

발 간 등 록 번 호

11-1790432-100003-01

개인정보관리 전문기관 지정 안내서 (중계전문기관 편)

2025. 03.



개인정보보호위원회

Personal Information Protection Commission

발 간 등 록 번 호
11-1790432-100003-01

개인정보관리 전문기관 지정 안내서

2025. 03.



개인정보보호위원회
Personal Information Protection Commission





중계전문기관 편

2025. 03.

개인정보관리 전문기관 안내서

안내 사항

발간 목적

본 안내서는 중계전문기관 지정 심사 시 제출서류 등 갖추어야 하는 사항, 심사사항별 검토내용을 안내함으로써 중계전문기관 지정 준비에 대한 이해를 돕고, 세부 점검사항 등 해석에 대한 명확한 기준을 안내하기 위해 작성되었습니다.

※ 중계전문기관 시스템 구축에 관한 사항에 대해서는 지정 안내서 외에 중계전문기관 시스템 구축 안내서 참고

제·개정 이력

일자	주요 내용
'25. 03. 발간	중계전문기관 지정심사 시 참고해야 할 「개인정보관리 전문기관 지정심사」 안내

재검토 기한

안내서의 최신성을 유지하기 위해 발간일(2025년 03월)을 기준으로 매 3년이 되는 시점(매 3년째의 12.31.까지를 말함)마다 보완 및 개선 등의 조치를 취할 예정입니다.

저작권 표시

본 안내서 내용의 무단전재를 금하며, 가공·인용할 때는 출처를 밝혀 주시기 바랍니다.

* 출처 : 개인정보보호위원회, 「개인정보관리 전문기관 지정 안내서 - 중계전문기관 편」 2025.03.

문의처

본 안내서 내용 관련 문의는 개인정보보호위원회 범정부 마이데이터추진단 서비스혁신팀(☎02-2100-3185), 보건복지부 의료정보정책과(☎044-202-2923)로 문의주시기 바랍니다.

법적 근거

「개인정보 보호법」제35조의2, 제35조의3 및 동법 시행령 제42조의2부터 제42조의15

※ 법령 최신 자료는 국가법령정보센터(www.law.go.kr), 개인정보관리 전문기관 지정 안내서-중계전문기관 편 최신자료는 개인정보보호위원회 누리집*, 개인정보 포털**을 참고

* 개인정보보호위원회 누리집(www.pipc.go.kr) : 법령 > 법령정보 > 안내서

** 개인정보 포털(www.privacy.go.kr) : 자료 > 자료보기 > 안내서

C O N T E N T S

I

개요 8

- 1. 중계전문기관 개요 8
- 2. 중계전문기관 지정 절차 15

II

중계전문기관 지정신청서 작성방법 18

- 1. 개인정보관리 지정신청서 양식 18
- 2. 지정신청서 작성요령 및 신청서류 19

III

중계전문기관 심사사항 해설 21

- 1. 사업계획서 21
- 2. 개인정보 관리 계획서 22
- 3. 설비 및 기술 23
- 4. 보호체계 48
- 5. 재정능력 152

- [부록] 중계전문기관 지정 Q&A 158

I 개요

1 중계전문기관 개요

가. 지정대상

- 개인정보 보호법 제35조의3제1항제1호 및 제2호에 따른 업무로서 개인정보 전송 중계에 필요한 기능을 제공하고 관련 시스템을 운영하는 업무 및 정보전송자의 전송을 지원하는 업무를 하는 기관·법인 또는 단체
- 중계전문기관은 일반전문기관, 특수전문기관을 함께 지정받을 수 없으며, 일반수신자 업무를 함께 수행할 수 없음

법률	시행령	고시
제35조의3(개인정보관리 전문기관) ① 다음 각 호의 업무를 수행하려는 자는 보호위원회 또는 관계 중앙행정기관의 장으로부터 개인정보관리 전문기관의 지정을 받아야 한다. 1. 제35조의2에 따른 개인정보의 전송 요구권 행사 지원 2. 정보주체의 권리행사를 지원하기 위한 개인정보 전송시스템의 구축 및 표준화 3. 정보주체의 권리행사를 지원하기 위한 개인정보의 관리·분석 4. 그 밖에 정보주체의 권리행사를 효과적으로 지원하기 위하여 대통령령으로 정하는 업무	제42조의9(개인정보관리 전문기관의 업무 등) ① 개인정보관리 전문기관은 다음 각 호와 같이 구분한다.	제2조(정의) 이 고시에서 사용하는 용어의 뜻은 다음과 같다.

법률	시행령	고시
	1. 중계전문기관: 법 제35조의3 제1항제1호 및 제2호에 따른 업무로서 개인정보 전송 중계에 필요한 기능을 제공하고 관련 시스템을 운영하는 업무 및 정보전송자의 전송을 지원하는 업무(이하 “중계업무”라 한다)를 수행하는 자 2. 일반전문기관: 법 제35조의3 제1항제3호에 따른 업무로서 통합조회, 맞춤형 서비스, 연구, 교육 등을 위해 정보전송자로부터 전송받은 개인정보(보건의료전송정보는 제외한다)를 관리·분석하는 업무를 수행하는 자 3. 특수전문기관: 법 제35조의3 제1항제3호에 따른 업무로서 통합조회, 맞춤형 서비스, 연구, 교육 등을 위해 정보전송자로부터 전송받은 보건의료전송정보를 관리·분석하는 업무를 수행하는 자	1~3. (생 략) 4. “중계전문기관”이란 영 제42조의9 제1항제1호에 해당하는 자로서 개인정보 전송 중계에 필요한 기능을 제공하고 관련 시스템을 운영하는 업무 및 정보전송자의 전송을 지원하는 업무를 수행하는 자를 말한다. 5. “일반전문기관”이란 영 제42조의9 제1항제2호에 해당하는 자로서 통합조회, 맞춤형 서비스, 연구, 교육 등을 위하여 정보전송자로부터 전송받은 개인정보(보건의료전송정보는 제외한다)를 관리·분석하는 업무를 수행하는 자를 말한다. 6. “특수전문기관”이란 영 제42조의9 제1항제3호에 해당하는 자로서 통합조회, 맞춤형 서비스, 연구, 교육 등을 위하여 정보전송자로부터 전송받은 보건의료전송정보를 관리·분석하는 업무를 수행하는 자를 말한다.

나. 중계전문기관 지정 기준

■ 중계전문기관은 기술수준 및 전문성, 안전성 확보조치, 재정능력을 갖추어 개인정보보호위원회 또는 관계 중앙행정기관의 장으로부터 지정을 받아야 함(구체적 사항은 ‘Ⅲ. 중계전문기관 심사사항 해설’ 부분 참고)

- **(기술수준 및 전문성)** 사업계획, 개인정보 관리 계획, 설비 및 기술
- **(안전성 확보조치 수준)** 법 제29조에 따른 안전조치의무, 보호체계
- **(재정능력)** 재무구조의 건전성 및 안전성, 자본금 10억 원 이상(법인의 경우는 납입자본금, 비영리법인은 기본재산, 법인이 아닌 단체의 경우 해당 단체가 보유하는 자산의 가액), 손해배상책임 이행을 위한 보험 또는 공제 가입하거나 준비금 적립

* 법 제2조제6호가목에 해당하는 공공기관에 대해서는 적용하지 않는다

법률	시행령	고시
제35조의3(개인정보관리 전문기관) ② 제1항에 따른 개인정보관리 전문기관의 지정요건은 다음 각 호와 같다. 1. 개인정보를 전송·관리·분석할 수 있는 기술수준 및 전문성을 갖추었을 것 2. 개인정보를 안전하게 관리할 수 있는 안전성 확보조치 수준을 갖추었을 것 3. 개인정보관리 전문기관의 안정적인 운영에 필요한 재정능력을 갖추었을 것 ③ ~ ⑦ (생략) ⑧ 제1항에 따른 개인정보관리 전문기관의 지정 절차, 제2항에 따른 지정요건의 세부기준, 제4항에 따른 지정취소의 절차 등에 필요한 사항은 대통령령으로 정한다.	제42조의11(개인정보관리 전문기관의 지정요건 세부 기준) ① 법 제35조의3 제2항에 따른 개인정보관리 전문기관의 지정요건별 세부기준은 다음 각 호와 같다. 1. 다음 각 목의 기술수준 및 전문성을 모두 갖추 것 가. 정보주체의 권리와 이익 등을 증대하고 정보주체와의 이해상충을 방지하기 위한 사업계획이 타당하고 건전할 것 나. 개인정보관리 전문기관 업무를 위한 개인정보 관리 계획이 적정할 것	

법률	시행령	고시
	다. 개인정보관리 전문기관 업무를 효과적으로 수행하기 위하여 보호위원회가 정하여 고시하는 설비 및 기술을 갖추고 있을 것 2. 다음 각 목의 안전성 확보조치 수준을 모두 갖추어 것 가. 법 제29조에 따른 안전조치 의무를 이행하기 위한 요건을 갖추어 것 나. 개인정보관리 전문기관을 안전하게 운영하기 위하여 보호위원회가 정하여 고시하는 보호체계를 적정하게 갖추어 것 3. 다음 각 목의 재정능력을 모두 갖추어 것(법 제2조제6호가목에 해당하는 공공기관에 대해서는 적용하지 않는다) 가. 재무구조가 건전하고 안전성이 있을 것 나. 다음의 구분에 따른 자본금 [법인의 경우에는 납입자본금 (비영리법인의 경우에는 기본재산)을 말하고, 법인이 아닌 단체의 경우에는 해당 단체가 보유하는 자산의 가액을 말한다. 이하 이 목에서 같다]을 갖추어 것 1) 중계전문기관: 자본금 10억원 이상 2) 일반전문기관 및 특수전문기관: 자본금 1억원 이상 다. 손해배상책임의 이행을 위한 보험 또는 공제에 가입하거나 준비금을 적립할 것(법 제39조의7제2항 각 호의 어느 하나에 해당하는 자에 대해서는 적용하지 않는다). 이 경우 보험·공제의 최저가입금액 또는 준비금의 최소적립금액의 기준은 별표 1의2와 같다.	

참고 | 「개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시」 [별표 3]

1. 중계전문기관

구분		지정기준
1. 설비 및 기술		1) 전송 관리 및 연계, 전송 이력 관리 기능 - 전송요구서 관리, 전자서명 검증, 접근권한 인가 - 이용기관(제3자 대상 정보전송자, 일반수신자, 일반·특수전문기관) 연계 기능 - 개인정보전송지원플랫폼과의 연계 기능 - 개인정보 전송 이력의 기록·보관 기능 ※ 중계 관련 시스템과 그 외 개인정보처리시스템의 분리 구축 2) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구축 및 보안시스템 구축 - 중계 관련 시스템의 네트워크 구축 - 중계 관련 시스템에 대한 침입탐지·차단 시스템 구축 3) 중계전문기관 업무의 가용성 및 연속성 보장을 위한 중계 관련 시스템 등의 이중화 구성, 모니터링, 통지 기능 - 중계 관련 시스템 및 네트워크의 이중화 구성 - 중계 관련 시스템 및 네트워크의 상시 모니터링 기능 - 중계 관련 시스템 장애, 오류 등으로 전송 중계 및 전송 지원이 불가한 경우 보호위원회 및 지정권자, 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관) 대상 통지 기능
2. 보호체계	가. 보호정책의 수립·시행 및 점검	1) 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획 ※ 중계 관련 시스템에 대한 정기적인 취약점 점검 및 조치 방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함 2) 개인정보 전송 이력의 기록·보관 및 점검 방안
	나. 접근권한의 관리	3) 중계 관련 시스템의 주요 정보를 안전하게 처리하기 위한 접근 권한의 관리 및 점검 체계
	다. 접근통제	4) 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 중계 관련 시스템, 업무용 단말 등에 대한 접근통제 체계 - 중계 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치 - 중계 관련 시스템에 대한 외부 접속시 안전한 인증수단 등의 적용 5) 유출 및 해킹을 신속하게 탐지·대응할 수 있는 모니터링 체계 - 유출 및 해킹 탐지 시스템, 네트워크 등에 대한 실시간 모니터링, 이상행위 분석·조사 등 조치 6) 중계 관련 시스템에 접근할 수 있는 관리용 단말기를 지정·관리하고, 중계 관련 시스템에 접속하려는 경우 추가적인 인증수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속 가능하도록 조치

구분	지정기준
	7) 중계 관련 시스템에 접근할 수 있는 관리용 단말기에 대한 인터넷망 차단 조치
라. 암호화	8) 정보의 송·수신 등을 위한 안전한 암호화 적용 9) 암호 키의 안전한 관리 체계 - 안전한 암호 키 생성·이용·배포·보관, 파기 등에 대한 정책 및 절차의 수립·이행 - 암호·복호화 대상 시스템과 암호키의 분리
마. 접속기록의 보관 및 점검	10) 중계 관련 시스템을 안전하게 관리하기 위한 접속기록의 보관 및 점검, 이상접속을 탐지하기 위한 조치 - 접속기록이 위·변조 및 도난, 분실되지 않도록 하기 위한 보관 조치 - 자동화된 방식 등을 통한 접속기록의 분석 기능
바. 악성프로그램 등 방지	11) 악성프로그램 등을 예방·탐지·대응하기 위한 조치 - 보안프로그램의 설치 및 최신 업데이트 관리, 발견된 악성프로그램에 대한 삭제 등 조치
사. 물리적 안전조치	12) 정보를 안전하게 보관·관리하기 위한 물리적 안전조치
아. 재해·재난 대비 안전 조치	13) 재난·재해 및 장애 등에 대비한 비상계획, 복구계획 및 훈련 실시 방안 - 위기대응 매뉴얼 마련 및 정기적 점검 14) 중계전문기관 업무 관련 정보의 안전한 백업 및 복구 체계(소산 포함)
자. 출력·복사시 안전 조치	15) 개인정보, 전송요구서 등을 안전하게 이용·관리하기 위한 출력·복사시 안전조치 방안 - 개인정보 출력시(인쇄, 화면표시, 파일생성 등) 용도의 특정 및 출력 항목 최소화
차. 파기	16) 정보의 안전한 파기를 위한 조치 - 데이터가 복구 또는 재생되지 않도록 파기하는 등 조치
카. 그 밖에 필요한 조치	17) 중계 관련 시스템의 가용성 및 연속성 보장을 위한 주요 지표 마련 및 관리 방안 18) 중계 관련 시스템 정비 및 프로그램 변경·이행 절차 19) 중계전문기관의 안정적 운영을 위한 전담조직 및 담당인력 지정

* 그 외 법 제29조에 따라 개인정보의 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 함

라. 중계전문기관 금지행위

■ 중계전문기관은 아래의 어느 하나에 해당하는 행위를 하여서는 아니 됨

개인정보 보호법 시행령 [별표 1의3]

- 중계전문기관 업무 종료 후 다른 법령에 따라 보존해야 하는 경우 등 정당한 사유 없이 법 제21조에 따라 개인정보를 파기하지 않는 행위
- 제42조의5제5항에 따른 정보주체의 전송 요구 철회에도 불구하고 즉시 전송 절차를 중단하지 않는 행위
- 제42조의6제9항에 따라 전송 내역에 대한 기록을 작성하지 않거나 보관하지 않는 행위
- 제42조의12제7항에 따라 중계업무의 일부 또는 전부를 중지 또는 폐지하는 경우 중지 또는 폐지 예정일의 6개월 전까지 지정권자에게 통지하지 않는 행위
- 전송 절차 중단을 이유로 정당한 이유 없이 위약금 등 경제적 대가를 요구하거나 제47조제1항에 따라 정해진 수수료의 금액보다 높은 수수료를 요구하는 행위
- 제47조제1항 단서에 따른 수수료 산정 기준을 위반하여 중계수수료를 산정하거나 중계수수료 산정에 필요한 기초 자료를 조작하는 등의 방법으로 중계수수료를 높이는 등 부당한 이익을 취득하는 행위
- 중계전문기관을 이용하려는 정보전송자, 일반전문기관, 특수전문기관 및 일반수신자에 대하여 정당한 사유 없이 중계를 거부하거나 이용을 차별하는 행위
- 그 밖에 위와 유사한 행위로서 정보주체의 이익을 침해하거나 전송 체계 확립에 지장을 초래할 우려가 있다고 보호위원회가 정하여 고시하는 행위

※ 금지행위를 위반한 자는 3천만원 이하의 과태료 부과(개인정보 보호법 제75조제2항제21호)

2 중계전문기관 지정 절차

가. 지정절차 및 방법

■ 개인정보보호위원회 또는 관계 중앙행정기관의 장은 중계전문기관 지정신청서를 제출받아 심사 후 중계전문기관 지정

- **(예비심사)** 중계전문기관으로 지정받고자 하는 자는 본 지정 전 사업계획, 개인정보 관리 계획 등을 기초로 예비심사를 신청할 수 있음
 - 예비심사는 서류심사로 진행되며, 신청서 접수 후 2개월 내에 심사결과를 통지하는 것을 원칙으로 함. 다만, 부득이한 사정이 있는 경우 1개월의 범위에서 연장 가능
- ※ 예비심사는 본지정 전 지정 요건에 대한 사전 심사로 허가의 효과를 갖지 아니하므로 예비심사만으로는 중계전문기관 업무를 수행할 수 없음
- ※ 예비심사는 필수가 아니며 고시 [별표 2]의 서류, [별표 3]의 시설 및 기술과 보호체계를 갖춰 본지정 신청이 가능하다고 판단한 경우 신청 가능
- **(본지정)** 본지정 심사는 지정신청, 지정권자 결정, 지정심사, 지정, 지정 공고 순으로 진행됨
 - 본지정은 지정권자가 신청서를 받은 날 다음날로부터 3개월 이내에 심사를 원칙으로 함. 다만, 부득이한 사정이 있는 경우 2개월의 범위에서 연장 가능

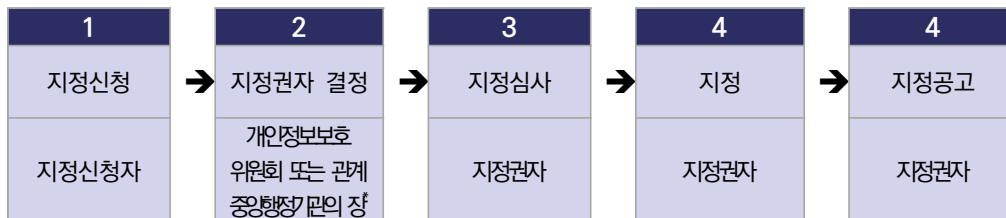
* 예비심사를 통과한 경우에는 1개월 이내에 지정 여부를 결정(다만, 부득이한 사정이 있는 경우 2개월 범위에서 연장 가능)

■ 중계전문기관 지정 절차

- 예비심사 단계



- 본지정 단계



* 관계 중앙행정기관의 장이 지정한 경우 개인정보보호위원회에 지정 통지

나. 지정신청 및 접수

- 1) **(지정신청)** 중계전문기관으로 지정받고자 하는 자는 개인정보 보호법 시행령 제42조의10제2항에 따른 지정권자*에게 지정신청서와 신청서류를 제출하여 지정 신청

※ 지정신청서 및 개인정보관리 전문기관 신청서류는 II-2. 지정신청서 작성요령 및 신청서류 참고

* 중계전문기관 지정권자(시행령 제42조의10제2항제1호)는 보호위원회 또는 중계전문기관이 전송받으려는 정보와 관련된 관계 행정기관의 장. 다만, 보건의료전송정보에 관한 중계전문기관의 경우에는 보건복지부장관으로 함

- 2) **(지정권자 결정)** 관계 중앙행정기관의 장은 전송받고자 하는 정보와의 업무 관련성을 고려하여 지정권자 결정

- 3) **(지정심사)** 지정심사는 서류심사, 현장심사, 종합심사 순으로 진행하며 지정신청을 받은 다음날부터 3개월 이내 지정(부득이한 사정이 있는 경우 2개월의 범위 내에서 기간 연장 가능)

※ 서류심사 시 충분한 준비가 안되었다고 판단될 경우 본지정 심사를 중단할 수 있음

※ 예비심사를 통과한 경우, 본지정 심사 시 서류심사와 현장심사를 병행하여 진행도 가능

- 단 아래 사유는 심사 기간에 포함하지 않음

1. 지정권자의 확인 및 변경, 지정권자 협의 등에 소요되는 기간
2. 지정권자가 신청서류 등이 누락되거나 보완이 필요한 경우 지정신청자에게 기간을 정하여 보완을 요구하고, 이에 따른 지정신청자의 신청서류 보완에 소요되는 기간
3. 법 또는 영에 따른 의무의 위반과 관련하여 지정신청자를 상대로 형사소송 절차가 진행되고 있거나 조사·검사 등의 절차가 진행되고 있고, 그 소송이나 조사·검사 등의 내용이 지정심사에 중대한 영향을 미칠 수 있다고 인정되는 경우에는 그 소송이나 조사·검사 등의 절차가 끝날 때까지의 기간
4. 지정심사 중 불가피한 사유, 대규모 사회재난, 천재지변 등 불가항력적인 사유로 인한 기간

- **(지정심사위원회)** 지정권자는 지정신청이 접수되면 중계전문기관 지정요건 세부기준의 충족 여부를 심사하기 위해 7인 이상 15인 이하로 지정심사위원회를 구성
 - **(지정심사위원회 자격)** 개인정보 보호, 정보보호, 회계 및 지정권자가 정하는 관계 분야 등 지정요건에 관하여 학식과 경험이 풍부한 전문가
- **(심사 유형 및 내용)**
 - **(서류심사)** 지정신청자가 제출한 서류를 기반으로 중계전문기관 지정요건 충족 여부에 대한 서류심사 진행
 - **(현장심사)** 시스템 및 기술, 보호체계 등 실사를 위한 현장심사 진행
 - **(종합심사)** 서류심사, 현장심사 결과를 종합하여 지정 여부를 결정하기 위한 종합심사 수행

4) **(지정)** 지정권자는 지정심사위원회의 심사결과를 확인하여 지정이 적합하다고 인정하는 경우 지정신청자에게 중계전문기관 지정결과를 통지하고 지정서를 발급

- **(보호위원회 통지)** 관계 중앙행정기관의 장은 중계전문기관을 지정한 경우 보호위원회에 미리 통보 (중계전문기관 명칭 및 주소, 담당부서 및 연락처, 지정 유효기간)

5) **(운영전환 및 서비스 개시)** 지정서 발급 후 실 운영 상태로 시스템을 전환하고 서비스 개시

※ 운영 전환 전 기능적합성 및 지정 시 부과받은 조건 이행여부를 확인 받아야 함

II 중계전문기관 지정신청서 작성방법

1 개인정보관리 지정신청서 양식

■ 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시 [별지 제2호서식]

개인정보관리 전문기관 지정신청서 ([] 지정 [] 예비심사)

지정 신청자	기관·법인·단체명 (또는 명칭)			사업자등록번호 또는 법인등록번호	
	대표자 성명				
	주소(주된 사무소 소재지)				
	주요 설비 및 시설의 설치 장소				
	홈페이지 주소				
담당자	담당자 성명				
	담당자 연락처	전화번호			
종전 지정사항	[] 예비심사	(예비심사를 받은 일시: 년 월 일)			
	[] 일반전문기관 업무	[] 특수전문기관 업무	(지정을 받은 일시: 년 월 일)		
지정받고자 하는 업무	[] 중계전문기관 업무 [] 일반전문기관 업무 [] 특수전문기관 업무				

「개인정보 보호법」제35조의3제1항 및 같은 법 시행령 제42조의10제1항, 「개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시」 제5조제1항 또는 제10조제1항에 따라 개인정보관리 전문기관 (지정을/예비심사를) 위와 같이 신청합니다.

년 월 일
(서명 또는 인)

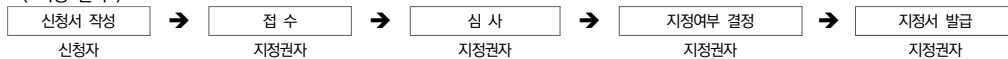
신청자

개인정보보호위원회 귀중 / 관계 중앙행정기관의 장 귀하

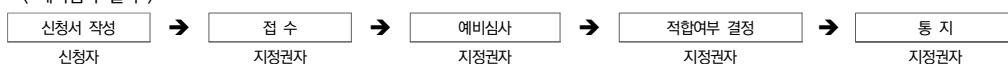
첨부 서류	별표 2에 따른 지정 신청서류	수수료 없음
-------	------------------	--------

처 리 절 차

< 지정 절차 >



< 예비심사 절차 >



210mm×297mm[(백상지(80g/㎡)또는 중질지(80g/㎡)]

2 지정신청서 작성요령 및 신청서류

가. 개인정보관리 전문기관 지정신청

■ 중계전문기관으로 지정받고자 하는 자는 지정신청서와 제출서류를 갖추어 지정권자에게 신청

- (신청유형) 예비심사와 본지정 중 해당하는 유형에 체크
- (지정신청자) 중계전문기관으로 신청하고자 하는 기관·법인·단체명, 해당 기관의 사업자등록번호 또는 법인등록번호, 대표자 성명, 주소, 주요 설비 및 시설의 설치 장소*, 홈페이지 주소 기재
* 중계전문기관 업무와 관련한 주요 설비 및 시설의 설치 장소 기재
- (담당자) 중계전문기관 업무를 담당하는 담당자 성명, 중계전문기관 업무와 관련하여 연락할 수 있는 전화번호와 이메일 기재
- (종전 지정사항) 예비심사를 받은 경우 예비심사 여부에 체크하고 예비심사 받은 일시를 기재
- (지정받고자 하는 업무) 중계전문기관 업무에 체크하여 제출
※ 중계전문기관 업무를 담당하는 자는 일반전문기관, 특수전문기관 및 일반수신자 업무를 함께 수행할 수 없음

나. 신청서류

구 분	신청서류	
	예비심사	지정
1. 정관 또는 규약	정관 또는 규약(안)	정관 또는 규약
2. 사업계획서	사업계획서(안)	사업계획서(증명 서류 포함)
3. 개인정보 관리 계획서	개인정보 관리 계획서(안)	개인정보 관리 계획서(증명 서류 포함)
4. 최근 3개년간의 재무제표	최근 3개년간의 재무제표	최근 3개년간의 재무제표
5. 법 제35조의3제2항에 따른 지정요건을 충족하였음을 증명할 수 있는 서류		
가. 영 제42조의11제1항제1호다목에 따른 설비 및 기술 증명 서류	설비 및 기술 구축 계획	설비 및 기술을 갖췄는지 확인할 수 있는 자료
나. 영 제42조의11제1항제2호가목에 따른 안전조치의무 이행 증명 서류	법 제29조에 따른 안전조치의무 이행 계획	법 제29조에 따른 안전조치의무 이행을 확인할 수 있는 자료
다. 영 제42조의11제1항제2호나목에 따른 보호체계 증명 서류	보호체계 이행 계획, 전문기관 업무 관련 내부 관리계획(안)	보호체계를 적절하게 갖췄는지 확인할 수 있는 자료, 전문기관 업무 관련 내부 관리계획
라. 영 제42조의11제1항제3호나목에 따른 자본금 증명 서류	자본금(납입자본금, 기본재산 또는 자산의 가액) 증빙자료 또는 자본금 조달계획서	자본금(납입자본금, 기본재산 또는 자산의 가액) 증빙자료
마. 영 제42조의11제1항제3호다목에 따른 손해배상책임의 이행을 위한 보험·공제 가입 또는 준비금 적립 증명 서류	-	보험·공제 가입 또는 준비금 적립을 확인할 수 있는 자료

※ 다만, 영 제42조의11제2항에 따라 지정권자는 보호위원회의 심의·의결을 거쳐 심사가 생략된 지정요건 세부기준과 관련한 신청서류를 생략 또는 간소화할 수 있음

붙임

1 사업계획서 및 개인정보 관리 계획서 작성 예시

가. 사업계획서

1. 서비스 개요

작성 항목	기재 내용
1. 목적 및 추진 전략	○ 사업 목적 및 추진전략
2. 서비스명(사업명)	○ 서비스 명칭(사업의 명칭)
3. 서비스 내용	○ 서비스 대상 기관 ○ 제공 서비스
4. 기대효과	○ 서비스 기대효과(우수성, 공익성 등)

2. 기관 개요

작성 항목	기재 내용
1. 운영 예산 계획	○ 사업비 총괄표 ○ 사업 운영을 위한 비목별 투입 예산 세부 계획 - 시스템 및 기술, 보호체계, 보험 및 공제 가입, 인건비, 서비스 운영 등 관련
2. 유관 사업 실적(해당 시)	○ 유관 사업 수행 실적

나. 개인정보 관리 계획서

구분	기재 내용
1. 개인정보 처리 방법	○ 전체 개인정보 흐름도 ○ 중계하는 정보에 대한 분리·보관 및 파기 방법 ○ 표준 전송규격 등 변환을 위한 개인정보 처리 방법
2. 전송요구 철회, 전송 중단 방법 및 절차	○ 전송요구 철회, 전송중단 시 대응 절차

III 중계전문기관 심사사항 해설

1 사업계획서

■ 세부 설명

작성 항목	기재 내용
1. 서비스 개요	○ 서비스 목적이 명확하며 실현 가능한가? ○ 추진 전략이 구체적이고 실현 가능한가? ○ 서비스 내용이 중계전문기관 업무로 구성되어 있는가? ○ 중계전문기관 업무 수행을 위한 기능이 갖추어져 있는가?
2. 기관 개요	○ 중계전문기관 업무 수행을 위한 조직 및 운영 인력이 마련되어 있는가? - 담당자들이 담당 업무를 수행하기에 적합한 경력을 갖추고 있는가? ○ 중계전문기관 업무를 수행하기에 비목별 세부 예산 계획이 적정하게 수립되어 있는가?

2 개인정보 관리 계획서

■ 세부 설명

구분	기재 내용
1. 개인정보 처리 방법	○ 중계하는 정보와 타 정보가 시스템에서 분리·보관되도록 설계되어 있는가? ○ 중계하는 정보에 대한 보유·이용기간 도과 시 파기하도록 설계되어 있는가? ○ 표준 전송규격 등 변환을 위한 개인정보 처리 방법을 갖추고 있는가?
2. 전송요구 철회, 전송 중단 방법 및 절차	○ 전송요구 변경, 철회, 전송중단 방법이 적절한가?

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계기관 업무와 관련한 개인정보 흐름도 • 중계하는 정보에 대한 분리·보관 - 개인정보 흐름도, 시스템 설계도 포함 • 표준 전송규격 등 변환을 위한 개인정보 처리 방법 - 처리 매뉴얼, 개인정보 흐름도, 시스템 설계도 포함

■ 미흡 사례

사례 1	• 표준 전송규격 등 변환을 위한 목적 이외로 개인정보가 보관되고 있음
사례 2	• 표준 전송규격 등 변환 이후에도 불필요하게 개인정보가 보관되고 있음

3 설비 및 기술

3.1. 전송 관리 및 연계, 전송 이력 관리 기능

3.1.1 전송요구서 관리, 전자서명 검증, 접근권한 인가

세부 지정요건 및 주요 확인사항	
주요내용	정보수신자로부터 전달받은 전송요구서를 검증하고, 정보 접근권한을 발급하여 관리하는 기능을 갖추어야 한다.
주요 준비사항	① 전송요구서 정당성 확인을 위한 전자서명 검증 및 정보주체 본인 확인 절차를 갖추고 있는가? ② 접근토큰(access token) 등 정보 접근권한 발급 및 권한관리 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송요구서 정당성 확인을 위한 전자서명 검증 및 정보주체 본인확인 절차를 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 정보수신자(일반수신자, 일반전문기관, 특수전문기관)로부터 받은 전송요구서의 정당성 및 유효성을 확인할 수 있는 기능 또는 시스템을 갖추어야 한다.
 - 인증기관(공동인증서 및 간편인증서 발급기관)이 제공하는 전자서명 검증 수단을 이용하여 전송요구서의 서명 검증 수행
 - 인증기관이 제공하는 전자서명 기반 본인확인 절차를 통해 인증서 명의자의 연계정보와 정보수신자가 전송요구 시 전송한 연계정보가 동일한지 검증 수행
- ※ 간편인증 전자서명인증사업자 연계를 위해 간편인증 인터페이스(KISA)를 적용하여, 전자서명 및 서명검증 등 수행 가능

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 인증기관(API 또는 모듈) 연계 테스트 결과서
현장실사(예시)	• 인증기관(API 또는 모듈) 연계 기능 실사

준비사항

② 접근토큰(access token) 등 정보접근권한 발급 및 권한관리 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 정보수신자(일반수신자, 일반전문기관, 특수전문기관)로부터 전송요구서를 수신하여 정당성/유효성을 확인한 후 접근토큰을 발급 및 관리할 수 있는 기능 또는 시스템을 갖추어야 한다.
- 중계전문기관은 접근토큰과 전송요구서상의 정보주체 전송요구 조건(정보전송자 및 정보항목, 전송요구서 유효기간, 정기적 전송여부 등)을 관리할 수 있는 기능을 갖추어야 한다.
 - 접근토큰, 갱신토큰 발급 및 폐기 기능
 - 접근토큰 및 전송요구 조건 관리 기능
- 중계전문기관은 전송요구서(전송요구 조건)를 함께 보관하여 이후 정보수신자가 정보조회 요청 시 제시한 접근토큰의 정당성(예, 접근토큰 유효성, 정보접근 범위, 유효기간 등)과 전송요구서상의 조건을 충족하는지 확인할 수 있는 기능을 갖추어야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 접근토큰 발급을 위한 검증 기능 • 접근토큰 발급 기능 • 갱신토큰 발급 기능 • 접근토큰 및 갱신토큰 정당성 확인 기능
현장실사(예시)	• 접근토큰 발급을 위한 검증 기능 실사 • 접근토큰 발급 기능 실사 • 갱신토큰 발급 기능 실사 • 접근토큰 및 갱신토큰 정당성 확인 기능 실사

3.1.2 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관) 연계 기능

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관은 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관)과의 API를 통해 연계할 수 있는 기능을 갖추어야 한다.
주요 준비사항	① 이용기관간 안전한 데이터 전송을 위한 상호인증(m-TLS, IP 접근제어, 자격증명 검증 등) 기능을 구축하고 있고 화이트리스트 방식으로 관리하고 있는가? ② 정보주체 식별자 중 주민등록번호에 대한 연계정보 변환 및 전송 기능을 갖추고 있는가? ③ 정보 추출 요청 API 및 정보 제공 API 연계 기능을 갖추고 있는가? ④ 정보요구 철회 시 접근토큰과 전송요구서 폐기 및 이력관리 기능을 갖추고 있는가? ⑤ 제3자 제공 동의내역 보관 및 조회 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 이용기관 간 안전한 데이터 전송을 위한 상호인증(m-TLS, IP 접근제어, 자격증명 검증 등) 기능을 구축하고 있고 화이트리스트 방식으로 관리하고 있는가?

■ 세부 설명

- 중계전문기관은 이용기관간 통신을 위하여 m(Mutual)-TLS 방식 등을 적용한 안전한 암호화 방식으로 운영해야 한다.
 - m-TLS를 적용하여 서버측 X.509 기반 인증서 검증 이외에 클라이언트측의 인증서도 검증 수행
 - 안전한 데이터 전송을 위하여 IP 접근통제 수행
 - ※ 제3자 대상 정보전송자의 경우 VPN으로도 연결 가능
- 중계전문기관은 제3자 대상 정보전송자, 정보수신자(일반 수신자, 일반전문기관, 특수전문기관) 연동을 화이트리스트 방식으로 관리하기 위해 개인정보 전송지원 플랫폼과 API 연계 기능을 갖추어야 한다.
 - 전송지원 플랫폼에 등록된 정보전송자, 정보수신자, 타 중계전문기관의 IP정보 등 연계를 위해 필요한 정보 송수신을 위한 연계 기능 구현
 - 이용기관을 화이트리스트 방식으로 정보 최신화 관리

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• m-TLS 적용 증적 • 전송구간 Cipher Suite 적용 알고리즘 리스트 제출
현장실사(예시)	• 이용기관간 IP 접근통제 목록

■ 미흡 사례

사례 1	• 중계전문기관이 타 중계전문기관과 데이터전송 시 전송구간 프로토콜이 상호인증 프로토콜인 m-TLS가 아닌 일반 TLS만 적용하고 있는 경우
------	--

준비사항

- ② 정보주체 식별자 중 주민등록번호에 대한 연계정보 변환 및 전송 기능을 갖추고 있는가?
(주민등록번호만을 보유한 정보전송자를 연계하는 중계전문기관만 해당)

■ 세부 설명

- 중계전문기관은 정보주체의 주민등록번호를 입력할 수 있는 화면 및 정보주체가 입력할 수 있도록 정보수신자에게 주소(URL)을 제공하여야 한다.
- 정보주체의 주민등록번호를 정보전송자가 제공하는 「주민등록번호 보유 여부 확인 API」를 통해 전송 및 확인하는 기능을 갖추어야 한다.
※ 근거 : 개인정보보호법 시행령 제62조2제3항
- 정보전송자가 주민등록번호 확인 성공 시 중계전문기관에서 연계정보 변환 후 정보전송자에게 연계 정보를 전달하는 기능을 갖추어야 한다.
 - 중계전문기관은 수신한 주민등록번호를 이용하여 본인확인기관에 연계정보 변환 요청
 - 정보수신자가 변환 결과 요청 시 성공 여부 응답 처리

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 정보전송자에게 주민등록번호 보유여부 확인 기능 • 정보전송자에게 변환된 연계정보 전송 기능 • 정보수신자에게 연계정보 변환 결과 처리 기능
현장실사(예시)	• 정보전송자에게 주민등록번호 보유여부 확인 기능 실사 • 정보전송자에게 변환된 연계정보 전송 기능 실사 • 정보수신자에게 연계정보 변환 결과 처리 기능 실사

준비사항

③ 정보 추출 요청 API 및 정보 제공 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 정보수신자(일반수신자, 일반전문기관, 특수전문기관)의 정보조회 요청 API에 따라 정보전송자와 정보추출 요청 API 연계 기능을 갖추어야 한다.
 - 정보수신자로부터 받은 접근토큰 검증 수행
 - 정보수신자 정보조회 요청 API 내역 확인
 - 정보전송자 정보추출 요청 API 호출
 - 전송 이력 저장
 - 정보수신자에게 정보 전달

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 정보추출 요청 API 연계 기능 • 전송 이력 저장 및 정보 전달 기능
현장실사(예시)	• 정보추출 요청 API 연계 기능 실사 • 전송 이력 저장 및 정보 전달 기능 실사

준비사항

④ 정보요구 철회 시 접근토큰과 전송요구서 폐기 및 이력관리 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 개인정보 전송지원 플랫폼 또는 정보수신자로부터 정보요구 철회 요청을 받아 처리하는 API 연계 기능을 갖추어야 한다.
 - 정보수신자로부터 접근토큰을 받아 전송요구 철회 처리
 - 개인정보 전송지원 플랫폼으로부터 전송요구서ID 받아 전송요구 철회 처리
 - 중계전문기관이 보유하고 있는 전송요구서 및 접근토큰 폐기
 - 폐기 이력 작성 및 관리

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 전송요구 철회 처리 API 연계 기능 • 전송요구서 및 접근토큰 폐기 기능 • 폐기 이력 관리 기능
현장실사(예시)	• 전송요구 철회 처리 API 연계 기능 실사 • 전송요구서 및 접근토큰 폐기 기능 실사 • 폐기 이력 관리 기능 실사

준비사항

⑤ 제3자 제공 동의내역 보관 및 조회 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 정보수신자가 전송요구를 통해 제공받은 정보에 대해 정보주체로부터 제3자 제공 동의 받은 내역을 API를 통해 전송받아 보관하는 기능을 갖추어야 한다.
- 정보주체가 개인정보 전송지원 플랫폼을 통해 제3자 제공 동의내역 조회 요청할 경우 제3자 제공 동의 목록 조회 API 연계할 수 있는 기능을 갖추어야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 정보수신자가 제3자 제공 내역을 전송할 수 있는 기능 • 개인정보 전송지원 플랫폼에서 요청한 제3자 제공 동의 이력을 처리할 수 있는 기능
현장실사(예시)	• 정보수신자가 제3자 제공 내역을 전송할 수 있는 기능 실사 • 개인정보 전송지원 플랫폼에서 요청한 제3자 제공 동의 이력을 처리할 수 있는 기능 실사

3.1.3 개인정보 전송지원 플랫폼과의 연계 기능

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관은 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추어야 한다.
주요 준비사항	① 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보 전송지원 플랫폼과의 이용기관 조회를 위한 API 연계 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 연계하려는 기관의 정보를 개인정보 전송지원 플랫폼에서 주기적으로 조회하여 확인할 수 있는 API 연계 기능을 갖추어야 한다.
- 중계전문기관은 이용기관(정보 전송자 정보, 일반수신자, 일반전문기관, 특수전문기관) 정보를 주기적으로 조회하여 확인하고 개인정보 전송지원 플랫폼에 적용할 수 있도록 API 연계 기능 구현

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보 전송지원 플랫폼과의 API 연계 기능
현장실사(예시)	• 개인정보 전송지원 플랫폼과의 API 연계 기능 실사

3.1.4 개인정보 전송 이력 기록·보관 기능

※ 중계 관련 시스템과 그 외 개인정보처리시스템의 분리 구축

세부 지정요건 및 주요 확인사항	
주요내용	개인정보 전송 내역에 대한 기록·보관 및 조회할 수 있는 기능 또는 시스템을 갖추어야 하고, 중계전문기관 시스템과 그 외 개인정보처리시스템은 분리하여 구축하고 운영하여야 한다.
주요 준비사항	① 전송 내역 기록·보관 및 조회할 수 있는 시스템을 갖추고 있는가? ② 중계 관련 시스템과 그 외 개인정보처리시스템을 분리하여 구축·운영하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송 내역 기록·보관 및 조회할 수 있는 시스템을 갖추고 있는가?

■ 세부 설명

- 중계전문기관은 전송 내역을 보관할 수 있는 시스템을 갖추어야 한다.
 - 전송 내역은 최소 3년간 보관될 수 있도록 충분한 저장 공간 또는 확장 가능한 구조로 구현
 - 전송 내역 조회 확인 기능(예, 별도 관리자 페이지 등) 구현
 - 전송 내역이 위·변조, 도난, 분실되지 않도록 안전한 보관 체계 마련
 - 전송 내역을 보관하는 시스템에 대한 비인가자의 접근통제 등 보호조치
 - 중계전문기관은 정보수신자(일반수신자, 일반전문기관, 특수전문기관)와 정보전송자 간 전송요구한 개인정보 영역(예: 정보조회 API의 본문영역)을 제외한 전송 내역을 보관
- 중계전문기관은 정보주체가 개인정보 전송지원 플랫폼을 통해 전송 내역을 조회할 수 있도록 개인정보 전송지원 플랫폼과 전송내역 조회 API 연계 기능을 갖추어야 한다.
 - 전송요구 내역 조회 요청 및 응답 처리

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보 전송 내역을 기록하고 보관을 위한 시스템
현장실사(예시)	• 전송내역 보관 시스템의 전송 내역 보관 및 조회 기능과 시스템에 대한 접근통제 등 위·변조 대비한 안전조치 운영 현황 실사

■ 미흡 사례

사례 1	• 개인정보 전송 내역을 기록하고 보관을 확인할 수 있는 충분한 저장 공간을 갖추지 않은 경우
------	--

준비사항

② 중계 관련 시스템과 그 외 개인정보처리시스템을 분리하여 구축 운영하고 있는가?

■ 세부 설명

- 중계전문기관 운영을 위한 시스템은 중계전문기관에서 자체적으로 운영하는 시스템과 분리하여 구축·운영하여야 한다.
 - 중계전문기관 운영을 위한 시스템은 별도의 서버 팜(Zone)을 구성
 - 중계전문기관 자체적으로 운영하는 개인정보처리시스템과의 정보 전송이 되지 않도록 접근통제 등 방안 마련
 - 개인정보를 가공 및 보관하지 않는 네트워크 장비, 보안 장비 등은 기존 설비 활용 가능

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계전문기관 업무를 위한 시스템과 기존에 처리하는 개인정보처리시스템과의 분리 및 보관할 수 있는 설비 및 시스템 • 중계전문기관 시스템 구성도 및 자산 리스트(DB서버, WAS 등) • 중계전문기관 시스템 DB 테이블 명세서(개인정보가 포함된 테이블 포함)
현장실사(예시)	• 네트워크 구성도 실사 • 중계전문기관 업무처리 DB 분리, 인스턴스 분리 여부 실사 • 기존 개인정보 분리를 입증할 수 있는 서버 가상화(VM), DB 서비스 계정, DB 스키마 정보 등(기존 개인정보DB 여부)

■ 미흡 사례

사례 1	• 중계 관련 시스템이 다른 목적의 시스템들과 같은 서버 팜에서 운영되는 경우
------	---

3.2 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 구성 및 보안시스템 구축

3.2.1. 중계 관련 시스템의 네트워크 구축

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고 방지 등 운영하는 시스템 보호가 가능한 네트워크를 구성하여야 한다.
주요 준비사항	① 중계 관련 시스템의 운영 및 보호가 가능한 네트워크를 구성하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템의 운영 및 보호가 가능한 네트워크를 구성하고 있는가?

■ 세부 설명

- API 연계를 통한 처리와 제공 받은 정보를 처리하는 중계 관련 시스템을 운영하기 위한 아래와 같은 네트워크에 대한 보호대책을 마련하여야 한다.
 - 네트워크에 대한 비인가 접근을 통제하기 위하여 IP관리, 불필요한 서비스 통제 등 관리 절차 수립
 - 중계 관련 시스템 등에 IP주소 부여하고 허가되지 않은 IP사용 통제
 - 업무목적 및 중요도에 따라 네트워크 분리(DMZ, 서버팜, DB존, 개발존 등)와 접근통제 보호조치
 - 네트워크 장비에 설치된 불필요한 서비스 및 포트 차단 등 보호조치
- 중계 관련 업무 처리를 위한 DMZ, 서버팜, DB존 등으로 구분하여 네트워크 환경에 대한 보호조치가 되도록 한다.
 - DMZ구간과 내부망(서버팜, DB존)에 대한 접근통제 운영 및 관리
 - ※ DMZ구간과 내부망사이에 방화벽 등을 설치하여 접근통제 방안 마련 고려
 - 내부망의 주소 체계는 사실 IP주소 체계를 사용하여 외부에 주소체계가 외부에 노출되지 않도록 보호조치
 - 이외에 네트워크 환경 및 정보시스템 보호를 위한 정보보호 시스템 구축 및 운영
- 물리적으로 떨어진 IDC, 지사 등과의 네트워크 연결 시 전용회선 또는 VPN(가상사설망) 등을 활용하여 안전한 접속환경을 구성하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계 관련 시스템 네트워크 구성도 • 네트워크 접근통제 규칙(Rule) • 정보보호 시스템 목록
현장실사(예시)	• 네트워크 구성에 따른 전산실 등 실사

3.2.2. 중계 관련 시스템에 대한 침입탐지·차단 시스템 구축

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고의 탐지 및 차단할 수 있는 네트워크를 구성하고 침입차단·탐지 시스템을 설치 운영하도록 하여야 한다.
주요 준비사항	① 정보통신망을 통한 불법적인 접근방지를 위한 침입차단시스템, 침입탐지시스템 등 보호설비 또는 기술을 갖추고 있는가? ② 중계 관련 시스템 및 업무용 컴퓨터에 대한 이동식 저장 매체 통제, 바이러스 및 스파이웨어 탐지 등을 위한 보안프로그램을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 정보통신망을 통한 불법적인 접근방지를 위한 침입차단시스템, 침입탐지시스템 등 보호설비 또는 기술을 적용하고 있는가?

■ 세부 설명

- 정보통신망을 통한 불법적인 접근 및 침해사고를 방지하기 위해 아래의 기능을 포함한 안전조치를 하여야 한다.
 - 접근권한을 IP 주소, 포트, MAC 주소 등으로 제한하여 인가받지 않은 접근을 제한할 수 있는 침입 차단시스템(방화벽), 침입탐지 및 침입방지시스템(IDS, IPS), UTM 등 보호설비 설치 및 운영
 - 중계 관련 시스템을 위한 방화벽 접근통제 정책 수행
 - 침입탐지 또는 침입방지시스템 등에 대한 최신 시그니처 및 패턴 업데이트를 통한 최신화 유지
 - 이외에 필요시 추가적인 침해사고 방지를 위한 보호설비 또는 기술 적용(예, 서버웹 셸 모니터링 적용 등)
- ※ 클라우드서비스를 이용하는 경우, 클라우드서비스제공자가 제공하는 보안기능 또는 서비스를 이용하여 접근통제 기능 구현 적용

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증거자료(예시)	• 방화벽, IPS or IDS, UTM 등 정보보호시스템 목록(예, 자산관리대장) • 네트워크 상세 구성도 (방화벽, IPS 등 침입차단시스템 중심)
현장실사(예시)	• 방화벽, IPS or IDS, UTM 등 정보보호시스템 구축 현황 실사 • 침입차단시스템(방화벽) 이외에 SW 모듈 형태보안 적용 또는 이에 준하는 침해사고 방지 기술 적용 여부 확인

■ 미흡 사례

사례 1	• 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 정보보호시스템이 구축되지 않은 경우
사례 2	• 침입방지시스템(IPS 등) 등 보안솔루션이 시그니처(패턴)를 주기적으로 최신 패턴으로 업데이트 하지 않은 경우

준비사항

- ② 시스템 및 업무용 컴퓨터에 대한 이동식 저장매체 통제, 바이러스 및 스파이웨어 탐지 등을 위한 보안프로그램을 갖추고 있는가?

■ 세부 설명

- 중계 관련 시스템 및 업무용 컴퓨터 등에 대하여 이동식 저장매체 통제, 백신 소프트웨어 설치 등 보호조치를 하여야 한다.
 - 이동식 저장매체 읽기, 쓰기 통제를 위한 정보보호시스템 또는 기술 적용
 - 이동식 저장매체를 사용할 경우, 내부 정책을 수립하여 책임자 승인절차를 통해 제한적으로 사용하도록 통제
 - 바이러스, 스파이웨어, 웜, 트로이목마, 랜섬웨어 등 악성코드로부터 보호할 수 있는 보안프로그램 설치 및 운영
 - ※ 보안프로그램의 경우 운영체제에서 제공하여 자동으로 설치된 프로그램(예, Windows Defender)도 가능함
 - ※ 클라우드 환경의 경우 클라우드 서비스에서 제공된 보안프로그램 설치 및 운영
 - 보안프로그램은 업데이트 등을 통해 최신상태 유지

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 이동식 저장매체 통제, 백신 소프트웨어 등 정보보호시스템 목록(예, 자산관리대장) • 백신 프로그램 설치 범위 (전송 요구 관련 시스템은 모두 포함, 업무용 컴퓨터 등)
현장실사(예시)	• 이동식 저장매체 통제 현황 실사 • 주기적인 악성코드 감염 여부 모니터링 및 서버/단말기 등에 대한 최신 백신 엔진 업데이트 현황 관리

■ 미흡 사례

사례 1	• 중계 관련 시스템 및 해당 업무 담당자 컴퓨터에 백신 프로그램이 설치되어 있지 않은 경우
사례 2	• 백신 엔진이 장기간 최신 버전으로 업데이트되지 않은 경우
사례 3	• 중계 관련 시스템 및 해당 업무 담당자 컴퓨터에 악성코드 감염 이력이 확인되었으나, 감염 경로 및 바이러스 감염 원인 분석 후 재발 방지 대책 등 구체적인 조치 활동을 수행하지 않은 경우

3.3 중계전문기관 업무의 가용성 및 연속성 보장을 위한 중계 관련 시스템 등의 이중화 구성, 모니터링, 통지 기능

3.3.1 중계 관련 시스템 및 네트워크 이중화 구성

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관 업무를 수행하기 위한 가용성과 연속성 보장을 위해 중계 관련 시스템 및 네트워크를 이중화 구성하여 운영하여야 한다.
주요 준비사항	① 중계 관련 시스템 및 네트워크를 이중화하여 구성하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템 및 네트워크를 이중화하여 구성하고 있는가?

■ 세부 설명

- 중계 관련 시스템 대상으로 지속적인 서비스 지원이 가능하도록 가용성을 고려한 주요 시스템 및 네트워크 이중화를 구축하여야 한다.
 - 내부 네트워크 및 주요 장비 장애 발생 시 신속한 Fail-Over를 위한 물리적/논리적 네트워크 이중화 (Active-Active, Active-Standby 구조 모두 가능)
 - 정보처리시스템(예, 서버, DB, 보안시스템 등)에 대한 이중화 구축
 - ※ 서버 이중화 등은 물리적 하드웨어 이중화 이외에 서버 가상화(VM)를 통한 이중화도 가능
 - 중요정보를 저장하고 있는 스토리지 이중화
 - API 연계 관련 시스템 이중화

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성도 • 시스템 구성도 (이중화) • 정보 시스템 배치도 • 네트워크 장비 Config, 라우팅 프로토콜 • 서비스 장애 유형 별 Fail-Over 정책
현장실사(예시)	• 네트워크 장비 Config 점검 • 중요 설비에 대한 이중화 여부 확인

■ 미흡 사례

사례 1	• 중계서비스 관련 서버는 모두 이중화되어 있으나, 내부 네트워크 장비 중 일부가 이중화되지 않아 해당 네트워크 장비에서 장애가 발생할 경우 서비스 중단이 우려되는 경우
------	--

3.3.2 중계 관련 시스템 및 네트워크의 상시 모니터링 기능

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관 업무 수행에 대한 무결성, 가용성 및 연속성을 보장하기 위한 제반시스템 및 네트워크에 대한 이상감지를 상시 모니터링할 수 있는 기능을 갖추어야 한다.
주요 준비사항	① 중계업무 제반시스템 및 네트워크에 대한 이상감지를 상시 모니터링할 수 있는 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계업무 제반시스템 및 네트워크에 대한 이상감지를 상시 모니터링 할 수 있는 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관 업무를 위하여 실시간으로 네트워크 트래픽을 모니터링하는 기능을 갖추어야 한다.
 - SNMP 프로토콜을 이용한 NMS 시스템 모니터링 또는 MRTG(Multi Router Traffic Grapher), PRTG 등에 준하는 네트워크 대쉬보드 모니터링
- 중계전문기관 본연의 업무를 위하여 실시간으로 중계업무 관련 정보시스템을 상시 모니터링하는 기능을 갖추어야 한다.
 - 미들웨어 또는 WAS 서버 등에서 중계업무와 관련된 프로세스 및 서버 데몬(백그라운드 동작 프로그램)을 모니터링하는 시스템 대쉬보드 운영

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계전문기관 정보시스템 운영 지침 (프로세스 모니터링 등) • 서버 모니터링 항목 : 프로그램 또는 프로세스 - 미들웨어(WAS서버), AP 데몬, DB 프로세스, 프로세스 ID 기반컨테이너 모니터링 등 • 실시간 네트워크 트래픽 모니터링 항목 (화선 이상 및 네트워크 트래픽 이상현상 감지 등)
현장실사(예시)	• 실시간 네트워크 트래픽 모니터링에 따른 이상현상 감지 여부 (NMS, MRTG, PRTG 등) • 실시간 서버 프로세스 모니터링에 따른 이상현상 감지 여부 (프로세스 ID, 서버 데몬 등)

■ 미흡 사례

사례 1	• 중계전문기관이 중계업무를 위한 시스템에 대하여 반드시 모니터링 항목에 포함된 주요 데몬 등을 실시간으로 확인할 수 있는 시스템과 관리체계가 구축되지 않은 경우
사례 2	• 중계전문기관이 중계업무를 위하여 주요 네트워크 설비 및 화선 트래픽에 대하여 실시간으로 확인할 수 있는 대쉬보드 시스템 및 이상현상 모니터링 관리체계가 구축되지 않은 경우

3.3.3 중계 관련 시스템 장애, 오류 등으로 전송 중계 및 전송 지원이 불가한 경우 보호위원회 및 지정권자, 이용기관(정보전송자, 일반수신자, 일반전문기관, 특수전문기관) 대상 통지 기능

세부 지정요건 및 주요 확인사항	
주요내용	시스템 장애, 오류 등으로 전송 중계 및 전송 지원이 불가한 경우 보호위원회 및 지정권자, 이용기관 대상으로 통지할 수 있는 기능을 갖추어야 한다.
주요 준비사항	① 중계업무 장애, 오류 등으로 정보 중계가 불가한 경우 보호위원회 및 이용기관에 통지를 위한 기능을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계업무 장애, 오류 등으로 정보 중계가 불가한 경우 보호위원회 및 이용기관에 통지를 위한 기능을 갖추고 있는가?

■ 세부 설명

- 중계전문기관이 중계시스템 장애, 오류 발생 및 복구 시 보호위원회 및 연계기관에 메시지 전송시스템 등의 비상 알람 통지 기능을 갖추어야 한다.
- 정보시스템 장애 또는 자연재해 등으로 인한 정보 중계가 불가한 경우 비상 알람 시스템 및 통지 절차 수립
- 긴급 장애 알람 홈페이지 구축 또는 긴급 메시지 전송 시스템 운영

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계시스템 장애, 오류 발생 시 보호위원회 및 연계기관에 메시지 전송시스템 등의 비상 알람 통지 시스템 운영 • 장애 알람 홈페이지 또는 메시지 전송 시스템
현장실사(예시)	• 재난·재해 발생 등 긴급 장애 발생 시 메시지 전송시스템 운영 여부 및 긴급 문자 발송 기본 문구

■ 미흡 사례

사례 1	• 중계전문기관이 중계시스템 장애, 오류 발생 시 메시지 전송시스템 등의 비상 알람 통지 시스템이 구축되지 않은 경우
------	---

4 보호체계

4.1. 보호정책의 수립·시행 및 점검

4.1.1 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획

※ 중계 관련 시스템에 대한 정기적인 취약점 점검 및 조치 방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 방안 포함

세부 지정요건 및 주요 확인사항	
주요내용	전문기관 업무 관련 정보의 안전성 확보를 위한 보호 정책을 수립하여야 한다. 보호 정책 수립 시, 「개인정보의 안전성 확보조치 기준(개인정보보호위원회고시 제2023-6호)」 제4조에 규정된 내부 관리계획의 기재사항을 포함하여 중계 관련 시스템에 대한 정기적 취약점 점검 및 조치방안, 해킹 등 전자적 침해행위로부터 보호하기 위한 내용 및 전문기관 업무를 반영한 내용 등을 포함하여 작성하여야 한다.
주요 준비사항	① 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획을 수립·시행하고 있는가? ② 내부 관리계획 이행 실태 점검을 수행하고 있는가? ③ 시스템(서버, DB, 응용프로그램) 및 네트워크 등에 대한 취약점 점검 절차를 수립·이행하고 있는가? ④ 발견된 취약점에 대한 조치 방안을 마련하고 있는가? ⑤ 침해사고의 정의 및 범위, 긴급연락체계 구축, 침해사고 대응 모니터링, 침해사고 발생 시 보고 및 대응절차, 침해사고 대응조직의 구성 등을 포함한 침해사고 대응체계를 수립하고 있는가? ⑥ 침해사고 대응 절차에 관한 연 1회 이상 모의훈련 계획을 수립하고 이에 따라 주기적으로 훈련을 실시하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시 개인정보 보호법 제34조(개인정보의 유출 등의 통지·신고)

준비사항

① 전문기관 업무 관련 정보의 안전성 확보를 위한 내부 관리계획을 수립·시행하고 있는가?

■ 세부 설명

- 전문기관 업무 관련 정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 전문기관업무 특성을 반영한 내부 관리계획을 수립·시행하여야 한다.
 - ※ 기업(기관)에서 수립된 내부 관리계획에 전문기관 업무 관련 내용을 추가 작성하거나 별도의 지침, 절차를 둘 수 있음
- 전문기관 조직의 구성 및 운영에 관한 사항
- 전문기관 관리책임자의 지정에 관한 사항
 - ※ 전문기관 관리책임자는 중계전문기관 운영 및 업무를 총괄하여 책임을 가진 자를 말함
- 전문기관 관리책임자와 개인정보취급자의 역할 및 책임에 관한 사항
- 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항
- 접근 권한의 관리에 관한 사항
- 접근 통제에 관한 사항
 - ※ 중계 관련 시스템에 대해 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위한 네트워크 접근통제, 이중화 구성, 인터넷 망 차단에 관한 사항 포함
 - ※ 중계 관련 시스템과 중계 관련 이외의 기업(기관)에서 운영하고 있는 시스템과 분리하여 운영해야 하므로 이에 대한 접근 통제 및 보호조치 방안 포함
- 개인정보의 암호화 조치에 관한 사항
- 접속기록 보관 및 점검에 관한 사항
- 악성프로그램 등 방지에 관한 사항
- 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항
- 물리적 안전조치에 관한 사항
- 파기에 관한 사항
 - ※ 파기대상을 누락없이 작성하고 파기 시기 및 방법·절차를 구체적으로 작성하여 파기 수행이 제대로 될 수 있도록 작성
 - ※ 파기대상으로 전송요구서, 폐기된 접근토큰, 3년이 경과된 전송내역 정보 및 개인정보는 반드시 포함되어야 함
- 개인정보 유출사고 대응 계획 수립·시행에 관한 사항
 - ※ 개인정보 유출통지, 유출신고 등 유출사고 대응을 위한 구체적인 내용을 작성하여야 함. 별도의 지침, 절차를 둘 수 있음
- 위험 분석 및 관리에 관한 사항
- 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항

- 내부 관리계획의 수립, 변경 및 승인에 관한 사항
 - 그 밖에 중계 업무 관련 정보의 안전성 확보를 위하여 필요한 사항
- 수립된 내부 관리계획의 중요한 변경이 있는 경우에는 이를 즉시 반영하여 시행하고, 그 수정 이력을 관리하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 운영관리 정책(내부 관리계획, 지침, 절차서, 매뉴얼 등)
현장실사(예시)	• 운영관리 정책 수립 여부 확인 • 운영관리 정책내용 적정성 확인

■ 미흡 사례

사례 1	• 내부 관리계획을 수립하지 않은 경우
사례 2	• 내부 관리계획에서 일부 중요 항목이 누락되거나 최근 개정된 관계 법령이 반영되지 않은 경우

준비사항

② 내부 관리계획 이행 실태 점검을 수행하고 있는가?

■ 세부 설명

- 중계 관련 시스템에 대한 내부 관리계획의 이행 실태를 연 1회 이상 점검 · 관리하여야 한다.
 - 내부 관리계획 내 작성된 내용을 점검항목으로 식별하고, 각 항목의 이행 여부를 점검하여야 함
 - 이행 실태 점검은 내부 관리계획에 따른 기술적, 관리적 및 물리적 안전조치 사항에 대하여 누락없이 점검 및 관리되도록 해야 함
 - 이행 실태 점검 결과에 따른 미흡사항에 대하여 개선 조치를 수행해야 함
- ※ 중계 관련 시스템이 운영되기 전일 경우 이행 실태 점검은 계획서로 대체
- 내부 관리계획 이행 실태 점검 결과에 대해 전문기관 관리책임자에게 보고하고, 이에 대해 개인정보 보호 책임자(CPO)는 제대로 수행되고 있는지에 대하여 관리·감독하도록 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획 이행 실태 점검표 • 전문기관 관리책임자 검토 및 승인 결과 • 이행 실태 점검 계획(시스템 운영되기 전일 경우)
현장실사(예시)	• 내부 관리계획 이행 실태 점검 항목 누락 여부 확인 • 전문기관 관리책임자의 내부 관리계획 검토 및 승인 결과 확인

■ 미흡 사례

사례 1	• 전문기관 관리책임자의 개인정보 내부 관리계획 검토 이력이 존재하지 않은 경우
------	--

준비사항

③ 시스템(서버, DB, 응용프로그램) 및 네트워크 등에 대한 취약점 점검 절차를 수립·이행하고 있는가?

■ 세부 설명

- 시스템(서버, DB, 응용프로그램) 및 네트워크 등에 대한 취약점 점검 절차에 다음의 사항을 포함하여 연 1회 이상 점검을 수행하여야 한다.
 - 취약점 점검 대상(예 : 서버, 네트워크 장비 등)
 - 취약점 점검 주기(법적 요구사항, 중요도 등 고려)
 - 취약점 점검 담당자 및 책임자 지정
 - 취약점 점검 절차 및 방법 등
 - 중요도에 따른 조치 기준
 - 취약점 점검 결과 보고 절차
 - 미조치 취약점에 대한 보안성 검토 등
 - 취약점 점검은 다음과 같은 내용을 포함하여 실시하여야 한다.
 - 라우터, 스위치 등 네트워크 장비 구성, 설정 취약점
 - 서버 OS, WEB/WAS, DBMS, 어플리케이션 등에 대한 보안 설정 취약점 및 알려진 취약점
 - 방화벽 등 정보보호시스템 취약점
 - 웹 및 모바일 서비스(모바일 앱 등) 취약점
 - 사용자 단말기(PC), 스마트 기기 취약점
 - 소스코드 보안약점
 - 인터페이스 및 API 취약점 등
 - 취약점 점검 시 이력관리가 될 수 있도록 '점검자', '점검일시', '점검대상', '점검방법', '점검내용 및 결과', '발견사항', '조치사항' 등이 포함된 보고서를 작성하여야 한다.
 - 취약점 점검은 최소 연 1회 이상 정기적으로 수행하여야 하며, 최신 보안취약점 발생 등 필요시 수시로 수행하여야 한다.
- ※ 시스템(서버, DB, 응용프로그램) 및 네트워크 등이 운영되기 전에 취약점 점검을 수행해야 함

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 취약점 점검 계획서 • 취약점 점검 결과보고서
현장실사(예시)	• 취약점 점검 대상, 취약점 점검 주기 등 필요한 사항이 포함된 취약점 점검 계획이 적절하게 수립되어 있는지 확인 • 취약점 점검 계획에 따라 취약점 점검을 수행하였는지 확인

■ 미흡 사례

사례 1	• 연 1회 취약점 점검이 수행되었으나, 주요 시스템 중 일부가 취약점 점검 대상에서 누락된 경우
------	--

준비사항

④ 발견된 취약점에 대한 조치 방안을 마련하고 있는가?

■ 세부 설명

- 발견된 취약점에 대한 조치방안을 마련하여 조치를 수행하고, 그 결과를 전문기관 관리책임자에게 보고하여야 한다.
 - 취약점 점검 시 이력관리가 될 수 있도록 점검일시, 점검대상, 점검방법, 점검내용 및 결과, 발견사항, 조치사항 등이 포함된 보고서 작성
 - 불가피하게 조치할 수 없는 취약점에 대해서는 그 사유를 명확하게 확인하고, 이에 따른 위험성, 보완 대책 등을 전문기관 관리책임자에게 보고
- 취약점별로 대응조치 완료 후 이행점검 등을 통하여 완료 여부 확인
 - 취약점 대응조치 이행점검 완료 결과에 대해 전문기관 관리책임자에게 보고

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 취약점 점검 계획서 • 취약점 점검 결과보고서 • 취약점 점검 조치 계획보고서 • 취약점 점검 조치 완료보고서(미조치 항목 사유 포함)
현장실사(예시)	• 취약점 점검 결과 발견된 취약점에 대한 조치계획이 적절히 마련되었는지 확인 • 취약점 점검 결과 발견된 취약점에 대해 개선 조치 및 이행점검이 수행되었는지 확인 • 취약점 점검 결과 발견된 취약점 중 미조치 취약점에 대한 타당성 검토 및 보완대책 마련 등이 적절히 이행되었는지 확인 • 취약점 점검 결과, 보완조치 계획 등이 책임자에게 보고되었는지 확인

■ 미흡 사례

사례 1	• 취약점 점검에서 발견된 취약점에 대한 개선조치를 이행하지 않은 경우
사례 2	• 취약점 점검 이후 단기간 내에 조치할 수 없는 취약점에 대한 타당성 검토 및 승인 이력이 없는 경우

준비사항

- ⑤ 침해사고의 정의 및 범위, 긴급연락체계 구축, 침해사고 대응 모니터링, 침해사고 발생 시 보고 및 대응절차, 침해사고 대응조직의 구성 등을 포함한 침해사고 대응체계를 수립하고 있는가?

■ 세부 설명

- 서비스 관련 주요 데이터의 유출, 장애 및 침해 등의 사고 발생 시 조직의 업무에 미치는 영향을 고려하여 식별된 정보자산의 중요도를 평가하고 신속하게 대응하기 위해 아래의 내용을 포함하여 절차를 수립하여야 한다.
 - 침해사고의 정의 및 범위 (중요도 및 유형 포함)
 - 침해사고 발생 시 기록, 보고 절차
 - 비상연락체계
 - 침해사고 신고 및 통지 절차 (관계기관, 외부전문가, 이용자 등)
 - 침해사고 유형에 따른 대응 절차 (대응조직 구성 및 구성원의 역할과 책임 포함)
 - 침해사고 복구조직의 구성, 책임 및 역할
 - 침해사고 대응 및 복구 훈련, 훈련 시나리오
 - 침해사고 훈련 결과 검토 후 개선 방안을 침해사고 대응 절차에 반영
- 침해사고를 모니터링하고 종합적인 대응을 위한 체계를 수립하여야 한다.
 - 모니터링 및 대응 방법, 절차
 - 대응 조직 및 인력
 - 침해사고 보고 및 승인 절차
- 보안관제서비스 등 외부 기관을 통하여 침해사고 대응체계를 구축·운영하는 경우 침해사고 대응절차의 세부사항을 계약서(SLA 등)에 반영하여야 한다.
 - 보안관제 용역의 범위
 - 침해 징후 발견 및 침해사고 발생 시 보고 및 대응 절차
 - 침해사고 발생에 따른 책임 및 역할에 관한 사항 등
- 침해사고의 모니터링, 대응 및 처리와 관련된 외부전문가, 전문 업체, 전문기관(KISA) 등과의 연락 및 협조체계를 수립하여야 한다.
 - 외부 전문기관과의 비상연락망 유지 등 연락체계를 구축하고 담당자, 연락처 등의 정보를 최신으로 유지
 - 자체 긴급연락망 등을 수립
 - 침해사고 발생 시 관련 책임자들에게 핫라인 등을 통해 즉각 통지 절차 마련

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 침해사고 관리지침(대응절차, 대응조직 포함) • 침해사고 대응조직 및 비상연락망(외부기관 포함) • 보안관제 용역 계약서 및 SLA(용역 계약을 한 경우에 한함) • 보안 관제 보고서
현장실사(예시)	• 침해사고 및 개인정보 유출사고에 대응하기 위한 체계와 절차 수립 여부 확인 • 대응 조직 및 인력 구성 확인 • 보안관제서비스를 통한 침해사고 대응 체계를 구축 운영하는 경우 침해사고 대응절차의 세부사항을 계약서(SLA 등)에 반영하고 있는지 확인 • 침해사고의 모니터링, 대응 및 처리와 관련된 외부전문가, 전문 업체, 전문기관(KISA) 등 연락 및 보고 절차 수립 여부

■ 미흡 사례

사례 1	• 침해사고에 대비한 침해사고 대응 조직 및 대응 절차를 명확히 정의하고 있지 않은 경우
사례 2	• 외부 보안관제 전문업체 등 유관기관에 침해사고 탐지 및 대응을 위탁하여 운영하고 있으나, 침해 사고 대응에 대한 상호 간 관련 역할 및 책임 범위가 계약서나 SLA에 명확하게 정의되지 않은 경우
사례 3	• 침해사고 신고·통지 및 대응 협조를 위한 대외기관 연락처에 기관명, 홈페이지, 연락처 등이 잘못 명시되어 있거나, 일부 기관 관련 정보가 누락 또는 현행화되지 않은 경우

준비사항

⑥ 침해사고 대응 절차에 관한 연 1회 이상 모의훈련 계획을 수립하고 이에 따라 주기적으로 훈련을 실시하고 있는가?

■ 세부 설명

- 침해사고 발생 시 신속하게 대응을 위한 연 1회 이상의 모의훈련 계획을 수립하고 시행하여야 한다.
 - 침해사고 대응 인력이 모두 포함될 수 있도록 모의훈련 계획 수립
 - 모의훈련 계획은 침해사고 대응과 관련된 담당자의 훈련이 될 수 있도록 문서화하여 책임자의 승인을 받은 후 시행
 - 모의훈련 완료 후 결과보고서를 작성하여 보고
 - 모의훈련 결과 대응체계의 변경이 필요한 경우 반영
 - 다양한 모의훈련 시나리오를 수립하여 상황별 신속 대응 능력 향상
- ※ 중계 관련 시스템이 운영되기 이전에는 침해사고 대응 모의훈련은 훈련 계획서로 대체

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 모의훈련 계획서(책임자의 승인 포함) • 모의훈련 결과보고서 • 모의훈련 개선 사항 도출 및 침해사고 대응체계 반영 내역
현장실사(예시)	• 침해사고 유형 및 중요도 분류에 따라 다양한 모의훈련 시나리오를 계획 수립 여부 확인 • 모의훈련 수행에 따른 결과보고서 작성 내역 확인 • 모의훈련 결과에 따라 도출된 개선 사항을 침해사고 대응체계에 반영한 내역 확인

■ 미흡 사례

사례 1	• 침해사고 모의훈련을 수행하지 않았거나 관련 계획서 및 결과보고서가 확인되지 않은 경우
사례 2	• 연간 침해사고 모의훈련 계획을 수립하였으나 타당한 사유 또는 승인 없이 해당 기간 내에 실시하지 않은 경우

4.1.2 개인정보 전송 이력의 기록·보관 및 점검 방안

세부 지정요건 및 주요 확인사항	
주요내용	개인정보 전송 내역을 3년간 안전하게 보관되도록 하여야하고 전송 내역에 대해서는 주기적으로 점검하여야 한다.
주요 준비사항	① 개인정보 전송 내역을 안전하게 보관하고 있는가? ② 개인정보 전송 내역을 주기적으로 점검하고 있는가?
관련 규정	개인정보보호법 시행령 제42조의6(개인정보 전송의 기한 및 방법 등) 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보 전송 내역을 안전하게 보관하고 있는가?

■ 세부 설명

- 다음 항목의 개인정보 전송 내역을 3년간 보관하여야 한다.

– 정보주체가 전송요구 시 특정하는 사항

- 전송 요구 목적
- 전송 요구를 받는 자
- 개인정보를 전송받는 자
- 전송을 요구하는 개인정보
- 정기적 전송을 요구하는지 여부 및 요구하는 경우 그 주기(영 제42조의5 제4항에 따라 정보 전송자에게 영 제42조의9제1항제2호에 따른 일반전문기관 및 같은 항 제3호에 따른 특수 전문기관에 대한 제3자 전송요구를 하는 경우에 한정한다)
- 전송 요구의 종료시점
- 전송을 요구하는 개인정보의 보유 및 이용기간

– 정보주체의 전송 요구에 따른 정보 송·수신 기록

– 전송 요구의 철회, 거절 및 전송 중단 내역 및 사유

※ 중계업무를 위해 전송을 받기 전에는 전송 내역은 없으므로 전송 내역을 기록할 수 있는 기능 및 3년간 보관할 수 있는 저장 공간을 확인하는 것으로 대체

- 개인정보 전송 내역이 위·변조 및 도난, 분실되지 않도록 다음 방법 중 어느 하나를 고려하여 안전하게 보관하여야 한다.

– 정기적으로 개인정보 전송 내역 백업 수행 및 별도의 저장장치에 보관

– CD-ROM, WORM(Write Once Read Many) 등 덮어쓰기 방지 매체 사용

– 개인정보 전송 내역을 수정 가능한 매체(하드디스크, 자기 테이프 등)에 백업하는 경우에는 무결성 보장을 위해 위·변조 여부를 확인할 수 있는 정보(MAC값, 전자서명값 등)를 별도의 장비에 보관·관리 등

- 개인정보 전송 내역에 대한 접근권한 부여는 최소화하여 비인가자에 의한 위·변조 및 삭제 등이 발생하지 않도록 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 전송 요구서 • 개인정보 전송 내역 • 개인정보 전송 내역 저장장치에 대한 접근통제 내역
현장실사(예시)	• 개인정보 전송 내역 포함 항목의 누락 여부 확인 • 개인정보 전송 내역 보관 기간 및 저장 공간 확보 여부 확인 • 개인정보 전송 내역 보관 장소의 접근통제 확인

■ 미흡 사례

사례 1	• 개인정보 전송 내역을 DBMS에 테이블로 저장하고 있으나, 접근 계정을 통제하지 않아 업무와 관련없는 비인가자도 접근이 가능한 경우
------	---

준비사항

② 개인정보 전송 내역을 주기적으로 점검하고 있는가?

■ 세부 설명

- 개인정보 전송 내역의 위·변조, 유·노출, 오류 등에 대응하기 위하여 점검 계획을 수립하고, 그 계획에 따라 주기적(월 1회 이상)으로 점검하여야 한다.
 - 점검계획에는 점검 방법, 점검 기준, 점검 주기/시점, 담당자, 이상 발견 시 대응 절차, 보고 절차 등 포함
 - ※ 중계 관련 시스템이 운영되기 이전에는 개인정보 전송 내역 점검 계획서로 대체
- 개인정보 전송 내역 점검 결과는 책임자에게 보고하고 이상징후 발견 시 절차에 따라 대응하여야 한다.
 - 개인정보 전송 내역 점검 결과 및 이상징후 발견 여부 등 그 결과를 책임자에게 보고
 - 이상징후 발견 시 개인정보 전송 내역 오류 등 발생 여부를 확인하기 위한 절차를 수립하고 절차에 따라 대응

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보 전송 내역 점검 절차 및 결과 • 개인정보 전송 내역 점검 계획서(중계 관련 시스템 운영 전일 경우)
현장실사(예시)	• 개인정보 전송 내역 점검 결과의 적절성 확인 • 개인정보 전송 내역 점검 계획서 적절성 확인

■ 미흡 사례

사례 1	• 개인정보 전송 내역 점검 계획이 수립되어 있지 않고, 주기적인 점검결과 증적자료가 없는 경우
------	---

4.2. 접근권한의 관리

4.2.1 중계 관련 시스템의 주요정보를 안전하게 처리하기 위한 접근권한의 관리 및 점검 체계

세부 지정요건 및 주요 확인사항	
주요내용	개인정보취급자 및 관리자의 접근권한을 관리하고 주기적으로 점검하여 안전하게 처리되도록 하여야 한다.
주요 준비사항	① 개인정보취급자의 업무상 필요한 최소한의 권한만을 부여하고 있는가? ② 개인정보취급자의 계정을 부여·변경·말소 시 책임자 승인절차를 수립하고 있는가? ③ 개인정보취급자별로 계정을 발급하고 다른 개인정보취급자와 공유하지 않도록 하고 있는가? ④ 관리자 권한 및 특수권한을 식별하여 최소한의 인원에게 부여하고 있는가? ⑤ 시스템에 대한 접근권한 부여·변경·말소에 대한 내역을 기록하고 보관하고 있는가? ⑥ 시스템에 대한 접근권한 검토기준, 검토주체, 검토방법, 주기 등을 정하여 정기적 검토를 이행하고 있는가? ⑦ 개인정보취급자의 인증수단을 안전하게 적용하고 관리하고 있는가? ⑧ 정당한 권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 시스템에 대한접근을 제한하는 등 필요한 조치를 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 개인정보취급자의 업무상 필요한 최소한의 권한만을 부여하고 있는가?

■ 세부 설명

- 중계 관련 시스템에 개인정보취급자(수탁자 포함)의 계정 생성 및 변경 시 수립된 접근권한 분류체계에 따라 최소한의 권한만 부여하여야 한다.
 - 정보시스템에 대하여 중요 디렉토리 및 파일을 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여
 - 데이터베이스에 대하여 중요 객체를 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여
 - 응용프로그램에 대하여 주요 메뉴 및 기능을 식별하고 개인정보취급자의 계정 생성 및 변경 시 직무별, 역할별 최소 접근권한을 부여

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자(수탁자 포함) 목록 • 정보시스템 계정 및 권한 관리 대장 또는 화면 • 데이터베이스 계정 및 권한 관리 대장 또는 화면 • 응용프로그램 계정 및 권한 관리 대장 또는 화면
현장실사(예시)	• 개인정보취급자 계정에 대한 정보시스템 접근권한 부여 현황 확인 • 개인정보취급자 계정에 대한 데이터베이스 접근권한 부여 현황 확인 • 개인정보취급자 계정에 대한 응용프로그램 접근권한 부여 현황 확인

■ 미흡 사례

사례 1	• 수탁사 직원인 개인정보취급자에게 정보시스템에 접근권한을 과도하게 부여하여 백업 디렉토리 또는 중요 설정/로그/key 파일에 접근 가능한 경우
사례 2	• 개발자인 개인정보취급자에게 데이터베이스 접근권한을 과도하게 부여하여 중요 테이블의 삭제 및 변경 권한이 부여된 경우
사례 3	• 상담 직원에게 응용프로그램 접근권한이 과도하게 부여되어 계정 생성/변경/삭제 메뉴에 접근 가능한 경우

준비사항

② 개인정보취급자의 계정을 부여·변경·말소 시 책임자 승인절차를 수립하고 있는가?

■ 세부 설명

- 중계 관련 시스템과 개인정보 및 중요정보에 대한 비인가 접근을 통제하기 위하여 다음 사항을 고려하여 공식적인 개인정보취급자 계정 및 접근권한 등록·변경·말소 절차를 수립하여야 한다.
 - 개인정보취급자에 대한 계정 발급 및 접근권한 부여·변경 시 책임자의 승인 절차 등을 통한 적절성 검토
 - 전보, 퇴직 등 인사이동 및 업무가 변경되었을 경우 지체 없이 접근권한 변경 또는 말소 (계정 삭제 또는 비활성화 포함)
 - 사용자 계정 및 접근권한의 등록·변경·삭제·해지 관련 기록의 유지·관리 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 계정 및 권한관리 절차서 • 사용자 계정 및 권한 신청서
현장실사(예시)	• 계정 및 권한관리 절차서 작성 여부 확인 • 계정 및 권한관리 절차서를 위반한 개인정보취급자 계정 유무 확인

■ 미흡 사례

사례 1	• 개인정보취급자에 대한 계정·권한에 대한 사용자 등록, 해지 및 승인절차 없이 구두 요청, 이메일 등으로 처리하여 이에 대한 승인 및 처리 이력이 확인되지 않는 경우
------	---

준비사항

③ 개인정보취급자별로 계정을 발급하고 다른 개인정보취급자와 공유하지 않도록 하고 있는가?

■ 세부 설명

- 중계 관련 시스템에 대한 계정 발급은 개인정보취급자별로 유일하게 구분할 수 있는 식별자를 할당하여야 한다.
 - 개인정보취급자별로 고유한 사용자 계정 발급을 원칙으로 하여 사용자에게 대한 책임추적성 확보
 - 계정 공유 금지 및 공용 계정 사용 제한
- 업무상 불가피하게 동일한 식별자를 공유하여 사용하는 경우 그 사유와 타당성을 검토하고 전문기관 관리책임자의 승인을 받도록 하고 계정 관리 대장, 접근제어 시스템 도입 등 관리적 또는 기술적 보완 통제를 통해 접속한 자를 식별할 수 있도록 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자(수탁자 포함) 목록 • 중계 관련 시스템 개인정보취급자 계정 목록
현장실사(예시)	• 개인정보취급자 목록과 중계 관련 시스템에 등록된 계정 대조 확인

■ 미흡 사례

사례 1	• 개발자가 중계 관련 시스템 계정을 공용으로 사용하고 있으나, 타당성 검토 또는 책임자의 승인 등이 없이 사용하고 있는 경우
사례 2	• 수탁사 직원이 중계전문기관 직원과 동일 계정을 공유하여 사용하고 있는 경우

준비사항

④ 관리자 권한 및 특수 권한을 식별하여 최소한의 인원에게 부여하고 있는가?

■ 세부 설명

- 관리자 및 특수 권한은 최소한의 인원에게만 부여하여야 한다.
 - 관리자 및 특수 권한은 공식적인 신청 절차를 통해 관리책임자의 승인 절차에 따라 부여
 - 특히, 서버 운영자, DB 운영자, 응용프로그램 관리자, 정보보호시스템 운영자 등에 대한 계정은 최소 인원으로 부여
 - 관리자 및 특수 권한은 최소한의 업무 수행자에게만 부여할 수 있도록 일반 사용자 계정, 권한 발급 절차 보다 엄격한 기준 적용

※ 특수목적을 위한 계정 및 권한을 가지는 특수 권한 예시는 아래와 같음

- 관리자 권한(Root, Administrator, admin, sys, system, sa 등 최상위 권한)
- 배치프로그램 실행을 위하여 부여된 권한
- 정보보호 시스템 관리자 권한
- 계정 생성 및 접근권한을 설정할 수 있는 권한 등

- 특수 목적을 위하여 부여한 계정 및 권한을 식별하고 별도의 목록으로 관리하는 등 통제절차를 수립·이행 하여야 한다.
 - 관리자 및 특수 권한 목록 작성 관리
 - 관리자 및 특수 권한 모니터링 강화 등의 통제절차 수립·이행
 - 정보시스템 유지보수 등 외부자에게 부여하는 관리자 및 특수 권한은 필요시에만 생성, 업무 종료 후에는 즉시 삭제 또는 정지하는 절차를 적용
 - 관리자 및 특수 권한 계정 현황을 정기적으로 검토하여 목록 현행화

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 관리자 및 특수 권한 신청·승인 내역 • 관리자 및 특수 권한 계정 목록
현장실사(예시)	• 관리자 및 특수 권한 신청 내역과 등록된 계정 대조 확인 • 관리자 및 특수 권한 계정 목록 작성 여부 및 주기적인 현행화 여부 확인

■ 미흡 사례

사례 1	• 관리자 및 특수 권한이 명확히 정의되지 않아, 일부 계정에 특수 권한(계정 생성, 개인정보 파기 권한 등)이 부여된 경우
사례 2	• 시스템에 등록된 관리자 계정 중 일부의 계정의 발급 신청서를 찾을 수 없는 경우
사례 3	• 퇴직하거나 전보된 관리자의 계정이 존재하는 경우
사례 4	• 유지보수 업체 직원이 분기 1회 방문하고 있지만, 유지보수를 위한 유지보수용 관리자 계정이 상시 활성화되어 있음

준비사항

⑤ 시스템에 대한 접근권한 부여·변경·말소에 대한 내역을 기록하고 보관하고 있는가?

■ 세부 설명

- 중계 관련 시스템에 대한 접근권한을 부여, 변경 또는 말소한 내역은 책임추적성을 확보할 수 있도록 관련 사항이 모두 포함되어 기록되어야 한다.
 - 대상자 정보(식별자 등)
 - 접근권한 부여자 정보(담당자, 승인자 등)
 - 접근권한 정보(일시, 권한명, 사유 등)
 - 기타 접근권한 검토를 위해 필요한 정보(특이사항 등)
- 접근권한 내역은 최소 3년간 보관하여야 한다.
 - ※ 중계 관련 시스템 운영되기 전일 경우는 3년간 보관할 수 있도록 구현한 기능으로 대체
 - ※ 중계 관련 시스템 운영이 3년이 경과되지 않은 경우는 현재까지 기록된 접근권한 내역 확인
- 접근권한 내역은 위·변조 또는 도난, 분실되지 않도록 안전하게 보관하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 시스템 접근권한 부여·변경·말소 내역
현장실사(예시)	• 접근권한 내역 내 항목의 적정성 확인 • 접근권한 내역 보관 확인

■ 미흡 사례

사례 1	• 중계 관련 시스템의 접근권한 내역은 로그 테이블에 저장되어 보관되고 있으나, 일부 항목이 누락되어 있어 누가 승인 하였는지 등의 정보를 파악하기 어려운 경우
사례 2	• 중계 관련 시스템을 운영한지 3년이 경과하였으나, 접근권한 내역은 2년만 보관하고 있는 경우

준비사항

⑥ 시스템에 대한 접근권한 검토기준, 검토주체, 검토방법, 주기 등을 정하여 정기적 검토를 이행하고 있는가?

■ 세부 설명

- 접근권한의 적정성을 상세히 검토할 수 있도록 접근권한 기록 검토방안을 마련하여야 한다.
 - 접근권한 검토 주체, 방법, 기준, 주기, 결과보고 등 검토 절차 수립
 - 접근권한이 적절한지 아래와 같은 사항에 대하여 주기적으로 검토를 수행하여야 한다.
 - 직원의 인사변경(퇴직, 휴직, 전보 등) 등 반영 여부
 - 장기간 미사용 계정의 존재 여부
 - 외부자(수탁사, 유지보수 업체 등)에게 할당된 계정의 관리 상태
 - 계정 및 권한 할당 시 승인 등의 절차 준수 여부
 - 직무의 변경 등이 발생한 경우 계정 또는 접근권한의 회수 및 재할당
 - 계정 등록대장과 실 시스템 계정 일치 여부
 - 직무 변경 등에 따른 접근권한 승인 내역
 - 임시 계정 권한 회수 여부
- ※ 중계 관련 시스템 운영되기 전일 경우 접근권한 점검은 계획서로 대체
- 접근권한 검토 과정에서 접근권한 과다 부여, 권한부여 절차 미준수, 권한 오·남용 등 문제점이 발견된 경우 그에 따른 조치절차를 수립·이행하여야 한다.
 - 접근권한 검토 결과 권한의 과다 부여, 절차 미준수, 권한 오·남용 등 의심스러운 상황이 발견된 경우 소명요청 및 원인분석, 보완대책 마련, 보고체계 등이 포함된 절차 수립·이행
 - 접근권한 검토 후 변경 적용된 권한에 대해서는 사용자 및 관련자에게 통지
 - 유사한 문제가 반복될 경우 근본 원인 분석 및 재발방지 대책 수립

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 접근권한 검토 기준 및 절차 • 접근권한 검토 이력 • 접근권한 검토 결과보고서 및 후속조치 내역
현장실사(예시)	• 접근권한 검토 기준 및 절차 수립 여부 및 적정성 확인 • 접근권한 검토 결과 및 후속조치의 적정성 확인

■ 미흡 사례

사례 1	• 접근권한 검토와 관련된 방법, 점검주기, 보고체계, 오·남용 기준 등이 관련 지침에 구체적으로 정의되어 있지 않아 접근권한 검토가 정기적으로 수행되지 않은 경우
사례 2	• 접근권한 검토 시 접근권한의 과다 부여 및 오·남용 의심사례가 발견되었으나, 이에 대한 상세조사, 내부보고 등의 후속조치가 수행되지 않은 경우
사례 3	• 내부 관리계획에 접근권한 검토 기준에 대하여 90일 이상 접근하지 않은 계정에 대해서는 계정 잠금 설정해야 한다고 명시되어 있으나, 시스템 미접속 90일 초과 미사용 계정이 활성화되어 있는 경우

준비사항

⑦ 개인정보취급자의 인증수단을 안전하게 적용하고 관리하고 있는가?

■ 세부 설명

- 정당한 권한을 가진 개인정보취급자를 인증하기 위하여 개인정보 처리환경, 침해위험, 정보주체에 미치는 영향 등을 고려하여 인증수단을 안전하게 적용하고 관리하여야 한다.
- 인증 수단 예시

인증수단 유형	인증수단 예
지식 기반	비밀번호 등
소유 기반	인증서(PKI), OTP, 스마트 카드, 보안 토큰 등
생체 기반	지문, 홍채, 안면 등

- 비밀번호를 인증수단으로 적용하는 경우, 개인정보취급자가 안전한 비밀번호를 설정하여 이행할 수 있도록 비밀번호 작성규칙을 수립하고 이를 중계 관련 시스템, 정보보호시스템 등에 적용하여야 한다.
- 비밀번호 이외의 인증수단을 적용하는 경우, 해당 인증수단의 발급, 배포, 설정, 보관, 변경, 폐기 등의 과정에서 유·노출 되거나 도용되지 않도록 안전한 관리 방안 및 절차를 수립·적용하여야 한다.
- 관리자 및 특수 권한 계정 인증, 중요 정보/기능 접근 시 인증 등의 경우 안전한 인증수단(예, 다중요소 인증(MFA, Multi-Factor Authentication))을 적용하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자 로그인 화면 • 비밀번호 작성 규칙 • 인증서(PKI) 관리 절차 • 정보서비스 흐름도
현장실사(예시)	• 복잡도, 변경 주기 등 비밀번호 작성 규칙의 적정성 확인 • 비밀번호 외 인증수단 관리 현황 확인 • 관리자 및 특수 권한 계정 인증, 중요 정보/기능 접근 인증 시 적용된 인증수단의 적정성 확인

■ 미흡 사례

사례 1	• 비밀번호 관련 내부 규정에는 비밀번호를 초기화 시 임시 비밀번호를 부여받고 강제적으로 변경하도록 되어 있으나, 실제로는 임시 비밀번호를 그대로 사용하고 있는 경우
사례 2	• PEM key, 인증서(PKI) 기반 인증수단을 사용하고 있으나, 사용기간 제한 없이 다수의 개인정보 취급자가 공유하여 사용하고 있는 경우
사례 3	• 대량의 개인정보 또는 중요한 개인정보를 처리하는 개인정보취급자 및 관리자가 비밀번호 인증만 적용하고 있는 경우

준비사항

- ⑧ 정당한 권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 시스템에 대한 접근을 제한하는 등 필요한 조치를 하고 있는가?

■ 세부 설명

- 정당한 권한을 가진 개인정보취급자만이 시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 시스템에 대한 접근을 제한하는 등 필요한 조치를 취하여야 한다.
 - 로그인 화면에서 연속적으로 일정 횟수(예를 들어, 5회) 이상 인증 실패 시 시스템 접속을 차단
 - 시스템 관리자는 개인정보취급자 확인 후 접속 차단 해제하거나, 강화된 인증수단(예, 소유 또는 생체 기반)을 적용 후 접속 차단 해제

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 개인정보취급자 연속 인증 실패 시 잠금 기능 • 시스템 접속 차단 해제 절차
현장실사(예시)	• 인증 실패 시 접근을 제한하는 정책 수립 여부 확인 • 인증 실패 시 시연 후 접근 제한 여부 확인 • 시스템 접속 차단 해제 절차의 적정성 확인

■ 미흡 사례

사례 1	• 개인정보취급자 로그인 화면에 “비밀번호 3회 입력 오류 시 로그인 접속이 제한됩니다”라는 메시지는 기재되어 있으나, 실질적으로 차단되도록 구현되어 있지 않은 경우
------	--

4.3. 접근통제

4.3.1 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 중계 관련 시스템, 업무용 단말 등에 대한 접근통제 체계

4.3.1.1 중계 관련 시스템에 대한 접속 권한의 제한 등 접근통제 조치

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 중계 관련 시스템 및 업무용 컴퓨터에 대한 IP통제, 방화벽, 유해사이트 차단 등 접근통제와 관련된 보호조치를 하여야 한다.
주요 준비사항	① 접근통제 정책에 따라 인가된 사용자만이 내부 네트워크에 접근할 수 있도록 인터넷 프로토콜(IP) 주소 등을 통제하고 있는가? ② 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있도록 정보보호 시스템을 구축하여 운영하고 있는가? ③ 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 전송요구 처리 정보가 공개되거나 유출되지 않도록 시스템, 컴퓨터 및 모바일 기기 등에 조치하고 있는가? ④ 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 접근통제 정책에 따라 인가된 사용자만이 내부 네트워크에 접근할 수 있도록 인터넷 프로토콜(IP) 주소 등을 통제하고 있는가?

■ 세부 설명

- 네트워크 대역별 IP주소 부여 기준을 마련하고 데이터베이스, 서버 등 중요 시스템을 사설 IP로 할당하여 외부에서 직접 접근이 불가능하도록 방화벽 등을 활용하여 설정하여야 한다.
 - IP주소 할당 현황을 최신으로 유지하고 IP주소 관리대장은 안전하게 관리
 - 내부망의 주소 체계는 사설 IP주소 체계를 사용하고 외부에 내부 주소체계가 노출되지 않도록 NAT(Network Address Translation) 기능 적용
 - 인가된 사용자만 네트워크에 접근할 수 있도록 IP 통제
 - 네트워크 장치에 불필요한 서비스 및 포트 등 제거 또는 차단
- 물리적으로 떨어진 IDC, 지사 등과의 네트워크 연결 시 전용회선 또는 VPN(가상사설망) 등을 활용하여 안전한 접속환경을 구성하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성 • IP 관리 대장 • 정보자산 목록
현장실사(예시)	• 중요 정보시스템 내 불필요 서비스 운영 여부 확인 • 네트워크 구성에 따른 IP 관리 현황

■ 미흡 사례

사례 1	• IP관리대장 및 정보자산목록을 주기적으로 점검하여 현행화하지 않아 실제 구축된 시스템의 IP 내용과 일치하지 않은 경우
------	--

준비사항

② 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있도록 정보보호시스템을 구축하여 운영하고 있는가?

■ 세부 설명

- 정보통신망을 통한 정보 유출 시도 탐지 및 대응할 수 있는 정보보호시스템을 설치하여 운영하여야 한다.
- 중계 관련 시스템의 중요 정보를 보호하기 위한 정보보호시스템에 대하여 다음 내용을 포함한 운영절차를 수립·이행하여야 한다.
 - 정보보호시스템 정책(룰셋 등) 적용 절차
 - 정보보호시스템별 책임자 및 관리자 지정
 - 최신 정책 업데이트 방안
 - ※ IPS, 웹방화벽 등의 정보보호시스템의 경우, 새로운 공격기법을 탐지하기 위한 최신 패턴(시그니처) 및 엔진의 지속적 업데이트 수행
 - 정보보호시스템 이벤트 모니터링 절차(정책에 위배되는 이상징후 탐지 및 확인 등)
 - 정보보호시스템 접근통제 정책
 - 정보보호시스템 운영현황의 주기적 점검 등
 - ※ 정보보호시스템 유형은 다음과 같음

- 네트워크 정보보호시스템 : 침입차단시스템(방화벽), 침입방지시스템(IPS), 침입탐지시스템(IDS), 네트워크 접근제어(NAC), DDoS대응시스템, 가상사설망(VPN) 등
- 서버 정보보호시스템 : 서버 접근제어, 보안운영체제(Secure OS)
- DB 정보보호시스템 : DB 접근제어
- 정보유출방지시스템 : N-DLP(Network Data Loss Prevention), E-DLP(Endpoint Data Loss Prevention) 등
- 기타 : APT 대응 솔루션, 웹방화벽 등

- 정보보호시스템 관리자 등 접근이 허용된 인원을 최소화하고 비인가자의 접근을 엄격하게 통제하여야 한다.
- 정보보호시스템 정책의 신규 등록, 변경, 삭제 등을 위한 공식적인 절차를 수립·이행하여야 한다.
- 정보보호시스템에 설정된 정책의 타당성 여부에 대하여 주기적으로 검토하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 정보보호시스템별 관리 화면(IDS, IPS, 웹방화벽 등) • 침입탐지 엔진 및 패턴 업데이트 이력
현장실사(예시)	• IDS, IPS의 엔진 및 침입탐지 패턴 최신화 여부 확인 • 정보 유출시도 대응 체계의 적정성 확인

■ 미흡 사례

사례 1	• 정보 유출을 탐지 및 차단하고 있는 IPS를 확인한 결과, 탐지 엔진 및 탐지 패턴이 주기적으로 업데이트 되지 않아 최근 발생한 유출 시도가 탐지되지 않고 있는 경우
------	--

준비사항

- ③ 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 전송요구 처리 정보가 공개되거나 유출되지 않도록 시스템, 컴퓨터 및 모바일 기기 등에 조치하고 있는가?

■ 세부 설명

- 전송요구 처리 정보가 인터넷 홈페이지, P2P, 공유설정, 공개된 무선망 이용 등을 통하여 열람 권한이 없는 자에게 공개되거나 유출되지 않도록 시스템, 개인정보취급자 컴퓨터, 모바일기기 등에 조치를 하여야 한다.

- 전송요구 처리 정보가 인터넷 홈페이지를 통해 열람권한이 없는 자에게 공개되거나 유출되지 않도록 다음과 같은 항목 등을 고려하여 조치

※ 인터넷 홈페이지를 통한 정보 유·노출 방지 대책에 관한 내용은 아래와 같음

- 잘 알려진 웹 취약점 항목들을 포함한 웹 취약점 점검 및 조치
- 인터넷 홈페이지 중 서비스 제공에 사용되지 않거나 관리되지 않는 사이트 또는 URL에 대한 삭제 또는 차단 조치
- 인터넷 홈페이지 관리자 페이지에 대한 노출 차단 등의 보호조치
- 웹 방화벽 설치·운영을 통하여 웹 해킹을 통한 개인정보 유·노출 탐지 및 차단
- 개인정보 필터링 솔루션을 통하여 게시판, 첨부파일 등을 통해 노출된 개인정보 탐지 및 변환
- 웹 취약점 점검과 함께 정기적으로 웹 쉘 등을 점검하고 조치하는 경우 취급중인 개인정보가 인터넷 홈페이지를 통해 열람권한이 없는 자에게 공개되거나 유출되는 위험성을 더욱 줄일 수 있음
- 시스템에서 인터넷으로의 아웃바운드 접속 차단(필요 시 해당 IP, Port만 허용) 등

- 전송요구 처리 정보가 개인정보취급자의 업무용 컴퓨터, 모바일 기기 등을 통해 열람권한이 없는 자에게 공개되거나 유출되지 않도록 다음과 같은 항목 등을 고려하여 조치

※ 개인정보취급자의 컴퓨터 또는 모바일기기를 통한 정보 유·노출 방지대책에 관한 내용은 아래와 같음

- N-DLP(Network Data Loss Prevention), 비업무사이트 차단시스템 등 보안시스템을 도입하여 개인정보의 외부전송 모니터링 및 P2P, 웹하드 등 개인정보 유·노출 위험성이 높은 사이트 차단 조치
- PC보안, E-DLP(Endpoint Data Loss Prevention) 등 업무용 컴퓨터에 보안프로그램을 설치하여 공유폴더 설정 차단, 메신저, P2P 및 웹하드 프로그램 실행차단, 매체 제어 등 조치
- 개인정보 송·수신 시 SSL, VPN 등 보안기술이 적용된 전용 프로그램을 사용하여 송·수신 또는 암호화 송·수신
- 개인정보취급자 컴퓨터, 모바일 기기에서 개인정보가 포함된 파일 송·수신 시 암호화 저장 후 송·수신

- 시스템, 개인정보취급자 컴퓨터, 모바일 기기 등에 P2P, 공유설정은 기본적으로 사용하지 않는 것이 원칙이나, 업무상 반드시 필요한 경우에는 권한 설정 등의 조치를 통해 권한이 있는 자만 접근할 수 있도록 설정하여 개인정보가 열람권한이 없는 자에게 공개되거나 유출되지 않도록 접근 통제 등에 관한 안전조치 적용

※ P2P, 공유설정을 통한 정보 유·노출 방지대책에 관한 내용은 아래와 같음

- 업무상 꼭 필요한 경우라도 드라이브 전체 또는 불필요한 폴더가 공유되지 않도록 조치하고, 공유폴더에 개인정보 파일이 포함되지 않도록 정기적으로 점검
- 상용 웹메일, 웹하드, 메신저, SNS 서비스 등을 통하여 고의 혹은 부주의로 인한 정보 유·노출 방지 조치 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 정보보호시스템 목록 • 인터넷 홈페이지, P2P 차단 등 보호조치 현황 • 시스템 및 컴퓨터 대상 공유설정 차단 등 보호조치 현황 • 보안점검 결과(인터넷 홈페이지, 개인정보취급자 컴퓨터, 모바일 기기)
현장실사(예시)	• 인터넷 홈페이지, P2P, 공유설정 차단 등 보호조치 현황 실사 • 시스템, 개인정보취급자의 컴퓨터 및 모바일 등의 보안점검 여부 확인

■ 미흡 사례

사례 1	• 개인정보취급자 컴퓨터의 공유폴더 사용을 금지하고 있으나, 이에 대한 주기적인 점검이 이루어지고 있지 않아 다수의 개인정보취급자 컴퓨터에서 과도하게 공유폴더를 설정하여 사용하고 있는 경우
------	---

준비사항

- ④ 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하고 있는가?

■ 세부 설명

- 시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무 처리를 하지 않은 경우 자동으로 접속이 차단되도록 하여야 한다.
 - 접속차단 조치는 시스템과 개인정보취급자의 컴퓨터 등의 연결이 완전히 차단되어 정보의 송·수신이 불가능한 상태가 되어야 하며, 접속차단 조치 이후에 다시 접속하고자 할 때에는 최초의 로그인 방법과 동일한 방법으로 접속하도록 조치
 - ※ 시스템은 응용프로그램, 서버, DBMS를 모두 포함
 - 접속차단을 적용하기 위한 시간 기준은 개인정보를 처리하는 방법 및 환경, 보안위험 요인, 업무특성 (DB 운영 관리, 시스템 모니터링, 유지보수 등)을 고려하여 필요 최소한의 시간으로 설정

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 서버/DBMS/응용프로그램 세션 타임 허용 여부 내역
현장실사(예시)	• 사용자 및 정보주체가 일정시간 이상 업무처리를 하지 않은 경우 시스템에 대한 접속이 차단되도록 기능 설계 및 구현 여부 확인 • 재접속 시도 시 최초의 로그인과 동일한 방법으로 접속 여부 확인

■ 미흡 사례

사례 1	• 서버 운영체제 설정을 확인 결과 세션 타임아웃 설정이 되어있지 않은 경우
------	--

4.3.1.2 중계 관련 시스템에 대한 외부 접속 시 안전한 인증수단 등의 적용

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통해 외부에서 전송 요구 관련 시스템에 접속하려는 경우 안전한 인증수단 등 접근통제와 관련된 보호조치를 하여야 한다.
주요 준비사항	① 개인정보취급자가 정보통신망을 통해 외부에서 시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 개인정보취급자가 정보통신망을 통해 외부에서 시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하고 있는가?

■ 세부 설명

- 인터넷구간 등 외부로부터 시스템에 대한 접속은 원칙적으로 차단하여야 하나, 업무 특성 또는 필요에 의해 개인정보취급자가 노트북, 업무용 컴퓨터, 모바일 기기 등으로 외부에서 정보통신망을 통해 시스템에 접속이 필요한 경우에는 안전한 인증수단을 적용하여야 한다.
 - 안전한 인증 수단 : 인증서(PKI), 보안토큰, 일회용 비밀번호(OTP), 생체인증 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성도 • 인증수단 화면
현장실사(예시)	• 개인정보취급자가 정보통신망을 통해 외부에서 시스템에 접속 시 안전한 인증수단 적용 여부 확인

■ 미흡 사례

사례 1	• 원격운영관리를 위하여 VPN을 구축하여 운영하고 있으나, VPN 접속 시 비밀번호 인증만 적용된 경우
------	--

4.3.2 유출 및 해킹을 신속하게 탐지·대응할 수 있는 모니터링 체계

4.3.2.1 유출 및 해킹 탐지 시스템, 네트워크 등에 대한 실시간 모니터링, 이상행위 분석·조사 등 조치

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통해 내·외부에서 의한 침해시도, 개인정보 유출시도, 부정행위 등 유출 및 해킹을 탐지할 수 있도록 모니터링 체계를 갖추어야 한다.
주요 준비사항	① 내·외부에 의한 침해시도, 개인정보유출 시도, 부정행위 등 유출 및 해킹을 탐지할 수 있도록 주요 정보시스템, 응용프로그램, 네트워크, 보안시스템 등에서 발생한 네트워크 트래픽, 데이터 흐름, 이벤트 로그 등 모니터링 체계를 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 내·외부에 의한 침해시도, 개인정보유출 시도, 부정행위 등 유출 및 해킹을 탐지할 수 있도록 주요 정보시스템, 응용프로그램, 네트워크, 보안시스템 등에서 발생한 네트워크 트래픽, 데이터 흐름, 이벤트 로그 등 모니터링 체계를 갖추고 있는가?

■ 세부 설명

- 내·외부에 의한 침해시도, 개인정보 유출 시도, 부정행위 등 유출 및 해킹을 탐지할 수 있도록 전송 요구 관련 정보시스템, 응용프로그램, 네트워크, 보안시스템 등에서 발생한 네트워크 트래픽, 데이터 흐름, 이벤트 로그 등을 수집하여 실시간으로 모니터링 하여야 한다.
 - 외부 침해시도에 대해서는 24시간 실시간 모니터링 수행
 - 보안전문업체를 통해 보안관제서비스를 받는 것도 가능
- ※ 중계 관련 시스템이 운영되기 이전에는 모니터링 체계 구축 계획서로 대체
- 이상행위 판단을 위하여 정보시스템, 보안시스템, 응용프로그램, 네트워크 장비 등의 로그를 수집하고 분석하는 방안에 대하여 다음의 사항을 고려하여 마련하여야 한다.
 - 이벤트 로그를 수집하거나 모니터링 하여야 할 대상 및 범위
 - 이벤트 수집 및 분석, 모니터링 방법
 - 담당자 및 책임자 지정
 - 분석 및 모니터링 결과 보고 체계
 - 이상행위 발견 시 대응 절차 등
- 침해시도, 개인정보 유출 시도, 부정행위 등의 여부를 판단하기 위한 기준 및 임계치를 정의하고, 이에 따라 이상행위의 판단 및 조사 등 후속 조치가 적시에 이루어지도록 하여야 한다.
 - 이상행위 판단을 위한 이상행위 식별기준 및 임계치를 설정하고, 필요시 시스템에 반영
 - 설정된 기준 및 임계치를 주기적으로 검토하여 최적화
 - 뉴스, KISA 보호나라 등을 통하여 사이버 위협(침해사고, 취약점 등) 발생시 이상행위 패턴 등을 갱신
- 모니터링 결과 이상행위가 확인된 경우, 책임자에게 보고하고 긴급 대응, 소명 요청, 원인 조사 등 사후 조치를 수행하여야 한다.
 - 원인 조사 결과에 따라 필요 시 재발방지 방안 마련

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 이상행위 분석 및 모니터링 현황 • 이상행위 식별기준 및 임계치 • 이상행위 발견 시 대응 증적
현장실사(예시)	• 내·외부에 의한 침해시도, 개인정보 유출 시도, 부정행위 등 이상행위를 탐지할 수 있는 모니터링 방안이 마련되어 있는지 확인 • 이상행위 모니터링 방안에 따라 실시간 모니터링이 수행되고 있는지 확인 • 이상행위 판단을 위한 이상행위 식별기준 및 임계치가 적절히 정의되어 있는지 확인 • 모니터링 결과에 대해 책임자에게 보고하고 있는지 확인 • 이상행위 발견 시 사후조치가 내부 절차에 따라 신속이 수행되고 있는지 확인

■ 미흡 사례

사례 1	• 주간 업무시간 중에는 이상행위에 대한 실시간 모니터링이 수행되고 있으나, 야간 및 주말에는 실시간 모니터링이 수행되지 않고 있는 경우
사례 2	• 중계 관련 일부 시스템 및 보안시스템이 이상행위 모니터링 대상에서 누락된 경우
사례 3	• 외부 보안관제 전문업체 등 외부 기관에 침해시도 모니터링 업무를 위탁하고 있으나, 위탁업체가 제공한 관련 보고서를 검토한 이력이 확인되지 않는 경우
사례 4	• 내부적으로 정의한 임계치를 초과하는 이상 트래픽이 지속적으로 발견되고 있으나, 이에 대한 대응조치가 이루어지고 있지 않은 경우

4.3.3 중계 관련 시스템에 접근할 수 있는 관리용 단말기를 지정·관리하고, 중계 관련 시스템에 접속하려는 경우 추가적인 인증수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속 가능하도록 조치

세부 지정요건 및 주요 확인사항	
주요내용	중계 관련 시스템에 접근할 수 있는 관리자는 지정된 관리용 단말기를 통해 접근하도록 통제하고, 추가인증을 적용하여 안전하게 시스템에 접근통제 등 보호조치를 하여야 한다.
주요 준비사항	① 중계 관련 시스템에 접속할 수 있는 관리용 단말기를 지정하고 있는가? ② 추가적인 수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속할 수 있도록 방안을 마련하고 있는가? ③ 관리용 단말기에 악성프로그램 감염방지 등을 위한 보안조치를 적용하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템에 접속할 수 있는 관리용 단말기를 지정하고 있는가?

■ 세부 설명

- 중계 관련 주요 시스템의 관리, 운영, 개발, 보안 등의 목적으로 시스템에 직접 접속하는 단말기를 관리용 단말기로 지정하여야 한다.
 - 중계 관련 주요 시스템의 관리, 운영, 개발, 보안 등의 목적으로 시스템에 직접 접속할 수 있는 업무용 컴퓨터, 노트북 등이 관리용 단말기에 해당
 - “직접 접속”이란 물리적 구조와 상관없이 단말기에서 개인정보처리시스템에 대하여 관리, 운영, 개발, 보안 등의 목적으로 활용할 수 있는 명령어 등을 직접 입력하여 처리할 수 있는 상태를 말함
- 관리용 단말기 지정현황을 목록으로 기록하고, 현행화하여 관리하여야 한다.
 - 단말기명, 단말기 유형, 담당자, 용도, IP주소, 설치 위치 등 현황 관리
- 중계 관련 주요 시스템에 대해 관리용 단말기로 지정된 단말기가 아닌 단말기에서는 직접 접속할 수 없도록 접근을 통제하여야 한다.
 - 관리용 단말기의 IP주소를 등록하여, 그 외 IP주소에서는 접속할 수 없도록 통제하는 방식 등 적용
- 지정된 관리용 단말기는 시스템 관리 등의 목적 외의 다른 목적으로는 사용되지 않도록 조치하여야 한다.
 - 인터넷망 접속 차단조치
 - 비인가자의 접근 및 사용을 방지하기 위한 부팅암호, 로그인 암호, 화면보호기 암호 설정
 - 관리용 단말기를 통한 개인정보 및 중요정보 유출을 방지하기 위한 조치
 - 관리용 단말기 사용 내역에 대한 기록유지
 - 관리용 단말기의 보안상태 및 사용현황에 대한 점검점검 등

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증거자료(예시)	• 관리용 단말기 현황 • 관리용 단말기 보안대책
현장실사(예시)	• 관리용 단말기 지정 기준 및 절차가 마련되어 있는지 확인 • 관리용 단말기 현황이 최신으로 관리되고 있는지 확인 • 개인정보 전송요구 처리 관련 주요 시스템의 접근 통제물을 점검하여 지정된 관리용 단말기 이외의 단말기에서는 접근할 수 없도록 통제하고 있는지 확인 • 시스템 관리 외의 다른 목적으로 관리용 단말기가 사용되지 않도록 통제하고 있는지 확인

■ 미흡 사례

사례 1	• 중계 관련 주요 시스템의 관리, 운영, 개발, 보안 등의 목적으로 시스템에 직접 접속할 수 있는 컴퓨터 중 일부가 관리용 단말기 지정에서 누락된 경우
사례 2	• 관리용 단말기 목록을 대장으로 기록하여 관리하고 있으나, 현행화가 미흡하여 실제 현황과 상이한 경우

준비사항

② 추가적인 수단 등 안전한 인증수단을 적용하여 정당한 권한을 가진 자만 접속할 수 있도록 방안을 마련하고 있는가?

■ 세부 설명

- 정당한 권한을 가진 자만이 중계 관련 시스템에 접속할 수 있도록 비밀번호 외에 추가인증 수단을 적용하여야 한다.
 - 추가인증 적용 대상 : 서버 및 DB 관리자·운영자, 응용프로그램 관리자, 접근 권한을 설정할 수 있는 자, 대량의 개인정보를 다운로드 받을 수 있는 자, 전송요구서 및 주민등록번호 등 중요한 정보를 취급하는 자 등
 - 추가인증 수단에는 일회용 비밀번호(OTP), 인증서, 보안토큰, 생체인증 등이 있음
- 추가인증 수단의 안전한 등록, 사용, 변경, 폐기에 관한 절차를 수립·이행하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 추가인증 적용 방안 • 추가인증 적용 현황
현장실사(예시)	• 중계 관련 시스템에 접속시 추가인증 수단이 적용되었는지 확인 • 추가인증 수단의 등록, 사용, 변경, 폐기 절차가 적절하게 마련되어 있는지 확인

■ 미흡 사례

사례 1	• 중계 관련 시스템에 대해 서버 및 DB로 접속할 경우에는 서버접근제어 및 DB접근제어 시스템을 통해 추가인증 수단을 적용했으나, 응용프로그램의 관리자로 접근할 때에는 추가인증이 적용되어 있지 않은 경우
------	--

준비사항

③ 관리용 단말기에 악성프로그램 감염방지 등을 위한 보안조치를 적용하고 있는가?

■ 세부 설명

- 관리용 단말기에 악성프로그램 감염방지 등을 위한 보안조치를 적용하여야 한다.
 - 악성코드 감염 방지를 위한 보안 프로그램의 최신상태 유지, 보안 업데이트 적용, 악성프로그램 삭제 등 대응 조치
 - 보조저장매체를 통한 악성코드 감염을 방지하기 위한 보조저장매체 통제 등

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증거자료(예시)	• 관리용 단말기 현황 • 관리용 단말기 악성프로그램 방지대책
현장실사(예시)	• 관리용 단말기에 대한 악성프로그램 방지대책이 적절히 수립되어 있는지 확인 • 관리용 단말기에 대한 보안프로그램 설치 및 최신 업데이트 여부, 운영체제 및 소프트웨어에 대한 보안 업데이트가 최신으로 적용되어 있는지 확인

■ 미흡 사례

사례 1	• 인터넷망 차단조치에 따라 관리용 단말기 운영체제에 대한 보안업데이트가 장기간 수행되고 있지 않은 경우
------	--

4.3.4 중계 관련 시스템에 접근할 수 있는 관리용 단말기에 대한 인터넷망 차단 조치

세부 지정요건 및 주요 확인사항	
주요내용	중계 관련 시스템에 접속하는 관리용 단말기에 대해서는 인터넷이 되지 않도록 인터넷망을 차단하여 보호조치를 하여야 한다.
주요 준비사항	① 중계 관련 시스템에 접속하는 관리용 단말기에 대한 인터넷망 차단 조치를 하고 있는가? ② 외부 인터넷망에서 중계 관련 시스템에 원격접속을 통제하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템에 접속하는 관리용 단말기에 대한 인터넷망 차단 조치를 하고 있는가?

■ 세부 설명

- 식별된 개인정보취급자의 관리용 단말기에 대해 인터넷망 차단조치를 적용하여야 한다.
 - 인터넷망 차단조치는 논리적(VDI 등) 또는 물리적 방식 적용 가능
- 클라우드컴퓨팅법 제2조제3호에 따른 클라우드컴퓨팅 서비스를 이용하여 개인정보처리시스템을 구성·운영하는 경우에는 해당 클라우드컴퓨팅 서비스에 대한 접속 외에 다른 인터넷의 접속을 차단하는 조치를 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성도 • 인터넷망 차단조치 구성도 • 인터넷망 차단조치 적용대상자 목록
현장실사(예시)	• 인터넷망 차단조치 적용대상자가 적절하게 지정되었는지 확인 • 인터넷망 차단조치 적용 여부 및 적용방식의 적정성 확인

■ 미흡 사례

사례 1	• 개인정보 보호법에 따른 인터넷망 차단조치 의무 대상 개인정보처리자로서, 개인정보처리시스템(중계 관련 시스템)의 접근권한을 설정할 수 있는 개인정보취급자 일부가 인터넷망 차단조치 대상에서 누락되어 있는 경우
사례 2	• VDI 기반으로 인터넷망 차단조치를 적용하였으나, VDI를 통하지 않고 개인정보처리시스템(중계 관련 시스템)에 접속할 수 있는 우회 경로가 존재하는 경우

준비사항

② 외부 인터넷망에서 중계 관련 시스템에 원격접속을 통제하고 있는가?

■ 세부 설명

- 중계 관련 시스템에 대해서는 정보통신망을 통해 외부에서 접속되지 않도록 통제하여야 한다.
 - 정보통신망을 통한 외부접속 통제 기준 및 절차 등 정책 마련
 - 중계 관련 시스템에 VPN 등을 통해 정보통신망을 통해 외부에서 접속되지 않도록 네트워크 등 접근 통제 관리
- 단, 긴급 장애 발생 등 비상 시 제한적으로 정보통신망을 통해 외부에서 접속이 가능하지만, 이에 대한 통제방안이 마련되어 있어야 한다.
 - 정보통신망을 통해 외부에서 접속하는 기준 및 절차가 포함된 보안정책 수립
 - 인가되지 않는 사용자가 정보통신망을 통해 외부에서 접속하지 못하도록 통제하기 위한 사용자인증, 암호화 등의 보안대책을 수립
 - 정보통신망을 통해 외부에서 접속하는 것은 책임자의 승인을 받은 사전 등록자에 한하여 허용하며 외부접속 목록을 기록·보관
 - 정보통신망을 통해 외부에서 접속하는 외부 단말기와 내부 업무용 시스템 구간의 암호화 통신
 - 정보통신망을 통해 외부에서 접속하는 사용자는 아이디·비밀번호 이외에 추가 인증수단을 적용
 - 정보통신망을 통해 외부에서 접속하는 외부 단말기의 악성코드 감염 예방 대책 수립·적용
 - 정보통신망을 통해 외부에서 접속 가능한 내부시스템의 접근 통제 수립·적용
 - 정보통신망을 통해 외부에서 접속하여 수행한 모든 작업 내역 기록 및 모니터링

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 네트워크 구성도 • 정보통신망을 통한 외부 접속 관련 보안정책 • VPN 접속 권한자 목록
현장실사(예시)	• 보안정책을 확인하여 중계 관련 시스템에 대한 정보통신망을 통해 외부에서 접속이 금지되어 있는지 확인 • 방화벽, VPN 정책 등을 점검하여 중계 관련 시스템에 대한 정보통신망을 통해 외부에서 접속이 차단되어 있는지 확인 • 비상시 제한적으로 원격접속하는 경우에 대한 절차 및 통제방안의 적절성 여부 확인

4.4 암호화

4.4.1 정보의 송·수신, 저장 등을 위한 안전한 암호화 적용

세부 지정요건 및 주요 확인사항	
주요내용	정보통신망을 통해 개인정보(비밀번호 등 인증정보 포함) 송·수신, 저장 시 안전한 암호화 알고리즘으로 암호화하여야 한다.
주요 준비사항	① 법적 요구사항을 검토하여 개인정보 저장 시 암호화 대상을 식별하고 있는가? ② 식별된 암호화 대상을 안전한 암호 알고리즘을 적용하여 저장하고 있는가? ③ 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신 시 안전한 알고리즘으로 암호화하고 있는가? ④ 비밀번호, 생체인식정보 등 인증정보를 정보통신망을 통하여 송·수신 시 안전한 알고리즘으로 암호화하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 법적 요구사항을 검토하여 개인정보 저장 시 암호화 대상을 식별하고 있는가?

■ 세부 설명

- 법적 요구사항을 검토하여 저장하는 개인정보 중 암호화 대상을 식별하여야 한다.
- 암호화 대상 식별 시 개인정보의 종류 및 저장 위치에 따라 각각 식별하여야 한다.

[개인정보의 안전성 확보조치 기준에 따른 암호화 대상]

저장 위치	개인정보의 종류	
	이용자가 아닌 정보주체의 개인정보	이용자의 개인정보
위치 무관	비밀번호, 생체인식정보 등 인증정보	
인터넷망 DMZ ¹⁾	고유식별정보	고유식별정보, 신용카드번호, 계좌번호
내부망	고유식별정보 (단, 여권번호, 외국인등록번호, 운전면허번호는 영향평가 또는 위험도 분석을 통해 암호화 미적용 가능)	
개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체	고유식별정보, 생체인식정보	개인정보

- ‘위험도 분석’은 「개인정보 위험도 분석 기준」에 따라 수행되어야 하며 정책기반, 네트워크 기반, DB 및 Application 기반, 웹 기반의 4개 영역 총 26개 점검항목을 모두 준수할 경우 내부망에 저장된 고유식별정보에 대하여 암호화 미적용 가능
- 공공기관은 개인정보 영향평가를 수행 시 내부망에 저장된 고유식별정보의 암호화 적용 여부 및 적용 범위를 정하기 위하여 「개인정보 위험도 분석 기준」에 따라서 위험도 분석 수행 가능

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호통제 정책(대상, 방식, 알고리즘 등) • 데이터베이스 명세서(암호화 대상 데이터 표시)
현장실사(예시)	• 기관 특성에 맞는 암호화 대상 개인정보 식별 여부 확인

■ 미흡 사례

사례 1	• 암호통제 내부 정책에서 관련 법적 요구사항을 고려한 암호화 대상, 암호 강도, 암호화 방법 등에 관한 사항이 적절히 명시되지 않은 경우
------	---

1) DMZ(Demilitarized Zone) : 인터넷망 구간과 내부망의 중간 지점

준비사항

② 식별된 암호화 대상을 안전한 암호 알고리즘을 적용하여 저장하고 있는가?

■ 세부 설명

- 암호화 대상으로 식별된 개인정보는 특성에 맞게 안전한 암호 알고리즘을 적용하여 저장하여야 한다.

[사용을 권장하는 안전한 암호 알고리즘 예시]

개인정보의 종류	적용 암호화 방식	안전한 암호 알고리즘
비밀번호	일방향 암호화	SHA-2 이상 (SHA-224/256/384/512 등)
비밀번호 외 개인정보	대칭키 암호화	SEED, ARIA-128 이상 (ARIA-128/192/256 등), AES-128 이상 (AES-128/192/256 등), LEA, HIGHT, Camellia-128/192/256 등
	공개키 암호화	RSA, RSA-OAEP 등 ※ 키 길이 2,048bit 이상 적용 필요

- 공공기관에서 DB암호화 제품을 도입하는 경우에는 「전자정부법」 등에 따라 국가정보원이 안전성을 확인한 암호모듈 또는 제품을 우선 적용
- 안전한 알고리즘의 기준은 위 사항을 참고할 수 있으나, IT기술의 발전에 따라 변할 수 있으므로 암호화 적용 시점에 국내외 암호전문기관의 최신정보를 반드시 확인
- 개인정보취급자 컴퓨터에 저장 시에는 문서도구 자체 암호화, 암호 유틸리티를 이용한 암호화, DRM(Digital Right Management), 디스크 암호화 등의 방식을 활용할 수 있으며, 안전한 암호 알고리즘을 사용
- 모바일 기기에 저장 시 파일 암호화 또는 디바이스 암호화 기능 등을 활용할 수 있으며, 보조저장매체에 저장 시 파일 암호화 또는 암호화 기능을 제공하는 보안 USB 등을 활용

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호통제 정책(대상, 방식, 알고리즘 등)
현장실사(예시)	• 암호화 대상 개인정보 종류 별 적용된 암호화 알고리즘 확인

■ 미흡 사례

사례 1	• 대상으로 식별된 이용자의 개인정보를 개인정보취급자 컴퓨터에 저장하면서 고유식별정보만 암호화하고, 그 외 개인정보(이름, 연락처 등)에 대해서는 암호화하지 않은 경우
사례 2	• 대상으로 식별된 정보주체의 고유식별정보를 저장하면서 DES 등 안전하지 않은 암호 알고리즘을 적용한 경우

준비사항

③ 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신 시 안전한 알고리즘으로 암호화하고 있는가?

■ 세부 설명

- 다음과 같은 업무 처리를 위해 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신 시 안전한 알고리즘으로 암호화하여야 한다.
 - 정보주체의 개인정보를 처리하는 업무(회원가입, 회원 정보 조회/변경/삭제 등)
 - API 연동으로 개인정보 전문을 처리하는 업무 등
- 정보통신망을 통하여 개인정보를 송·수신 시 다음과 같은 암호화 방법을 적용할 수 있다.
 - TLS(Transport Layer Security) 방식
 - 암호화 응용프로그램(솔루션) 방식
 - IPSec VPN 또는 SSL VPN 방식
 - 첨부문서 암호화 후 이메일 등으로 전송하는 방식 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호통제 정책(대상, 방식, 알고리즘 등) • 웹서버 설정 화면 • 네트워크 구성도
현장실사(예시)	• 개인정보가 처리되는 인터넷망 구간 식별 여부 확인 • 개인정보가 처리되는 인터넷망 구간 암호화 방법 및 알고리즘의 적정성 확인

■ 미흡 사례

사례 1	• API 연동을 이용하고 있으나 HTTP 프로토콜을 이용하여 개인정보를 송·수신하고 있는 경우
사례 2	• 웹서버를 통해 정보주체의 회원가입 시는 암호화 하고 있으나, 회원정보 조회 및 변경, 비밀번호 찾기 등 일부 구간에는 암호화 조치가 누락된 경우

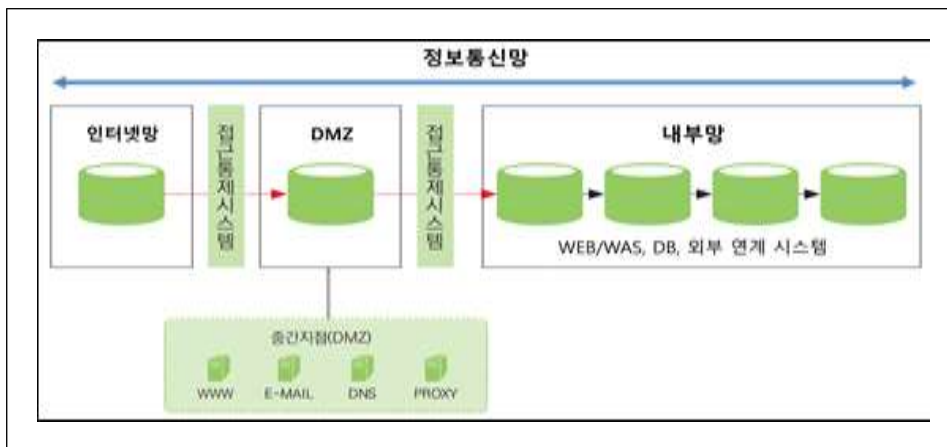
준비사항

- ④ 비밀번호, 생체인식정보 등 인증정보를 정보통신망을 통하여 송·수신 시 안전한 알고리즘으로 암호화하고 있는가?

■ 세부 설명

- 비밀번호, 생체인식정보 등 인증정보를 정보통신망을 통하여 송·수신하는 경우 이를 안전한 암호 알고리즘으로 암호화하여야 한다.
 - 인터넷망, DMZ, 내부망 내에서 시스템 간 송·수신 시 암호화
 - 인터넷망, DMZ, 내부망 간 이동 시 암호화

[개인정보 전송 구간 예시]



■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증거자료(예시)	• 암호통제 정책(대상, 방식, 알고리즘 등) • 네트워크 구성도
현장실사(예시)	• 인증정보가 처리되는 정보통신망 구간 식별 여부 확인 • 인증정보가 처리되는 정보통신망 구간 암호화 방법 및 알고리즘의 적정성 확인

■ 미흡 사례

사례 1	• 정보주체의 인증서 또는 인증키를 발급하는 통합인증서가 타 시스템과 통신 시 전송구간 암호화를 적용하지 않은 경우
------	--

4.4.2 암호키의 안전한 관리 체계

4.4.2.1 안전한 암호 키 생성·이용·배포·보관, 파기 등에 대한 정책 및 절차의 수립·이행

세부 지정요건 및 주요 확인사항	
주요내용	암호키는 암호화된 데이터를 복호화 할 수 있는 정보이고 암호키의 안전한 사용과 관리가 매우 중요하므로 암호키 관리에 대한 절차 등을 마련하여 안전하게 관리되어야 한다.
주요 준비사항	① 암호키 생성, 이용, 보관, 배포, 복구, 파기 등에 관한 암호화 정책을 수립·이행하고 있는가? ② 암호키 사용에 관한 접근권한 부여를 최소화하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 암호 키 생성, 이용, 보관, 배포, 복구, 파기 등에 관한 암호화 정책을 수립·이행하고 있는가?

■ 세부 설명

- 암호 키 생성, 이용, 보관, 배포, 파기에 대해 다음과 같은 항목이 포함된 정책 및 절차를 수립하고 이행하여야 한다.
 - 암호 키 관리 담당자
 - 암호 키 생성, 보관 방법
 - 암호 키 배포 대상자 및 배포방법(복호화 권한 부여 포함)
 - 암호 키 사용 유효기간(변경 주기) : 암호키 변경 시 비용, 업무중요도 등을 고려하여 결정
 - 암호 키 복구 및 폐기 절차와 방법
 - 소스코드에 하드코딩 방식의 암호 키 기록 금지에 관한 사항 등
- 암호 키의 유효기간 만료가 가까워지는 경우 또는 암호 키가 유출되거나 유출이 의심되는 경우, 즉시 암호 키를 변경하여야 한다.
- 담당자는 암호 키 변경, 복구 및 폐기 절차를 숙지하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호 키 관리 정책(암호화 정책에 포함 가능) • 암호 키 관리대장 및 관리시스템 화면
현장실사(예시)	• 암호 키 관리 정책이 마련되어 있는지 확인 • 암호 키 관리 정책에 암호 키 생성, 이용, 보관, 배포, 파기에 대해 필요한 항목이 적절히 포함되어 있는지 확인 • 암호 키 관리 정책에 따라 암호 키가 관리되고 있는지 확인

■ 미흡 사례

사례 1	• 암호 키 관리 절차가 마련되어 있으나, 암호 키 관리담당자 지정에 관한 사항이 누락된 경우
사례 2	• 내부 규정에 중요 정보를 암호화 할 경우 관련 책임자 승인 하에 암호화 키를 생성하고 암호 키 관리대장을 작성하도록 정하고 있으나, 암호 키 관리대장에 일부 암호 키가 누락되어 있거나 현행화되어 있지 않은 경우
사례 3	• 외부 연계를 위해 암호 키를 외부 기관에게 배포하고 있으나, 해당 암호 키에 대한 유효기간이 설정되어 있지 않아 암호 키 변경 없이 영구적으로 사용 가능한 경우

준비사항

② 암호 키 사용에 관한 접근 권한 부여를 최소화하고 있는가?

■ 세부 설명

- 암호 키 사용에 관한 접근 권한은 최소화하여 부여하고 관리하여야 한다.
 - 암호 키에 대한 접근 권한 최소화
 - 암호 키 관리시스템의 관리자 및 담당자 변경 시 지체없이 접근 권한을 변경 또는 말소
 - 암호 키 접근 권한의 적절성 여부에 대한 주기적인 검토
 - 암호 키 사용 및 접근에 대한 모니터링 등

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호 키 접근 권한 부여 현황 • 암호 키 관리대장 및 암호 키 관리시스템 화면
현장실사(예시)	• 암호 키 관리시스템 등 암호 키 사용에 대한 접근 권한이 최소한으로 부여되고 있는지 확인

■ 미흡 사례

사례 1	• 암호 키 관리시스템에 대한 접근이 불필요한 인원에게 암호 키 관리시스템의 접근 권한이 부여되어 있는 경우
------	--

4.4.2.2 암호복호화 대상 시스템과 암호키의 분리

세부 지정요건 및 주요 확인사항	
주요내용	암호키의 안전한 관리를 위하여 암호복호화 대상 시스템과 분리된 별도의 장치에 안전하게 보관 및 관리되어야 한다.
주요 준비사항	① 암호키 생성 후 암호키는 별도의 안전한 장소에 보관하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 암호 키 생성 후 암호 키는 별도의 안전한 장소에 보관하고 있는가?

■ 세부 설명

- 암호 키의 안전한 관리를 위하여 암호·복호화 대상 시스템과 분리된 암호 키 관리시스템을 구축하여야 한다.
 - 암호 키는 암호·복호화 대상 시스템 내에 함께 존재하지 않도록 별도로 분리된 시스템을 통해 관리하여야 함
 - 예를 들어, 암호 키 관리시스템(KMS; Key Management System), HSM(Hardware Security Module) 등을 통해 암호 키를 별도로 저장·관리할 수 있음
- 생성된 암호키는 암호키 손상 시 시스템 또는 암호화된 정보의 복구를 위하여 별도의 매체에 저장 후 안전한 장소에 보관하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 암호 키 관리시스템 구축 증적(시스템 설명자료, 구성도 등) • 암호 키 관리대장 및 암호 키 관리시스템 화면 • 암호 키 백업 현황
현장실사(예시)	• 암호·복호화 대상 시스템과 분리된 암호 키 관리시스템이 구축되어 있는지 확인 • 암호 키 생성 후 안전한 장소에 백업하고 있는지 확인

■ 미흡 사례

사례 1	• 암호 키 관리시스템이 별도로 구축되어 있으나, 일부 응용프로그램에서 사용되는 암호 키는 소스 프로그램 내에 하드코딩 되어 있거나, 해당 시스템의 설정 파일에 저장되어 있는 경우
사례 2	• 암호 키를 백업하고 있으나, 암호 키 관리시스템과 동일한 전산실에 보관하고 있어 재해 등이 발생할 경우 암호 키가 소실될 위험이 높은 경우

4.5 접속기록의 보관 및 점검

4.5.1 중계 관련 시스템을 안전하게 관리하기 위한 접속기록의 보관·점검 및

이상접속을 탐지하기 위한 조치

4.5.1.1 접속기록이 위·변조 및 도난, 분실되지 않도록 하기 위한 보관 조치

세부 지정요건 및 주요 확인사항	
주요내용	중계 관련 시스템을 안전하게 관리하기 위한 접속기록이 전자적으로 기록되도록 하고, 접속기록은 분실·도난·유출·위조·변조 또는 훼손되지 않도록 안전하게 보관되도록 하여야 한다.
주요 준비사항	① 접속기록을 식별자, 접속 일시, 접속지 정보, 처리한 정보주체 정보, 수행 업무 등 필요한 사항이 모두 기록 및 저장하고 있는가? ② 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하고 있는가? ③ 접속기록을 일정기간 이상 보관하고 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 접속기록을 식별자, 접속 일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등 필요한 사항이 모두 기록 및 저장하고 있는가?

■ 세부 설명

- 개인정보처리시스템에 대한 접속기록은 법적 요구사항을 준수할 수 있도록 필요한 항목을 모두 포함하여 전자적으로 기록하도록 하고 접속 경로별로 누락없이 기록될 수 있도록 하여야 한다.
 - 응용프로그램을 통해 접속하는 경우
 - DB접속툴을 이용하여 DB에 직접 접속하는 경우
 - 운영자 등이 DB서버에 SSH 등으로 접속 후, 해당 서버에서 DBMS로 접속하는 경우 등
- 접속기록은 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 5가지 항목은 반드시 포함하여 저장하여야 한다.

필수 저장 항목	항목 예시	설명
식별자	ID	• 개인정보처리시스템에서 접속한 자를 식별할 수 있도록 부여된 ID 등 계정 정보
접속일시	날짜 및 시간	• 접속한 시점 또는 업무를 수행한 시간 (년-월-일, 시:분:초)
접속지 정보	접속자 IP 주소	• 시스템에 접속한 자의 PC, 모바일기기 등 단말기 정보 또는 서버의 IP주소 등 접속 주소
처리한 정보주체 정보	ID, 고객센터, 학번, 사번 등	• 개인정보취급자가 누구의 개인정보를 처리하였는지 알수 있는 식별정보 • 검색조건문(쿼리)을 통해 대량의 개인정보를 처리했을 경우 해당 검색조건문을 정보주체 정보로 기록 가능
수행업무	조회, 입력, 수정, 삭제, 출력, 다운로드 등	• 개인정보에 대한 열람, 수정, 삭제, 인쇄, 입력, 다운로드 등 어떤 행위를 수행했는지 알 수 있는 구체적인 정보

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 접속기록 저장 대상 시스템 식별 결과 • 접속기록 내역
현장실사(예시)	• 접속기록 저장 대상 시스템 누락 여부 확인 • 접속기록 내 항목의 적정성 확인

■ 미흡 사례

사례 1	• 개인정보를 처리하는 응용프로그램의 최근 개발된 페이지에서 정보주체를 조회한 기록이 저장되지 않은 경우
사례 2	• 개인정보처리시스템에 접속한 기록을 확인한 결과 접속자의 계정, 접속 일시, 접속자 IP주소 정보는 남기고 있으나, 처리한 정보주체 정보 및 수행업무 정보는 남기고 있지 않은 경우

준비사항

② 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하고 있는가?

■ 세부 설명

- 개인정보의 다운로드가 확인된 경우에는 내부 관리계획 등으로 정하는 바에 따라 그 사유를 반드시 확인하여야 한다.
 - 개인정보 다운로드가 확인된 경우에 대한 사유 확인 기준 및 절차를 내부 관리계획 등으로 사전에 정할 필요가 있음
 - 다운로드 사유 확인이 필요한 기준은 개인정보처리시스템의 운영 환경 등을 고려하여 자율적으로 수립할 수 있으며, 다운로드한 정보주체 수, 일정기간 내 다운로드 횟수, 업무시간 외 다운로드 수행 사유 등을 포함할 수 있음
 - 개인정보처리시스템을 통한 다운로드 시 다운로드 사유를 작성 및 확인하는 기능 구현
- ※ 다운로드 사유 확인이 필요한 기준에 관한 예시는 아래와 같음

- (다운로드 정보주체의 수) 통상적으로 개인정보 처리 건수가 일평균 20건 미만인 소규모 기업에서 개인정보취급자가 100명 이상의 정보주체에 대한 개인정보를 다운로드 한 경우 사유 확인
- (일정기간 내 다운로드 횟수) 개인정보취급자가 1시간 내 다운로드한 횟수가 20건 이상일 경우 단시간에 수차례에 걸쳐 개인정보를 다운로드 한 행위에 대한 사유 확인
- (업무시간 외 다운로드 수행) 새벽시간, 휴무일 등 업무시간 외 개인정보를 다운로드한 경우 사유 확인

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획 • 개인정보 다운로드 시 사유 확인 기준 및 결과 • 개인정보처리시스템의 다운로드 사유 작성 및 확인 기능
현장실사(예시)	• 내부 관리계획 내 다운로드 사유 확인 기준 수립 여부 확인 • 다운로드 사유 점검 결과 및 소명자료의 적정성 확인

■ 미흡 사례

사례 1	• 내부 관리계획에 개인정보 다운로드 사유 확인 기준이 없거나 중계전문기관의 업무환경을 고려하지 않은 기준이 수립된 경우
사례 2	• 내부 관리계획에는 1,000명 이상의 정보주체에 대한 개인정보를 다운로드한 경우에는 사유를 확인하도록 기준이 책정되어 있는 상태에서 1,000건 이상의 개인정보 다운로드가 발생하였으나 그 사유를 확인하지 않고 있는 경우

준비사항

③ 접속기록을 일정 기간 이상 보관하고 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하고 있는가?

■ 세부 설명

- 개인정보처리시스템에 접속한 기록을 1년 이상 보관·관리하여야 하며, 다음 항목에 해당하는 경우 2년 이상 접속기록을 보관·관리하여야 한다.
 - 5만명 이상의 정보주체에 관한 개인정보를 처리하는 경우
 - 고유식별정보 또는 민감정보를 처리하는 경우
 - 「전기통신사업법」제6조제1항에 따라 등록을 하거나 같은 항 단서에 따라 신고한 기간 통신사업자에 해당하는 경우
- ※ 중계 관련 시스템 운영하기 전에는 접속기록을 일정기간 보관할 수 있는 저장 공간 등 확인
- 접속기록은 위·변조 및 도난, 분실되지 않도록 다음 방법 중 언 하나를 고려하여 안전하게 보관하여야 한다.
 - 정기적으로 접속기록 백업 수행 및 별도의 저장장치에 보관
 - CD-ROM, WORM(Write Once Read Many) 등 덮어쓰기 방지 매체 사용
 - 접속기록을 수정 가능한 매체(하드디스크, 자기 테이프 등)에 백업하는 경우에는 무결성 보장을 위해 위·변조 여부를 확인할 수 있는 정보(MAC값, 전자서명값 등)를 별도의 장비에 보관·관리 등
- 접속기록에 대한 접근권한 부여는 최소화하여 비인가자에 의한 위·변조 및 삭제 등이 발생하지 않도록 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 접속기록 보관 내역 • 접속기록 저장장치에 대한 접근통제 내역
현장실사(예시)	• 보관하고 있는 접속기록 보관 기간 및 방법 확인 • 접속기록 보관 장소의 접근통제 확인

■ 미흡 사례

사례 1	• 개인정보처리시스템에 접속한 기록을 로그 파일로 기록하고 있으나 백업 등 별도의 안전한 보관 조치가 적용되지 않은 경우
사례 2	• 개인정보처리시스템에 접속한 기록을 보관하고 있으나, 최근 6개월 동안만 저장하고 있는 경우

4.5.1.2 자동화된 방식 등을 통한 접속기록의 분석 기능

세부 지정요건 및 주요 확인사항	
주요내용	중계 관련 시스템에서 처리한 개인정보의 오남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위한 접속기록에 대하여 자동화된 방식으로 분석하여야 한다.
주요 준비사항	① 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 자동화된 방식으로 접속기록 등을 분석하여 보고하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 자동화된 방식으로 접속기록 등을 분석하여 보고하고 있는가?

■ 세부 설명

- 개인정보의 오·남용, 분실·도난·유출·위조·변조·훼손 등에 대응하기 위하여 접속기록 점검 계획을 수립하고, 그 계획에 따라 자동화된 방식으로 접속기록을 분석하여야 한다.
 - 점검계획에는 점검 방법, 점검 기준, 점검 주기/시점, 담당자, 비정상 행위 발견 시 대응 절차, 보고 절차 등 포함
 - 점검계획에 수립된 점검 기준에 따라 이상행위를 탐지하는 기능을 직접 프로그램으로 구현 또는 상용 솔루션(예, 접속기록 분석 시스템) 도입
- ※ 자동화된 방식으로 분석은 접속기록에 대한 비정상 행위를 프로그램화하여 자동으로 분석할 수 있는 것을 말함
- ※ 중계 관련 시스템 운영하기 전에는 접속기록은 없으므로 자동화된 방식의 점검 기능으로 대체
- 특히, 대량 개인정보 다운로드, 과도한 개인정보 조회 등 위험 행위에 대해서는 점검기준에 포함되어 반드시 분석될 수 있도록 하여야 한다.
- 접속기록 점검 결과는 전문기관 관리책임자에게 정기적으로 보고하고 비정상 행위 발견 시 절차에 따라 대응하여야 한다.
 - 접속기록 점검 결과 비정상 행위 발견 등이 확인되면 전문기관 관리책임자 및 개인정보 보호책임자에게 보고
 - 비정상 행위 발견 시 개인정보 유출, 오·남용 행위 등 발생 여부를 확인하기 위한 절차를 수립하고 절차에 따라 대응
- ※ 접속기록 내 비정상 행위에 해당하는 경우의 예시는 아래와 같음

- 계정 : 접근권한이 부여되지 않은 계정으로 접속한 행위 등
- 접속일시 : 출근시간 전, 퇴근시간 후, 새벽시간, 휴무일 등 업무시간 외에 접속한 행위 등
- 접속지 정보 : 인가되지 않은 컴퓨터 또는 지역(IP)에서 접속한 행위 등
- 처리한 정보주체 정보 : 특정 정보주체에 대하여 과도하게 조회, 다운로드 등의 행위 등
- 수행업무 : 대량의 개인정보에 대한 조회, 정정, 다운로드, 삭제 등의 행위 등
- 그 밖에 짧은 시간에 하나의 계정으로 여러 지역(IP)에서 접속한 행위 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 접속기록 자동화된 점검 기능(화면) • 전문기관 관리책임자 보고 결과
현장실사(예시)	• 접속기록 자동화된 점검 기능 확인 • 접속기록 점검 결과의 전문기관 관리책임자 보고 결과 확인

■ 미흡 사례

사례 1	• 접속기록 검토 대상, 주기, 담당자 등에 대한 세부 기준 및 절차가 수립되어 있지 않은 경우
사례 2	• 접속기록 점검 결과 또는 전문기관 관리책임자 보고 결과 증거자료가 존재하지 않은 경우

4.6 악성프로그램 등 방지

4.6.1 악성프로그램 등을 예방·탐지·대응하기 위한 조치

4.6.1.1 보안프로그램의 설치 및 최신 업데이트 관리, 발견된 악성프로그램에 대한 삭제 등 조치

세부 지정요건 및 주요 확인사항	
주요내용	시스템 및 업무 컴퓨터에 대한 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영하여 최신 업데이트 상태로 유지하도록 하고 운영체제 및 소프트웨어의 제작 업체에서 공지된 보안업데이트도 최신 업데이트 상태로 유지하여야 한다.
주요 준비사항	① 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영하고 있는가? ② 일 1회 이상 업데이트를 실시하는 등 최신의 상태로유지하고 있는가? ③ 발견된 악성프로그램 등에 대해 삭제 등 대응조치를 마련하고 있는가? ④ 응용프로그램이나 운영체제 소프트웨어의 제작 업체에서 보안업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트 등을 실시하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영하고 있는가?

■ 세부 설명

- 악성프로그램 방지·치료를 위한 내부 정책(예, 내부 관리계획 등)이 수립하여 체계적으로 운영되어야 한다.
 - 악성프로그램 탐지 시 즉시 대응할 수 있도록 처리 절차를 수립하고 이를 지속적으로 이행
 - 처리 절차에는 탐지, 격리, 제거, 보고, 사후 분석 단계를 포함
 - 정기적으로 절차를 검토하고, 새로운 위협에 대응할 수 있도록 현행화
- 서버 및 업무용 컴퓨터에 백신소프트웨어 등의 보안 프로그램을 설치 및 운영되어야 한다.

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획(보안 프로그램 관리 조항을 포함) • 보안 프로그램 설치·운영 현황 • 보안 프로그램 관리 시스템 운영 현황(있을 경우)
현장실사(예시)	• 보안 프로그램 설치·운영 현황 확인 • 보안 프로그램 관리 방안 수립 여부 확인 • 보안 프로그램 관리 시스템 구성 현황 확인 • 보안 프로그램 관리 시스템 통제 정책 설정 및 운영 현황 확인

준비사항

② 일1회 이상 업데이트를 실시하는 등 최신의 상태로 유지하고 있는가?

■ 세부 설명

- 악성프로그램 방지·치료를 위해 수립된 내부 정책(예, 내부 관리계획 등)을 준수하여야 한다.
- 서버 및 업무용 컴퓨터에 백신소프트웨어 등의 보안 프로그램의 업데이트를 실시하여 최신의 상태를 유지하여야 한다.
 - 중앙백신관리서버와 클라이언트 백신소프트웨어 간 통신 상태 점검
 - 악성프로그램 탐지 패턴 일1회 이상 업데이트
 - 실시간 감시 등 보안 기능 설정

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획(보안 프로그램 관리 조항을 포함) • 보안 업데이트 운영 및 관리 현황
현장실사(예시)	• 서버 및 컴퓨터에 대한 백신소프트웨어 최신 상태 확인 • 중앙백신관리서버와 클라이언트 백신소프트웨어 간 통신 상태 점검

■ 미흡 사례

사례 1	• 사용자 컴퓨터에 설치된 백신프로그램의 패턴이 정상적으로 업데이트되고 있지 않음
------	---

준비사항

③ 발견된 악성프로그램 등에 대해 삭제 등 대응조치를 마련하고 있는가?

■ 세부 설명

- 악성프로그램 방지·치료를 위해 수립된 내부 관리계획을 준수하여야 한다.
※ 내부 관리계획 이외에 악성프로그램 방지·치료 관련하여 수립된 다른 정책(예, 정보보안 지침 등)도 가능함
- 악성프로그램 발견 시 신속히 삭제 등 대응조치를 수행하고 책임자에게 보고 및 승인절차에 따라 체계적 관리가 되어야 한다.
- 악성프로그램이 발견 이후 로그 분석, 과거 침해사고 보고서 등을 통해 발견된 악성프로그램의 유포 경로를 식별하고 기술적·절차적 대응 방안을 수립하도록 한다.
 - 발생한 악성 프로그램에 대한 상세 분석, 처리 방안, 개선 절차를 문서화
 - 정기적인 보안 인식 교육 등을 통해 재발 방지 방안 수립

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획(보안 프로그램 관리 조항을 포함) • 악성프로그램 대응 절차
현장실사(예시)	• 악성프로그램 발견 사례 여부 확인

준비사항

- ④ 응용프로그램이나 운영체제 소프트웨어의 제작 업체에서 보안업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트 등을 실시하고 있는가?

■ 세부 설명

- 내부 관리계획 내에 응용프로그램이나 운영체제 보안 업데이트 등 중계 관련 시스템 보호를 위한 공식적인 절차를 수립하도록 한다.
- 서버 및 업무용 컴퓨터에 응용프로그램 및 운영체제 소프트웨어 업데이트를 통해 최신화를 유지하고 현황을 관리하도록 한다.
 - 패치 관리 시스템(PMS) 등과 클라이언트 프로그램 간 통신 상태 점검, 보안 업데이트 수행, 실시간 감시 등 보안 기능 설정 현황
- 공지된 보안업데이트 지연에 따른 취약점에 대한 조치 활동 수립 및 보완조치를 수행하도록 한다.
 - 취약점 확인에 대한 책임자 보고 및 승인절차
 - 조치 지연 발생 시 책임자 보고 및 위험관리 방안 수립

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 내부 관리계획(보안 업데이트 관리 조항을 포함) • 보안 업데이트 운영 및 관리 현황
현장실사(예시)	• 서버 및 컴퓨터에 응용프로그램 및 운영체제 업데이트 현황 확인

4.7 물리적 안전조치

4.7.1 정보를 안전하게 보관·관리하기 위한 물리적 안전조치

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관은 중계 관련 시스템이 구축된 전산실 등 중요 정보를 보관하고 있는 물리적 보관 장소에 대하여 비인가자의 출입 등으로 인한 침해 사고 방지를 위한 출입통제 절차를 수립·운영하여야 한다.
주요 준비사항	① 주요 설비 및 시스템을 보호하기 위하여 물리적 보호구역을 정의하고 구역 별 보호대책을 수립·이행하고 있는가? ② 물리적 보호 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 시설(예 : 출입 통제 시스템 등)을 갖추고 있는가? ③ 주기적으로 통제구역의 출입명단 및 출입카드 발급 현황을 검토 및 승인하고 더 이상 출입하지 않는 직원은 출입명단에서 삭제하고 있는가? ④ 보호구역 내 중요한 장비, 문서, 모바일 기기(노트북, 패드 등), 보조저장 매체 등에 대한 반출·입 관련 정책 및 절차를 수립·이행하고 있는가? ⑤ 반출·입 절차에 따라 반출·입대장을 작성하고 관리자는 주기적으로 반출·입 이력을 점검하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 주요 설비 및 시스템을 보호하기 위하여 물리적 보호구역을 정의하고 구역별 보호대책을 수립·이행하고 있는가?

■ 세부 설명

- 개인정보 및 중요정보, 문서, 저장매체, 주요 설비 및 시스템 등을 보호하기 위하여 통제구역, 제한구역, 접근구역 등 보호구역 지정기준 마련하여야 한다.
 - 주요 설비가 운영되는 시설 등 서비스의 주요 물리적인 시설을 안전하게 보호하기 위해 중요도에 따라 분류하여 지정하고 보호구역임을 알리는 표식 설치
 - 주요 설비는 관리자가 즉시 설비의 위치를 확인할 수 있도록 물리적 배치도(시설 단면도, 배치도 등) 또는 목록을 주기적으로 현행화
- 보호구역 별 중요도 및 특성을 반영하여 물리적인 접근통제 대책을 수립하고 작업 절차에 따른 필요 설비 구비 및 운영하여야 한다.
 - 보호구역 별 출입통제 방식(ID카드, 생체인식 등), 출입 가능자, 출입 절차, 영상감시(CCTV 등) 등이 포함된 보호대책 수립
- 내부직원, 외부직원(유지보수 등), 제3자의 출입 등 역할에 따른 출입절차 수립 및 운영하여야 한다.
 - 제한구역 및 통제구역은 출입 인가자를 최소한으로 제한하고 접근시도를 차단하고 불법적인 접근시도 여부를 주기적으로 검토

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 보호구역 지정 현황 • 보호구역 물리적 보안대책 • 시스템 구성도(물리적 구성 확인 가능) • 시스템 정보자산 배치도 • 물리적보안지침
현장실사(예시)	• 접근구역, 제한구역, 통제구역 등으로 물리적 보호구역을 지정하고 있는지 확인 • 주요 물리적 보호구역에 대한 적절한 보호대책을 수립하고 있는지 확인 • 보호구역에 대한 비인가자 접근 시 출입을 통제할 수 있는지 확인 • 출입 동선상 통제되지 않은 출입문 및 우회경로가 있는지 확인

■ 미흡 사례

사례 1	• 보호구역별 보호 대책이 마련되지 않음
------	--

준비사항

② 물리적 보호 구역에 인가된 자만이 접근할 수 있도록 출입을 통제하는 시설(예 : 출입 통제 시스템 등)을 갖추고 있는가?

■ 세부 설명

- 보호구역 별 중요도 및 특성을 반영하여 물리적인 접근통제 대책을 수립하고 작업 절차에 따른 필요 설비(예: 출입 통제시스템)를 구비하여 운영하도록 한다.
 - 보호구역 별 출입통제 방식(ID카드, 생체인식 등), 출입 가능자, 출입 절차, 영상감시(CCTV 등) 등이 포함된 보호대책 수립
 - 담당자, 내부직원, 외부직원(유지보수 등), 제3자의 출입에 대한 출입절차를 수립하여 적용
 - 보호구역 별 출입통제 방식(ID카드, 생체인식 등), 출입 가능자, 출입 절차, 영상감시 등 보호대책 적용
- 보호구역에 출입 시 출입자에 대한 추적 및 관리를 효율적으로 수행하기 위해 출입 통제 시스템을 구축하여 출입자에 대해서는 시스템을 통해 출입기록이 자동으로 기록되고 확인할 수 있어야 한다.
 - 출입자에 대한 신원확인을 할 수 있도록 지문 또는 출입카드를 발급하여 출입 관리
 - 임시출입자의 경우 출입이력을 관리할 수 있도록 수단을 강구하여야 함(출입구 내 CCTV 설치 및 출입대장 기록·관리)

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 물리적 보안 지침 • 보호구역 출입절차 및 출입권한 등록절차서 • 출입통제 장치 종류 및 운영사진 • 출입관리대장
현장실사(예시)	• 보호구역에 대한 비인가자 접근 시 출입을 통제할 수 있는지 확인 • 출입 동선상 통제되지 않은 출입문 및 우회경로가 있는지 확인 • 임시 출입자의 출입절차(카드키 반출입 등)의 적절성 확인 • 출입관리대장 작성 적절성 확인

준비사항

③ 주기적으로 통제구역의 출입명단 및 출입카드 발급 현황을 검토 및 승인하고 더 이상 출입하지 않는 직원은 출입명단에서 삭제하고 있는가?

■ 세부 설명

- 담당자, 내부직원, 외부직원(유지보수 등), 제3자 등의 출입에 대한 출입절차를 수립하여 적용하도록 한다.
 - 보호구역에 대한 출입권한 등록 · 삭제는 별도 신청하여 관리
 - 보호구역 별 출입 가능한 업무를 정의하고 출입권한이 부여된 인가자 명단을 관리
 - ※ 보호구역을 신규로 구축하여 해당 출입내역 등 주기적 검토사항이 없는 경우는 출입절차 수립의 적정성 확인
- 제한구역 및 통제구역은 출입 인가자를 최소한으로 제한하고 접근시도를 차단하고 불법적인 접근시도 여부를 주기적으로 검토하도록 한다.
- 출입기록은 즉시 확인할 수 있도록 출입통제 시스템 등을 통해 관리되도록 한다.
 - 보직변경, 퇴사자 등이 발생하면 즉시 출입명단에서 삭제하여 현행화 관리
 - 출입통제 저장정보: 일련번호, 행위자, 출입유형(IN/OUT), 출입위치, 성공/실패 여부, 실패원인, 일자/시간 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 출입권한 부여인원 현황 (이름, 등록기간, 담당업무, 등록사유 등) • 출입기록 관리대장 및 출입로그 • 출입기록 검토서
현장실사(예시)	• 인가된 상시 출입자에 대한 주기적 검토 확인 • 보호구역 출입권한자 중에 불필요한 인원이 포함되어 있는지 확인 • 임시 출입자의 출입절차(카드키 반출입 등)의 적절성 확인 • 출입 이벤트 발생 시 출입내역을 기록하고 관리하는지 확인 • 보호구역 출입내역을 확인 하여 비인가자의 출입기록이 있는지 확인 • 출입기록은 성공 · 실패 내역이 모두 기록되어야 하며, 이상행위로 파악되는 경우에는 실패사유에 대한 감사절차가 있는지 확인

준비사항

- ④ 보호구역 내 중요한 장비, 문서, 모바일 기기(노트북,패드 등), 보조저장매체 등에 대한 반출·입 관련 정책 및 절차를 수립·이행하고 있는가?

■ 세부 설명

- 보호구역 내 중요한 장비 및 문서 등의 미승인 반출·입을 통한 중요정보 유출, 악성코드 감염 등의 보안 사고 예방을 위하여 보호구역 내 임직원 및 외부인력의 장비 및 문서의 반출·입 통제절차를 수립하고 기록·관리하여야 한다.
 - 정보시스템(서버, 네트워크 장비 등), 문서, 모바일 기기(노트북, 스마트패드, 스마트폰 등), 보조저장매체(HDD, SDD, USB메모리, 외장하드디스크, CD/DVD, 테이프 등)을 반출입 통제 대상으로 지정
 - 보호구역 출입통제 책임자 사전승인, 반출입 관리대장 기록, 반출입 기기에 대한 보안점검 수행(백신 설치 여부, 보안업데이트 여부, 악성코드 감염 여부, 보안스티커 부착 여부 등) 등 반출입 통제 절차 수립
- ※ 보호구역을 신규로 구축하여 반출·입 내역이 없는 경우 반출·입 절차의 적정성 확인
- 주요 정보시스템이 위치한 통제구역, 중요 제한구역 등에서 보조저장매체 사용을 제한하여야 한다.
 - 불가피하게 사용할 경우 책임자의 허가절차를 거친 후 적법한 절차에 따른 사용
 - 통제구역, 중요 제한구역 내 보조저장매체 사용 현황에 대한 정기적인 검토 수행
- 불가피하게 사용할 경우 보조저장매체 사용에 대한 기록관리가 되도록하여야 한다.
 - 보안USB 또는 매체제어 솔루션을 통해 사용할 경우 보조저장매체를 통한 입출력 로그를 기록하고 주기적으로 검토 수행
 - IO 포트 봉인을 해제한 후 IO포트를 사용할 경우 봉인상태와 서버 랙의 전/후면부를 촬영하는 감사 기록을 기록하고 주기적으로 검토 수행

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 반출입 통제 대상 반출·입 통제 절차 • 반출입 통제 대상 반출·입 신청서 • 반출입 관리 대장 • 보조저장매체 사용 승인 자료 • 보조저장매체 관리 절차 • 보조저장매체 관리 대장
현장실사(예시)	• 보호구역 별 반출입 통제 대상 지정 여부 확인 • 보호구역 별 반출입 통제 대상의 반출·입에 대한 통제절차를 수립 확인 • 반출입 관리 대장 확인 • 보조저장매체 사용 승인 자료 확인 • 보조저장매체 솔루션 로그 또는 IO포트 봉인 상태 감사기록 및 운영 현황 확인 • 보조저장매체 관리 절차 확인 • 보조저장매체 관리 대장 확인

■ 미흡 사례

사례 1	• 별도의 승인 절차 없이 특정 사용자에게 예외 정책을 허용함
사례 2	• 특정 사용자에게 허용한 예외 정책이 허용 기간이 종료되었으나, 차단되지 않음

준비사항

⑤ 반출·입 절차에 따라 반출·입대장을 작성하고 관리자는 주기적으로 반출·입 이력을 점검하고 있는가?

■ 세부 설명

- 보호구역 내 반출·입 절차에 따라 반출·입 대장을 작성하고 관리자는 반출·입 이력을 주기적으로 점검하여야 한다.
 - 반출·입 통제 대상에 대한 출입에 대한 이력에는 반출·입 일시, 반출·입 요청자, 기기식별정보(모델, MAC, 시리얼 번호 등), 사유, 반출·입 구역, 보안점검 결과, 관리자 확인 서명 등이 포함되어 기록 되도록 함
 - 관리자는 주기적(월 1회)으로 점검하여 미승인된 반출·입 여부를 확인
 - ※ 보호구역을 신규로 구축하여 반출·입 내역이 없는 경우 반출·입 절차의 적정성 확인
- 보조저장매체를 사용하는 경우, 보조저장매체의 보유현황, 사용 및 관리 실태를 책임자가 주기적으로 점검하여 현행화 관리가 되도록 한다.
 - 반출·입 절차에 따라 반출·입 대장을 작성하고 관리자는 반출·입 이력을 주기적으로 점검
 - 보조저장매체 보유 현황, 관리 대장, 사용이력 확인 등 관리 실태를 주기적으로 점검
 - ※ 보조저장매체를 보유하고 반출·입 내역 등 사용이력이 없는 경우 보조저장매체 보유현황 등 관리의 적정성 확인

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 반출·입 통제 대상 반출·입 신청서 • 반출·입 관리 대장 • 반출·입 관리 대장 검토 내역 • 보조저장매체 관리대장 • 보조저장매체 실태 점검 내역
현장실사(예시)	• 보호구역 별 반출·입 통제 대상 지정 여부 확인 • 보호구역 별 반출·입 통제 대상의 반출·입 관리대장 점검 결과 확인 • 보조저장매체 보유 현황, 관리 대장 확인 등 관리 실태를 주기적으로 점검 기록 확인

4.8 재해·재난 대비 안전조치

4.8.1 재해·재난 및 장애 등에 대비한 비상계획, 복구계획 및 훈련실시 방안

4.8.1.1 위기대응 매뉴얼 마련 및 정기적 점검

세부 지정요건 및 주요 확인사항	
주요내용	시스템에 대한 재해·재난 및 장애 등에 대비한 위기대응 매뉴얼을 수립하도록 하고 이에 대하여 모의훈련 등 주기적 점검을 통해 대응 조치할 수 있도록 하여야 한다.
주요 준비사항	① 재해·재난, 장애 등에 대비한 위기대응 매뉴얼 등 대응 절차를 수립하고 있는가? ② 재해·재난, 장애 등에 대비 대응절차에 따른 정기적으로 점검을 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 재해·재난, 장애 등에 대비한 위기대응 매뉴얼 등 대응 절차를 수립하고 있는가?

■ 세부 설명

- 서비스 연속성을 위협할 수 있는 재해·재난, 장애 유형을 식별하고, 유형별 피해규모 및 업무 영향도를 분석하여 서비스 및 시스템을 식별하여야 한다.

– 중계 관련 시스템 등 자산 식별

– 자연재해, 해킹, 통신장애 등 서비스(업무) 연속성을 위협할 수 있는 IT재해 유형 식별

※ IT 서비스 중단을 초래할 수 있는 IT 재해 유형은 아래와 같음

- 자연재해 : 화재, 홍수, 지진, 태풍 등
- 외부요인 : 해킹, 통신장애, 정전 등
- 내부요인 : 시스템 결함, 기계적 오류, 사용자 실수, 의도적 악의적 운영, 핵심 운영자 근무 이탈(사망, 병가, 휴가, 이직 등), 환경설정 오류 등

– 재해·재난(화재, 지진, 수해 등), 장애(통신장애, 시스템 장애 등) 유형 별 피해규모 및 영향도 분석

– 서비스 및 시스템의 중요도 및 특성에 따른 복구 목표시간(RTO), 복구 목표시점(RPO)을 정의

- 서비스의 재난 상황 발생 시 신속하게 대응하고 서비스 연속성을 확보하기 위해 대응 절차를 수립하여야 한다.
- IT 재해 발생 시 신속한 복구가 가능하도록 하기 위해 위기대응 매뉴얼에 다음의 내용이 포함되어야 한다.

– 재해 시 복구조직 및 역할 정의 : IT 재해 발생 시 복구를 위한 관련부서 및 담당자 역할과 책임 부여

※ 필요시, 관련 전문기술자 확보 방안 고려

– 비상연락체계 : 조직 내 관련 부서 담당자, 유지보수 업체 등 복구 조직상 연락체계 구축

– 복구 전략 및 대책 수립 방법론 : 업무영향분석, 복구 목표시간 및 복구 목표시점 정의, 서비스 및 시스템 식별 등

– 복구 순서 정의 : 복구 목표 시간별로 정보시스템의 복구 순서 정의

– 복구 절차, 재해 발생, 복구 완료, 사후관리 단계 포함

※ 개인정보처리시스템 위기대응 매뉴얼 및 백업 복구 계획에 작성되는 내용은 아래 참조

- 개인정보처리시스템 구성 요소(개인정보 보유량, 종류·중요도, 시스템 연계 장비 설비 등)
- 재해·재난 등에 따른 파급효과(개인정보 유출, 손실, 훼손 등) 및 초기대응 방안
- 개인정보처리시스템 백업 및 복구 우선순위, 복구 목표시점, 복구 목표시간
- 개인정보처리시스템 백업 및 복구 방안(복구센터 마련, 백업계약 체결, 비상가동 등)
- 업무분장, 책임 및 역할
- 비상연락체계
- 실제 발생 가능한 사고에 대한 정기적 점검, 사후관리 및 지속관리 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 재해·재난, 장애 등에 대비한 위기대응 매뉴얼
현장실사(예시)	• 재해·재난, 장애 등에 대비한 위기대응 매뉴얼 결재 및 내용의 적정성 확인

준비사항

② 재해·재난, 장애 등에 대비 대응절차에 따른 정기적으로 점검을 하고 있는가?

■ 세부 설명

- 재해·재난, 장애 발생 등을 대비한 위기대응 매뉴얼을 대로 업무 수행이 가능하도록 정기적으로 점검을 하여야 한다.
 - 통신 중단, 전원 공급망 장애, 화재 등 재난유형 별 재해복구 모의훈련 시나리오 작성 및 모의훈련 계획 수립
 - 재해 복구 모의 훈련 수행 후 결과보고서 작성 및 보고
 - 모의 훈련 결과보고서에 따른 개선사항 도출 및 대응 절차 보완
 - 연 1회 이상 주기적 대응 절차 검토 수행
- ※ 중계 관련 시스템이 운영되기 이전에는 재해·재난 대응 훈련 계획서로 대체

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 재해복구 모의훈련 계획서 • 재해복구 모의훈련 결과보고서
현장실사(예시)	• 재해복구 모의훈련 계획서 확인 • 재해복구 모의훈련 결과보고서 확인

4.8.2 중계전문기관 업무 관련 정보의 안전한 백업 및 복구 방안(소산 포함)

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관 업무 관련 정보의 안전한 관리를 위해 백업 및 복구를 체계적으로 수행할 수 있는 절차를 마련하여 백업 및 복구 시스템을 구축하고 물리적으로 떨어진 장소에 백업데이터를 소산하여 관리하여야 한다.
주요 준비사항	① 중계 관련 시스템에서 처리하는 정보에 대한 백업·복구 및 소산을 위한 시스템을 갖추고 있는가? ② 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구절차를 수립·이행하고 있는가?(소산 포함)
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템에서 처리하는 정보에 대한 백업·복구 및 소산을 위한 시스템을 갖추고 있는가?

■ 세부 설명

- 중계 관련 시스템에서 처리하는 정보의 백업 및 복구를 위한 시스템을 갖추어야 한다.
 - 중계 관련 시스템에서 처리하는 정보의 백업 및 복구를 위한 시스템 구축 및 운영
- 저장된 백업 정보에 대하여 물리적으로 떨어진 장소에 소산할 수 있는 설비 등을 갖추어야 한다.
 - 재난·재해에 대처할 수 있도록 백업매체를 물리적으로 떨어진 장소에서 소산 여부(동일한 구역 내 소산 백업 인정불가)
 - 원격 소산 백업에 대한 주기 및 소산 백업 대상 선정 기준 마련

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 중계 관련 시스템에서 처리하는 정보에 대한 백업 및 복구 시스템 현황 • 소산 시설 및 시스템 현황
현장실사(예시)	• 백업 및 복구시스템의 정상 작동여부 확인 • 소산 관리 여부 (소산 백업 대장, 소산 백업 매체 반출입 일자 등)

■ 미흡 사례

사례 1	• 전송요구 관련 DBMS를 비롯하여 백업 대상이 실제로 백업이 수행되지 않는 경우
사례 2	• 소산 백업 장소가 물리적으로 멀리 떨어진 장소가 아닌 전송요구 관련 정보처리시스템이 위치한 곳과 동일한 위치일 경우

준비사항

② 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구절차를 수립 · 이행하고 있는가?

■ 세부 설명

- IT 재해, 장애, 침해사고 등 발생 시 적시에 복구하기 위해 백업 및 복구절차를 수립하고 백업담당자 및 책임자를 지정하여 체계적으로 관리하여야 한다.
 - 백업대상(서버 이미지, DB 데이터, 보안로그 등) 선정
 - 백업대상별 백업 주기 및 보존기한 정의
 - 백업 담당자 및 책임자 지정
 - 백업 방법 및 절차 : 백업시스템 활용, 매뉴얼 방식 등(백업매체 관리 포함)
 - 복구 절차
 - 백업이력관리(백업 관리 대장)
 - 백업 소산에 대한 물리적·지역적 사항 고려
 - 백업 사이트 구축 및 운영 정책
 - 백업 대상은 대상 정보 및 시스템의 중요도를 고려하여 선정하여야 하며 정해진 절차에 따라 백업관리를 수행하여야 한다.
 - 주기적으로 백업이력 등을 검토하고 복구 테스트를 통해 정확성과 무결성을 점검한다.
 - 복구절차는 복구 테스트 과정을 통하여 적시에 복구가 가능한 절차를 포함하여야 한다.
 - 복구테스트 계획 및 시나리오 수립
 - 복구테스트 실시 및 결과보고서 보고 절차
 - 복구테스트 결과에 따른 테스트 개선계획 마련
- ※ 중계 관련 시스템이 운영되기 이전에 백업 및 복구 대상이 없으므로 지침 또는 절차서로 대체

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 백업 및 복구 절차서 • 백업 관리 대장 • 복구테스트 실시 내역 및 결과보고서 • 백업 현황
현장실사(예시)	• 백업 대상, 주기, 방법, 절차 등이 포함된 백업 및 복구절차를 수립하고 있는지 확인 • 백업 및 복구절차에 따라 백업이 수행되고 있는지 확인 • 복구 테스트를 수행하고 있으며, 복구테스트 결과에 따라 필요 시 백업 및 복구 절차를 개선하고 있는지 확인

■ 미흡 사례

사례 1	• 백업 절차 수립되어 있으나 백업 담당자 및 책임자, 백업매체 관리 절차, 백업 복구절차 등 중요 내용이 누락되어 있는 경우
사례 2	• 복구 테스트 결과 현재의 백업 방법이 복구 목표시간을 준수하지 못하는 것으로 확인되었으나, 이에 따른 후속 조치 방안(백업 방법 개선 등)이 마련되어 있지 않은 경우

4.9 출력복사 시 안전조치

4.9.1 개인정보, 전송요구서 등을 안전하게 이용·관리하기 위한 출력복사 시 안전조치 방안

4.9.1.1 개인정보 출력시(인쇄, 화면표시, 파일생성 등) 용도의 특정 및 출력 항목 최소화

세부 지정요건 및 주요 확인사항	
주요내용	개인정보, 전송요구서 등을 안전하게 이용·관리하기 위해 시스템 화면, 종이 인쇄물 등 출력 항목을 최소화하고 출력·복사물을 안전하게 관리할 수 있도록 하여야 한다.
주요 준비사항	① 시스템에서 개인정보의 출력 시(인쇄, 화면표시, 파일생성 등) 용도를 특정 하여야 하며, 용도에 따라 출력 항목을 최소화하고 있는가? ② 개인정보가 포함된 종이인쇄물, 개인정보가 복사된 외부저장 매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

- ① 시스템에서 개인정보의 출력 시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하고 있는가?

■ 세부 설명

- 개인정보를 출력(인쇄, 화면표시, 파일생성 등)할 때에는 아래와 같은 사항 등을 고려하여 용도를 특정하고, 용도에 따라 출력 항목을 최소화하여야 한다.
 - 시스템에서 개인정보 및 중요정보 출력 시(인쇄, 화면표시, 파일생성 등) 용도를 특정하고 용도에 따라 출력항목 최소화
 - 업무 수행 형태 및 목적, 유형, 장소 등 여건 및 환경에 따라 시스템에 대한 접근 권한 범위 내에서 최소한의 개인정보를 출력
 - 업무상 반드시 필요한 경우가 아니라면 개인정보 검색 시 Like 검색이 되지 않도록 조치
 - 개인정보 검색 시에는 불필요하거나 과도한 정보가 조회되지 않도록 일치검색(equal 검색) 또는 두 가지 항목 이상의 검색조건 사용 등
 - 웹페이지 소스 보기 등을 통하여 불필요한 개인정보가 출력되지 않도록 조치 등
- 용도에 따라 개인정보의 출력항목을 최소화하는 방법으로는 아래와 같은 방법을 활용할 수 있다.
 - 개인정보 출력(인쇄, 화면표시, 파일생성 등) 시 접근 권한에 따라 출력 항목을 다르게 하는 방법
 - 개인정보 출력 시 업무상 반드시 조회할 필요가 없는 개인정보 항목에 대해 표시제한 조치(마스킹 등)를 적용하는 방법
 - ※ 표시제한 조치(마스킹 등)를 적용하는 경우, 개인정보 항목별 기준을 수립하여 일관성 있게 적용할 필요가 있음
 - 주민등록번호 뒷자리 등 중요 개인정보 항목은 출력 시 기본적으로 마스킹을 적용하고, 업무상 조회가 필요한 경우 승인 절차 또는 접근 권한에 따라 마스킹을 해제할 수 있도록 하는 방법
 - 개인정보를 다운로드 시 업무에 필요한 최소한의 개인정보만 다운로드 받도록 하거나 개인정보 일부를 마스킹처리하여 다운로드 받도록 하는 방법

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 시스템 개인정보 조회, 검색 기능 • 개인정보 마스킹 적용 기능 • 출력·복사물 보호조치 현황
현장실사(예시)	• 시스템 개인정보 조회, 검색 기능 실사 • 개인정보 마스킹 적용 기능 실사 • 개인정보가 포함된 매체 출력 시 보호조치(복합기 보안, 출력물 워터마크 등 출력·복사물 보안기술 적용 등) 현황 확인

■ 미흡 사례

사례 1	• 개인정보 표시제한 조치 기준이 마련되어 있지 않거나 이를 준수하지 않는 등의 사유로 동일한 개인정보 항목에 대하여 개인정보처리시스템 화면별로 서로 다른 마스킹 기준이 적용된 경우
사례 2	• 개인정보처리시스템의 화면상에는 개인정보가 마스킹되어 표시되어 있으나, 웹브라우저 소스 보기를 통하여 마스킹되지 않은 전체 개인정보가 노출되는 경우

준비사항

- ② 개인정보가 포함된 종이인쇄물, 개인정보가 복사된 외부저장 매체 등 개인정보의 출력·복사물을 안전하게 관리하기 위해 필요한 안전조치를 하고 있는가?

■ 세부 설명

- 개인정보가 포함된 종이 인쇄물 등 개인정보의 출력·복사물을 통한 개인정보의 분실·도난·유출 등을 방지하고 출력·복사물을 안전하게 관리하기 위하여 필요한 보호조치를 하여야 한다.

※ 출력·복사물 보호조치에 관한 예시는 아래 내용 참조

- 출력·복사물 보호 및 관리 정책, 규정, 지침 등 마련
- 출력·복사물 생산·관리 대장 마련 및 기록
- 출력·복사물 운영·관리 부서 지정 및 운영
- 출력·복사물 외부반출 및 재생산 통제·신고·제한
- 인쇄자, 인쇄일시 등 출력·복사물 기록 저장·관리
- 종이 인쇄물에 대한 파기 절차, 파기여부 확인 등을 포함하는 파기계획 수립 및 주기적 점검
- 복합기 보안, 출력물 워터마크 등 출력·복사물 보안기술 적용 등

- 개인정보의 출력·복사물을 통해 업무를 수행하는 처리부서 및 업무 환경에 대하여 주기적으로 점검 하여야 한다.
 - 출력·복사물의 시건장치된 안전한 곳에 보관여부
 - 출력·복사물 관리 대장 및 기록에 따른 적절한 관리 여부
 - 출력·복사물의 파기 계획에 따라 파기 수행 여부 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 출력·복사물 보호조치 현황
현장실사(예시)	• 출력·복사물 보호조치 현황 실사

■ 미흡 사례

사례 1	• 개인정보가 포함된 서류를 잠금장치가 없는 사무실 문서함에 보관한 경우
------	--

4.10 파기

4.10.1 정보의 안전한 파기를 위한 조치

4.10.1.1 데이터가 복구 또는 재생되지 않도록 파기하는 등 조치

세부 지정요건 및 주요 확인사항	
주요내용	전문기관 업무 관련 정보에 대하여 보유기간 경과, 처리목적이 달성할 경우 지체없이 파기하고 전문기관 관리책임자에게 보고하여 관리가 되도록 하여야 한다.
주요 준비사항	① 전송받은 정보의 목적이 달성되거나 보유기간이 경과한 경우에는 파기하고 있는가? ② 파기 내역을 주기적으로 검토하고 책임자에게 보고하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 전송받은 정보의 목적이 달성되거나 보유기간이 경과한 경우에는 파기하고 있는가?

■ 세부 설명

- 중계 관련 시스템 설계 상에 개인정보 등 파기에 대한 기준 및 로직에 따라 자동으로 파기가 되도록하거나 관리자 등이 파기할 수 있는 기능을 통해 파기가 되도록 하여야 한다.
 - 전송요구 철회 요청 시 전송요구서, 접근 토큰 등 폐기 수행
 - 전송 내역 정보는 3년간 보관 후 파기 수행
 - 이외에 불필요하게 된 정보(개인정보 포함)에 대하여 파기 수행
- ※ 중계 관련 시스템이 운영되기 이전에 파기대상이 없는 경우는 파기 로직 및 파기 계획서로 대체
- 처리 목적 달성, 전송요구 철회 시, 서비스 종료, 법령에 따른 보존기관 경과(예, 전송 내역 3년) 등 정보(개인정보 포함)가 불필요하게 되었을 때에는 정당한 사유가 없는 한 지체없이 파기하여야 한다.
 - 개인정보처리시스템에 보관된 데이터베이스, 백업데이터, 전자파일 및 출력·복사물을 모두 포함하여 파기 수행
- 파기할 때에는 복구·재생되지 않도록 안전한 방법으로 파기하여야 한다.
 - ※ 복원이 불가능한 방법이란 현재의 기술수준에서 사회통념상 적절한 비용으로 파기한 개인정보의 복원이 불가능하도록 조치하는 방법을 말한다.
 - 완전파괴(소각, 파쇄 등)
 - 전용 소자장비(자기장을 이용해 저장장치의 테이터를 삭제하는 장비)를 이용하여 삭제
 - 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행
- 개인정보 중 보유기간이 경과한 일부 개인정보를 파기하는 경우 복구 또는 재생되지 아니하도록 개인정보가 저장된 매체 형태에 따라 보호조치를 하여야 한다.
 - 전자적 파일 형태인 경우는 개인정보를 삭제한 후 복구 및 재생되지 않도록 관리·감독 수행
 - 전자적 파일 형태 이외의 기록물, 서면, 그 밖의 기록매체인 경우는 해당 부분을 마스킹, 구멍 뚫기 등으로 삭제
- 기술적 특성으로 인하여 위의 방법으로 파기하는 것이 현저히 곤란한 경우에는 개인정보 보호법 제58조의2에 해당하는 정보로 처리(익명처리)하여 개인정보가 복원이 불가능하도록 조치하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 파기 계획서 • 파기 결과(데이터베이스 등) • 파기 관리대장
현장실사(예시)	• 파기 계획서에 작성된 파기 대상별 파기 수행 확인 • 파기 결과(데이터베이스 등) 실사 • 파기 관리대장 확인

■ 미흡 사례

사례 1	• 보유기간이 경과 된 후에도 파기하지 않고 보관하고 있는 경우
사례 2	• DB에 저장된 개인정보 파기 수행 시 개인정보에 해당하는 식별정보에 대하여 일부를 마스킹처리 하여 파기를 수행한 경우

준비사항

② 파기 내역을 주기적으로 검토하고 책임자에게 보고하고 있는가?

■ 세부 설명

- 파기 계획에 따라 파기가 제대로 수행되고 있는지 주기적으로 검토하고 책임자에게 보고하여야 한다.
 - 파기에 대한 기록을 남기고 관리하여야 한다.
 - 파기의 시행 및 파기 결과의 확인은 책임자의 책임하에 수행되어야 하며, 파기에 관한 사항을 기록·관리
 - 파기에 대한 기록은 파기 관리대장에 기록하거나 파기 내용을 담은 사진 등을 기록물로 보관
- ※ 중계 관련 시스템이 운영되기 이전에 파기대상이 없는 경우는 파기 계획서로 대체

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 파기 계획서 • 파기 대장 또는 파기 이력 • 파기 이력 검토 절차 • 주기적 파기 이력 검토 내역(책임자 승인 포함)
현장실사(예시)	• 파기 계획서 적정성 확인 • 파기 대장 또는 파기 이력 확인 • 파기 점검 결과 확인

■ 미흡 사례

사례 1	• 파기가 제대로 수행되고 있는지 점검하지 않고 책임자에게 보고하지 않는 경우
------	---

4.11 그 밖에 필요한 조치

4.11.1 중계 관련 시스템 가용성 및 연속성 보장을 위한 주요 지표 마련 및 관리 방안

세부 지정요건 및 주요 확인사항	
주요내용	시스템 장애 발생 시 즉시 대처할 수 있는 절차를 수립하여 운영하도록 하고 시스템의 성능 및 용량에 관하여 지속적인 모니터링을 수행하여 시스템 가용성·연속성 보장을 위해 서비스 장애가 발생하지 않도록 적절한 보호조치를 하여야 한다.
주요 준비사항	① 시스템 장애를 즉시 인지하고 대응하기 위한 절차를 수립·이행하고 있는가? ② 장애 발생 시 절차에 따라 조치하고 장애 조치보고서 등을 통해 기록·관리하고 재발방지 대책을 마련하고 있는가? ③ 시스템의 성능 및 용량을 지속적으로 모니터링하기 위한 절차를 수립·이행하고 있는가? ④ 시스템 성능 및 용량 요구사항(임계치)을 초과하는 경우에 대한 조치 절차를 수립·이행하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 시스템 장애를 즉시 인지하고 대응하기 위한 절차를 수립·이행하고 있는가?

■ 세부 설명

- 중계 관련 시스템 장애를 즉시 인지하고 대응하기 위한 절차를 수립·이행하여야 한다.
 - 장애 대응 절차는 매년 정기적으로 점검하고 필요 시 업데이트
- 장애 대응절차는 발생 가능한 장애의 유형과 장애의 심각도에 따라 체계적으로 대응할 수 있도록 아래의 내용을 포함하여 작성하여야 한다.
 - 장애 유형 및 심각도 정의
 - 장애 유형 및 심각도별 보고절차 (재발방지 대책 포함)
 - 장애 유형별 탐지 방법 수립 : NMS 등 관리시스템 활용
 - 장애 대응 및 복구에 관한 책임과 역할 정의
 - 장애 유형별 대응 및 복구절차
 - 장애 기록 및 분석
 - 데이터 백업 및 복구 절차
 - 장애에 따른 관계 기관 및 이용기관 통지 절차
 - 비상연락체계(유지보수업체, 정보시스템 제조사) 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료	• 장애대응 절차 • 장애보고 양식 • (해당되는 경우) 장애보고 내역
현장실사	• 장애대응 절차가 필요한 사항을 포함하여 적절하게 수립되어 있는지 확인 • 장애보고 절차 내에 통지범위, 대상, 방법, 내용 등의 사항이 적절히 마련되어 있는지 확인

■ 미흡 사례

사례 1	• 장애 대응절차를 수립하고 있으나 장애유형 및 심각도, 장애 대응 및 복구에 관한 책임과 역할 정의, 보고 절차, 장애 유형별 조치 절차, 장애 탐지 방법 등 일부 내용이 장애 대응절차에서 누락되어 있는 경우
사례 2	• 장애 발생 시 비상연락망에 따라 장애 대응 담당자에게 연락하도록 하고 있으나 장애 대응 담당자 연락처에 보직 이동자나 퇴사자 정보가 남아 있는 등 현행화 되지 않은 경우

준비사항

② 장애 발생 시 절차에 따라 조치하고 장애 조치보고서 등을 통해 기록·관리하고 재발방지 대책을 마련하고 있는가?

■ 세부 설명

- 장애 발생 시 장애대응 절차에 따라 해당 서비스의 장애를 신속히 조치하여야 한다.
 - 장애 처리 완료 후 다음의 내용이 포함된 장애조치 보고서를 작성하고 이력을 관리하여야 한다.
 - 장애일시
 - 장애 유형 및 심각도 (예 : 상, 중, 하)
 - 담당자, 책임자명 (유지보수업체 포함)
 - 장애 내용 (장애로 인한 피해 또는 영향 포함)
 - 장애 원인
 - 조치 내용
 - 복구내용
 - 재발방지대책 등
- ※ 중계 관련 시스템이 운영되기 이전에 장애발생이 없으므로 장애대응 처리 절차 또는 계획서 등으로 대체
- 장애 복구를 완료한 이후 동일한 장애가 반복적으로 발생하지 않도록 재발방지대책을 수립·이행하여야 한다.
 - 심각도가 높은 장애의 원인을 분석하여 원인을 제거하거나 회피수단을 강구하여 재발방지대책을 마련
 - 재발방지대책이 수립되면 해당 내용을 장애가 발생한 서비스를 운영하는 이해관계자 등에게 교육, 통지 등 수행
 - 재발방지대책이 장애 조치보고서에 포함된 경우 장애 조치보고서로 증적 대체 가능
 - 장애를 조치하는 동안 적용된 절차가 부적절할 경우 장애 대응절차 변경
 - 기존 절차에 포함되어 있지 않거나, 현실적인 내용과 다른 경우 장애분석을 통해 개선된 사항을 반영하여 지침·절차를 개정

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 장애대응 절차 • 장애관리 대장 • 장애조치 보고서 • 장애 재발방지 대책
현장실사(예시)	• 장애 발생시 장애대응 절차에 따라 조치를 하고 있는지 확인 • 장애 발생 및 조치 시 장애조치 보고서를 적절하게 작성하여 보고하고 있는지 확인 • 심각도가 높은 장애의 경우 원인분석을 통한 재발방지 대책을 수립·이행하고 있는지 확인

■ 미흡 사례

사례 1	• 장애 발생시 장애 대응 조치를 하고 있으나, 내부 절차에서 규정한 장애조치 보고서를 작성하고 있지 않은 경우
사례 2	• 장애 대응절차에 따라 장애 대응 중 부적절한 절차를 발견하였으나 장애 처리 후 개선하지 않은 경우

준비사항

③ 시스템의 성능 및 용량을 지속적으로 모니터링하기 위한 절차를 수립·이행하고 있는가?

■ 세부 설명

- 중계서비스 및 관련 업무의 연속성을 보장하기 위해 시스템의 성능 및 용량을 지속적으로 모니터링하기 위한 절차를 수립·이행하여야 한다.
 - 성능 및 용량 관리가 필요한 대상을 식별
 - 식별된 관리대상의 네트워크 대역폭, HW 요구사항(CPU, MEM, HDD, NIC 등) 등의 임계치 정의
 - 모니터링 방법 수립
 - 설정된 임계치에 따라 모니터링 결과 기록 및 보고
 - 성능 및 용량 관리를 담당하는 담당자 및 책임자 등의 지정

■ 증거자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증거자료(예시)	• 성능 및 용량 모니터링 대상 • 성능 및 용량 모니터링 절차서
현장실사(예시)	• 성능 및 용량 관리가 필요한 대상이 구체적으로 식별되어 있는지 확인 • 성능 및 용량 모니터링 방법을 포함한 성능 및 용량 모니터링 절차가 적절하게 수립·이행되고 있는지 확인

■ 미흡 사례

사례 1	• 성능 및 용량 모니터링 절차를 수립하였으나 시스템의 성능 및 용량 모니터링을 수행하지 않는 경우
사례 2	• 성능 및 용량 모니터링 대상을 식별하였으나, 시스템 가용성에 영향을 미칠 수 있는 일부 장비가 모니터링 대상에서 제외된 경우

준비사항

④ 시스템 성능 및 용량 요구사항(임계치)을 초과하는 경우에 대한 조치 절차를 수립·이행하고 있는가?

■ 세부 설명

- 시스템 성능 및 용량 관련 정의된 임계치 초과 시 신속하게 대응할 수 있도록 조치 절차를 수립·이행하여야 한다.
 - 중계시스템의 성능 및 용량을 지속적으로 모니터링
 - 임계치 초과 시 조치 절차 또는 방안을 수립 및 이행
 - 조치 방안으로는 정보시스템, 메모리, 저장장치, 회선, 네트워크 대역폭, 가상자원 증설 등이 있을 수 있음

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 모니터링 대상 및 임계치 현황 • 임계치 초과 시 조치 절차
현장실사(예시)	• 시스템 성능 및 용량 관련 정의된 임계치 초과 시에 대한 조치 절차가 마련되어 있는지 확인 • 시스템 성능 및 용량 관련 정의된 임계치 초과 시 조치 절차에 따라 조치가 수행되고 있는지 확인

■ 미흡 사례

사례 1	• 중계서비스 관련 시스템의 성능 및 용량 모니터링 절차를 수립하였으나 성능 및 용량 요구사항(임계치) 초과 시 관련 검토 및 후속 조치방안이 수립·이행되고 있지 않은 경우
------	--

4.11.2 중계 관련 시스템 정비 및 프로그램 변경·이행 절차

세부 지정요건 및 주요 확인사항	
주요내용	중계 서비스의 안정적인 운영을 위한 주요 시스템 정비 및 프로그램 변경·이행 절차를 마련하여 체계적으로 운영하여야 한다.
주요 준비사항	① 중계 관련 시스템 정비 및 프로그램 변경·이행 절차 마련하고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계 관련 시스템 정비 및 프로그램 변경·이행 절차 마련하고 있는가?

■ 세부 설명

- 중계서비스의 안정적인 운영을 위한 주요 시스템 정비 절차를 수립·이행하여야 한다.
 - 시스템별 정비 주기, 시점, 범위, 방법 등 시스템 정비 계획 수립
 - 정비 업체 및 담당자 연락처 현행화 관리
 - 주요 시스템에 대한 SLA(Service Level Agreement) 설정 등
- 정보시스템 관련 자산(하드웨어, 운영체제, 상용 소프트웨어, 응용프로그램 등) 변경에 관한 절차를 수립·이행하여야 한다.
 - 운영체제 업그레이드, 상용 소프트웨어 설치, 운영 중인 응용프로그램 기능 개선, 네트워크 구성 변경, CPU·메모리·저장장치 증설 등 정보시스템 관련 자산 변경이 필요한 경우 변경을 위한 공식적인 절차 수립 및 이행
- 변경 절차에는 다음의 사항이 포함되어야 한다.
 - 변경 요청
 - 책임자 검토 및 승인
 - 변경 작업 공지(내·외부 관련자 및 관련 기관)
 - 변경 확인 및 검증
 - 관련 문서 식별 및 변경(자산목록, 운영 매뉴얼, 구성도 등)
 - 변경 이력관리 등
- 정보시스템 관련 자산 변경을 수행하기 전 성능 및 보안에 미치는 영향을 분석하여야 한다.
 - 정보시스템 관련 정보자산 변경이 필요한 경우 변경에 따른 보안, 성능, 업무 등에 미치는 영향을 분석(방화벽 등 보안시스템 정책 변경 필요성, 정책 변경 시 문제점 및 영향도 등)
 - 변경 전 테스트 수행
 - 변경에 따른 영향을 최소화할 수 있도록 변경을 이행
 - 변경 실패에 따른 복구방안을 사전에 고려

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 변경관리 절차 • 변경관리 수행 내역(승인·신청, 변경 내역 등) • 변경에 따른 영향분석 결과
현장실사(예시)	• 중계서비스 관련 주요 시스템의 정비 절차가 적절히 수립되어 있으며, 이에 따라 정비가 수행되고 있는지 확인 • 정보시스템 관련 자산(하드웨어, 운영체제, 상용 소프트웨어, 응용프로그램 등) 변경에 관한 절차가 필요한 사항을 모두 포함하여 적절히 수립되어 있는지 확인 • 정보시스템 관련 자산 변경을 수행하기 전 성능 및 보안에 미치는 영향을 분석하는 등 변경관리 절차에 따라 변경이 수행되고 있는지 확인

■ 미흡 사례

사례 1	• 자산 변경절차가 마련되어 있어 변경 전 영향분석 및 변경 실패 시 복구방안을 마련하여야 하나 담당자가 복구방안을 마련하지 않고 네트워크 장비 교체 작업을 수행한 경우
사례 2	• 자산관리시스템을 구축하여 정보시스템 입고 또는 변경 시 성능 및 보안에 미치는 영향을 분석·협의하고 관련 이력을 관리하도록 하고 있으나, 해당 시스템을 통하지 않고도 시스템 변경이 가능하며, 관련 변경사항이 적절히 검토되지 않는 경우

4.11.3 중계전문기관의 안정적 운영을 위한 전담조직 및 담당인력 지정

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관의 안정적 운영을 위해 전담조직을 구성하여 담당인력의 역할 및 책임을 부여하여 체계적으로 업무를 수행할 수 있도록 하여야 한다. 또한, 관리책임자는 개인정보보호 및 정보보호 분야의 전문성을 갖춘자로 지정하고 담당인력은 업무별 전문성을 갖춘인력으로 지정하여 운영하여야 한다.
주요 준비사항	① 중계전문기관 운영을 위한 전담조직이 구성되어 있는가? ② 관리책임자는 전문성을 갖춘자로 지정하고 있는가? ③ 담당인력의 업무별 역할과 책임을 적절히 부여하고 있는가? ④ 담당인력이 담당업무별로 요구되는 전문성을 갖추고 있는가?
관련 규정	개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 중계전문기관 운영을 위한 전담조직이 구성되어 있는가?

■ 세부 설명

- 중계전문기관 운영을 전문적이고 체계적으로 수행하기 위한 전담조직이 구성되어 있어야 한다.
 - 조직 구성 인원은 중계전문기관 운영 업무를 전담으로 수행해야 함
 - 조직 구성은 중계전문기관의 업무를 실무적으로 수행할 수 있도록 시스템(서버, DB 등) 운영 및 관리, 개인정보 보호 및 정보보호 이슈 관리, 기타 행정업무 등 업무 특성을 고려하여 구성
 - ※ 기관(기업)의 공통설비(네트워크 장비, 보안시스템 등) 운영자는 조직 내 전담 부서의 조력을 받을 수 있음
- 전담조직에 관한 업무가 직무기술서 등에 적정하게 정의되어 있어야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 조직도 • 인사명령 • 직무기술서 • 중계전문기관 운영 정책·지침
현장실사(예시)	• 조직도 대로 조직구성이 되어 있는지 확인 • 조직도 내 구성된 인력에 대해 인사발령이 되었는지와 해당 인력이 맞는지 여부 확인

준비사항

② 관리책임자는 전문성을 갖춘자로 지정하고 있는가?

■ 세부 설명

- 중계전문기관 운영에 대하여 총괄적으로 책임지는 관리책임자를 공식적으로 지정하여야 한다.
- 관리책임자가 업무를 구체적으로 수행할 수 있도록 직무기술서 등을 통하여 책임 및 역할을 구체적으로 정의하여야 한다.
- 관리책임자는 정보기술, 정보보호 또는 개인정보보호 분야에 대한 전문성을 갖춘자로 지정하여야 한다.
 - 운영하는 시스템에 대한 기술적 보호조치 등 정보기술 또는 정보보호에 대한 전문성 필요
 - 중계전문기관에서 처리정보 등 개인정보 보호에 대한 전문성 필요
- 정보기술, 정보보호 또는 개인정보보호 분야 전문성을 입증할 수 있는 증빙자료(예, 학위, 경력증명, 자격증 등)를 제시할 수 있어야 함
- 관련 법령의 개정, 신규 보안 위협 등 내·외부 환경에 대한 신속한 대응을 위해 내·외부 교육 등에 참여하여 전문성 유지하여야 함

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 조직도 • 관리책임자 인사명령 • 직무기술서 • 중계전문기관 운영 정책·지침 • 정보기술, 정보보호 또는 개인정보보호 관련 학위 • 자격증, 경력증명서 • 교육 수료증 또는 참석확인서
현장실사(예시)	• 조직도 내 구성된 관리책임자에 대해 인사발령이 되었는지와 해당 인력이 맞는지 여부 확인 • 증적자료의 사실관계 확인 • 관리책임자의 인터뷰를 통한 전문성 확인

■ 미흡 사례

사례 1	• 관리책임자가 중계전문기관 운영 정책·지침이나 직무기술서 등에 구체적으로 명시되어 있지 않는 경우
------	---

준비사항

③ 담당인력의 업무별 역할과 책임을 적절하게 부여하고 있는가?

■ 세부 설명

- 담당인력의 업무를 실무적으로 수행할 수 있도록 직무기술서 등을 통하여 역할과 책임을 구체적으로 정의하여야 한다.
 - 시스템 운영 및 관리 담당, 보안 담당, 행정업무 담당 인력 등 각각에 대한 직무기술서 등 정의
- 권한 오남용 등으로 인한 잠재적인 피해 예방을 위하여 1명의 담당인력이 다수의 업무 수행하지 않도록 직무분리를 하도록 한다.
 - 정보보호시스템 및 개인정보처리시스템(서버, DB 등) 간 운영직무 분리
 - 보안담당자와 시스템 운영자와의 직무 분리

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 조직도 • 직무기술서 • 업무 분장표
현장실사(예시)	• 조직도, 직무기술서, 업무분장표 등을 확인하여 담당업무별로 구체적으로 역할과 책임이 부여되어 있는지 확인

■ 미흡 사례

사례 1	• 업무 편의성만을 사유로 내부 규정으로 정한 직무 분리 기준을 준수하고 있지 않은 경우
------	---

준비사항

④ 담당인력이 담당업무별로 요구되는 전문성을 갖추고 있는가?

■ 세부 설명

- 담당인력이 담당업무별로 요구되는 전문성을 갖춘자로 운영하여야 한다.
 - 서버 및 데이터베이스 운영 업무 담당인력의 경우 시스템 운영에 따른 기술적 보호조치 사항에 대한 전문성 필요
 - 보안 업무 담당인력의 경우 정보보호 및 개인정보 보호에 대한 전문성 필요
- 담당인력의 전문성을 입증할 수 있는 증빙자료(예, 학위, 경력증명, 자격증 등)를 제시할 수 있어야 한다.
- 관련 법령의 개정, 신규 보안 위협 등 내·외부 환경에 대한 신속한 대응을 위해 내·외부 교육 등에 참여하여 전문성 유지하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 담당업무와 관련 학위 • 자격증, 경력증명서 • 교육 수료증 또는 참석확인서
현장실사(예시)	• 증적자료의 사실관계 확인

■ 미흡 사례

사례 1	• 보안담당자의 경우 정보보호 및 개인정보보호 관련 전문성이 없는 인원으로 구성된 경우
------	--

5 재정능력

5.1 자본금 규모, 재무구조 건전 및 안전성

세부 지정요건 및 주요 확인사항	
주요내용	중계전문기관은 자본금(법인의 경우에는 납입자본금(비영리법인의 경우에는 기본재산) 10억 이상의 재정능력을 갖추어야 하고, 재무구조가 건전하고 안전성이 있어야 한다.
주요 준비사항	① 최근 3년간 재무구조가 건전하고 안전성이 있는가? ② 자본금 10억 이상의 재정능력을 갖추고 있는가?
관련 규정	개인정보 보호법 시행령 제42조의11(개인정보관리 전문기관의 지정요건 세부기준) 개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시

준비사항

① 최근 3년간 재무구조가 건전하고 안전성이 있는가?

■ 세부 설명

- 최근 3년간의 재무구조의 건정성 및 안전성을 입증할 수 있는 자료를 제출하여야 한다.
 - 최근 3년간의 재무 제표
 - 신용평가등급확인서 등

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 최근 3년간의 재무제표 • 신용평가등급확인서 등

준비사항

② 자본금 10억 이상의 재정능력을 갖추고 있는가?

■ 세부 설명

- 자본금 10억 이상으로 재정능력을 갖추어야 하고 자본금을 확인할 수 있는 자료를 제출하여야 한다.
 - 법인의 경우에는 납입자본금을 말함
 - 비영리법인의 경우에는 기본재산을 말함
 - 법인이 아닌 단체의 경우에는 해당 단체가 보유하는 자산의 가액을 말함

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	• 자본금납입증명서 • 재무제표 등

5.2 보험 또는 공제 가입

세부 지정요건 및 주요 확인사항	
주요내용	손해배상책임의 이행을 위하여 최저가입금액 10억원 이상의 보험 또는 공제에 가입하거나 준비금을 적립하여야 한다 (다만, 제42조의11제2항제2호 또는 제3호에 해당(중앙행정기관 또는 지방자치단체, 그 외 공공기관)하는 경우는 별표 1의4에 따른 최저가입금액(최소적립금액)으로 한다.)
주요 준비사항	① 최저가입금액 10억원 이상의 보험 또는 공제에 가입하거나 준비금이 적립되어 있는가?
관련 규정	개인정보 보호법 시행령 제42조의11(개인정보관리 전문기관의 지정요건 세부기준) 및 별표 1의2

준비사항

① 최저가입금액 10억원 이상의 보험 또는 공제에 가입하거나 준비금이 적립되어 있는가?

■ 세부 설명

- 지정신청자는 손해배상책임의 이행을 위하여 최저가입금액 10억원 이상의 보험 또는 공제에 가입하거나 준비금을 적립하여야 한다.
 - 보험 또는 공제 가입과 준비금 적립을 병행하는 경우 보험 또는 공제 가입금액과 준비금 적립금액을 합산한 금액이 10억원 이상이어야 함
 - 신용정보법 등 다른 법률에 따라 가입한 보험(공제 또는 적립한 준비금)이 개인정보 보호법에 따른 손해배상책임의 이행을 보장(손해배상책임의 범위·내용을 포함·충족)하는 경우, 개인정보 보호법에 따른 손해배상 보장 조치를 이행한 것으로 인정
- 다만, 지정신청자가 아래의 <참고1>에 해당하는 경우 <참고2>의 최저가입금액 기준에 따른 보험 또는 공제에 가입하거나 준비금을 적립하여야 한다.
 - ※ 다만, 지정신청자가 보험 또는 공제 가입과 준비금 적립을 병행하는 경우에는 보험 또는 공제 가입금액과 준비금 적립금액을 합산한 금액이 <참고2>의 최저가입금액의 기준 이상이어야 함
- 준비금을 적립하는 경우에는 임의적립금(자본계정)으로 적립하고 주주총회 결의 등을 통해 해당 임의적립금이 개인정보 보호법 제39조 및 제39조의2에 의무 이행을 위한 것임을 명확히 하여야 한다.

■ 증적자료, 현장실사(담당자 인터뷰) 등 준비사항

구분	준비사항
증적자료(예시)	- 보험 또는 공제가입 서류 (준비금 적립 시) 준비금 적립 증빙 문서

■ 미흡 사례

사례 1	• 개인정보보호 관련 사이버 보험에 가입하였으나, 보장금액이 10억원 미만인 경우
사례 2	• 신용정보법에 따라 손해배상보장 보험을 가입하였으나, 배상범위에 신용정보법에 따른 손해 배상만 명시되어 있고 개인정보 보호법에 따른 손해배상 여부는 불명확한 경우

참고 | 개인정보관리 전문기관 지정을 위한 보험 또는 공제 기준

〈참고 1〉

- 「의료법」 제3조에 따른 의료기관(시행령 제42조의4제2항제1호의 정보를 전송받는 경우에 한함)
- 중앙행정기관 또는 지방자치단체
- 법 제2조제6호에 따른 공공기관(단, 제2호의 자는 제외)

〈참고 2〉

가입대상개인정보처리자의 가입금액 산정요소		최저가입금액 (최소적립금액)
정보주체 수	매출액등	
100만명 이상	800억원 초과	10억원
	50억원 초과 800억원 이하	5억원
	10억원 이상 50억원 이하	2억원
10만명 이상 100만명 미만	800억원 초과	5억원
	50억원 초과 800억원 이하	2억원
	10억원 이상 50억원 이하	1억원
1만명 이상 10만명 미만	800억원 초과	2억원
	50억원 초과 800억원 이하	1억원
	10억원 이상 50억원 이하	5천만원

IV

부 록

중계전문기관 지정 Q&A

FAQ 일반

Q1 | 개인정보관리 전문기관이 결합전문기관의 기능을 동시에 병행할 수 있나요?

답변 : 개인정보관리 전문기관은 결합전문기관 업무를 동시에 병행할 수 있습니다. 다만, 개인정보관리 전문기관으로서 처리하는 정보와 결합전문기관으로서 처리하는 정보는 분리하여 보관하여야 합니다.(개인정보 보호법 시행령 제42조의6제9항)

Q2 | 관리·감독을 통해 개인정보관리 전문기관지정 취소가 된 경우, 해당 개인정보관리 전문기관은 재지정신청을 할 수 없나요?

답변 : 지정취소가 된 경우 개인정보관리 전문기관 지정요건을 다시 갖추어 개인정보관리 전문기관 지정을 받을 수 있습니다.

Q3 | 중계전문기관은 중계 관련 정보를 보관할 수 있나요?

답변 : 중계전문기관은 중계전문기관 업무와 관련하여 필요한 경우가 아니면 중계 관련 정보를 보관할 수 없습니다.

FAQ 지정절차

Q1 | 예비심사와 본지정의 차이는 무엇인가요?

답변 : 예비심사는 본지정 심사 전 사업계획, 개인정보관리계획, 법 제35조의3제2항에 따른 지정요건 충족하기 위한 이행·관리 계획에 대해 확인을 받는 절차에 해당합니다. 본 지정 심사 시 시설 및 기술 요건 등을 모두 갖추어 심사를 받아야 하므로 지정이 되지 않을 경우 설비 및 비용 투자에 대한 손실이 있을 수 있어, 예비심사를 통해 기관의 본 지정 심사 전 기관의 역량 및 지정 요건들에 대해 검토를 받아 매몰 비용 발생 등을 방지할 수 있습니다.

Q2 | 예비심사를 받은 경우 본 지정 시 예비지정 때 제출한 서류를 제출해야 하나요?

답변 : 본 지정 심사 시 예비심사를 위해 제출한 서류는 추가로 제출하지 않아도 됩니다. 다만, 고시 별표2에 규정된 서류 중 예비심사 때 제출한 내용과 변동이 있는 경우 서류를 추가로 제출하여야 합니다.

Q3 | 개인정보관리 전문기관 지정이 되지 않으면 신청기관은 해당 내용을 개선해 다시 신청할 수 있나요?

답변 : 개인정보관리 전문기관 지정이 되지 않으면 신청기관은 해당 내용을 개선하여 다시 신청할 수 있습니다.

Q4 | 지청 신청 후 심사 완료되어 지정되기까지 소요 예상 기간은 어떻게 되나요?

답변 : 지정 신청 후 지정까지는 3~5개월 정도 소요될 수 있습니다.

(개인정보 전송 및 개인정보관리 전문기관 지정 등에 관한 고시 제7조제3항)

FAQ 지정요건

Q1 | 개인정보관리 전문기관으로 지정받은 자는 개인정보 보호법 제29조에 따른 안전조치의무를 준수하여야 하나요?

답변 : 개인정보관리 전문기관으로 지정받은 자 역시 개인정보처리자에 해당하므로 개인정보 보호법 제29조에 따른 안전조치의무를 준수하여야 합니다.

Q2 | 인터넷 차단 범위 및 방법은 어떻게 되나요?

답변 : 중계전문기관의 경우는 관리용 단말기에 대하여 인터넷 접속이 불가능하도록 인터넷망 차단조치하도록 하고 있습니다.

Q3 | 개인정보관리 전문기관 업무에 필요한 전산설비는 기존 업무에 필요한 전산설비와 구분하여 별도로 구축하여 운영해야 하나요?

답변 : 개인정보관리 전문기관 업무에 필요한 전산 설비의 경우, 기존 일부 전산설비(예, 네트워크 장비, 정보보호시스템 등)는 활용은 가능하나, 보호대책 수립을 위해서 가급적 전문기관 업무에 필요한 전산 설비를 구분하여 구축하는 것을 권장합니다.

Q4 | API 호출 시 반드시 전용선(또는 VPN)을 의무적으로 사용해야 하나요?

답변 : API 호출 시 전용선(또는 VPN)을 의무적으로 사용하지 않아도 됩니다.
(표준API 및 전송요구절차 가이드 참고)

Q5 | 개인정보관리 전문기관은 전송받은 개인정보 파기 시 어떠한 방식으로 처분해야 하나요?

답변 : 개인정보는 목적이 달성되거나 보유기간이 경과되면 지체없이 파기하도록 해야하고 개인정보의 안전성 확보조치 기준 제13조를 준수하여 복구되지 않도록 완전하게 파기해야 합니다.

발 행 일	2025년 03월
발 행 처	개인정보보호위원회
지원기관	한국인터넷진흥원

※ 최신자료는 “개인정보보호위원회 누리집(pipc.go.kr)”, “개인정보 포털(privacy.go.kr)”에서 확인할 수 있습니다.

개인정보관리 전문기관 지정 안내서



개인정보보호위원회
Personal Information Protection Commission